



Université Cadi AYYAD
L'école nationale des sciences appliquées - Marrakech
Département Réseaux et Télécommunications
Année académique 2021-2022



Rapport de stage de fin d'études

Pour obtenir le Diplôme d'Ingénieur d'Etat en
Réseaux & Télécommunications (GRT)

Orchestration, automatisation et réponse de la sécurité
(MONTER)

Réalisé à : Groupe Techso



Réalisé par :
M. Youness AIT ICHOU

Encadré par : M.
Othmane MENOVAR M. Anas
ABOU EL KALAM

Soutenue le 2 juillet 2022 devant le jury : M. Omar
ACHBAROU (Président)
M. Tarik HIDAR (Examineur)
M. Anas ABOU EL KALAM (Tuteur ENSA)
M. Othmane MENOVAR (Chef d'entreprise)

Dédicaces

A ma mère, à la flamme de l'espoir, à l'incarnation de l'abnégation, j'espère qu'elle trouvera dans ce modeste travail tout mon amour et toute ma gratitude.

A mon père, à celui qui s'aliène sans compter, celui qui m'a soutenu tout au long de mes études, je t'offre le travail que tu attendais.

A ma chère sœur et mon cher frère, personnes qui m'ont entouré tant de soutien moral et physique que de tendresse fraternelle. Je vous souhaite beaucoup de bonheur et de courage dans la vie.

A tous mes amis, de l'ENSAM et d'ailleurs, j'exprime mes sentiments de respect et d'amour.

Aux membres de l'équipe du Groupe Techso, votre apport en expertise et en savoir-faire m'a énormément aidé à grandir.

Je vous dédie cette modeste contribution, je ne peux exprimer ma gratitude que par des mots. Que Dieu vous garde et vous bénisse.

Reconnaissance

Je remercie Dieu Tout-Puissant qui m'a donné la force et la volonté de mener à bien ce projet.

Je tiens à exprimer mes sincères remerciements à mes chers parents qui m'ont éclairé et qui m'ont soutenu tout au long de mes études.

Je tiens également à remercier ma famille et mes amis bien-aimés qui m'ont toujours motivé et encouragé.

Je tiens à exprimer mes sincères remerciements à Monsieur MENOVAR Othmane « Professional Services & Security Operations Center Manager » et à Monsieur WARAKI Hamza « Chief Technical Officer » chez Techso Group de m'avoir autorisé à réaliser ce stage dans les meilleures conditions chez SOC département du Groupe Techso Casablanca.

Mes remerciements vont également à Monsieur ABOU EL KALAM Anas "Professeur-Chercheur", mon tuteur académique dans mon projet de stage de Fin d'Etudes, et à toute l'équipe pédagogique de l'Ecole Nationale des Sciences Appliquées de Marrakech pour avoir veillé à ce que nous acquérions les compétences nécessaires pour mener à bien de tels projets avec une grande efficacité.

Mes remerciements s'adressent également à tous les membres de l'équipe du Groupe Techso.

Abstrait

Afin d'assurer leurs performances croissantes, le centre des opérations de sécurité dispose d'une variété d'outils d'orchestration, d'automatisation et de réponse de la sécurité parmi lesquels choisir.

Le temps moyen de réponse joue un rôle énorme dans le temps dont disposera l'adversaire avant d'être détecté et bloqué.

L'objectif de ce projet est d'aider les équipes du centre des opérations de sécurité dans leur travail quotidien en leur permettant de se concentrer sur les menaces critiques plutôt que sur les menaces simples et connues.

Le grand nombre d'alertes auxquelles les équipes des centres d'opérations de sécurité sont confrontées chaque jour est un défi majeur qu'elles ne peuvent même pas relever sans l'aide de l'automatisation.

Ainsi, j'ai commencé par une phase de documentation afin de maîtriser le processus technique du travail d'orchestration, d'automatisation et de réponse de la sécurité, puis j'ai réalisé une implémentation de TheHive qui servait à organiser l'environnement de travail, Cortex pour l'automatisation, MISP qui sert de nos renseignements personnalisés sur les menaces, et enfin, des playbooks écrits en Python ont été utilisés pour améliorer le processus d'automatisation.

La possibilité d'ingérer automatiquement les données de Suricata, Kaspersky et de la boîte de réception des e-mails pour TheHive et rendre les observables avec leurs enrichissements disponibles pour les analystes sont les résultats.

En conclusion, nous verrons comment l'orchestration et l'automatisation peuvent aider le travail d'une équipe de centre d'opérations de sécurité et leur faciliter la vie.

Mots clés : TheHive, Cortex, MISP, SOC, SOAR, Orchestration, Automatisation, Réponse.

CV

Afin d'assurer leurs performances croissantes, le centre d'opérations de sécurité est doté d'une variété d'outils d'orchestration, d'automatisation et de réponse de sécurité parmi lesquels choisir. Le temps moyen de réponse joue un rôle énorme dans le temps dont il ne disposera pas l'adversaire avant d'être détecté et bloqué.

L'objectif de ce projet est d'aider les équipes du centre des opérations de sécurité dans leur travail quotidien en leur permettant de se concentrer sur les menaces critiques plutôt que sur les menaces simples et bien connues.

Le grand nombre d'alertes auxquelles les équipes des centres d'opérations de sécurité sont confrontées chaque jour est un défi majeur qu'elles ne peuvent même pas gérer sans l'aide de l'automatisation.

Ainsi, j'ai commencé par une phase de documentation afin de maîtriser le processus technique du travail d'orchestration, d'automatisation et de réponse de la sécurité, puis j'ai réalisé une implémentation de TheHive qui a été utilisée pour l'organisateur environnement de travail, Cortex pour l'automatisation, MISP qui sert de renseignement personnalisé sur les menaces, et enfin, des playbooks écrits en Python ont été utilisés pour améliorer le processus d'automatisation.

La possibilité d'ingérer automatiquement les données de Suricata, Kaspersky et de la boîte de réception des e-mails vers TheHive et de rendre les observables avec leurs enrichissements disponibles pour les analystes sont les résultats.

En conclusion, nous examinons comment l'orchestration et l'automatisation peuvent aider une équipe de centre des opérations de sécurité à travailler et à lui faciliter la vie.

Mots clés : TheHive, Cortex, MISP, SOC, SOAR, Orchestration, Automatisation, Réponse.

invesn.

ER fon
fér vrir

TheHive

MISP

Cortex

Python

lette

bur

invesn. Cortex MISP TheHive.

Table des matières

Dédicaces	je
Reconnaissance	II
Abstrait.....	III
CV.....	IV
V.....	
Liste des figures.....	IX
Liste des tableaux.....	XII
Liste des acronymes	XII
Introduction générale	1
Chapitre 1 : Contexte général	3
1. Introduction.....	4
2. La cybersécurité en chiffres.....	4
3. Groupe Techso.....	5
1. Présentation	5
2. Domaines d'activité et partenaires.	5
4. Contexte du projet et problématique	6
1. Travailler à travers le bruit	6
2. La fatigue d'alerte peut conduire à la négligence.....	7
3. La solution du projet.....	8
5. Gestion de projet – Diagramme de Gantt.....	dix
6. Conclusion	11
Chapitre 2 : Orchestration, automatisation et réponse de la sécurité	12
1. Introduction.....	13
2. Définition de l'orchestration, de l'automatisation et de la réponse de la sécurité.....	13
3. Objectif de l'orchestration, de l'automatisation et de la réponse de la sécurité.....	13
4. Cas d'utilisation de l'orchestration, de l'automatisation et de la réponse de la sécurité	13
5. Avantages de l'orchestration, de l'automatisation et de la réponse de la sécurité.....	14
1. Fournir des renseignements de meilleure qualité.....	14
2. Améliorer l'efficacité et l'efficacité des opérations	14
3. Amélioration de la réponse aux incidents	14
4. Rationalisation des rapports et de la capture des connaissances	15
6. Analyse comparative de l'orchestration, de l'automatisation et de la réponse de la sécurité ..	15
7. Le projet Hive	16

1. La définition du projet Hive.....	16
2. Le vocabulaire de la Ruche :	17
3. Fonctionnalités de TheHive	20
8. Cortex.....	20
1.Architecture.....	20
2. Analyseurs et répondeurs	21
9. DMU	21
1. Définition du MISP	21
2. Fonctionnalités MISP.....	22
dix. Conclusion.....	23
Chapitre 3 : Installation et configuration (TheHive, Cortex et MISP).....	24
1. Introduction.....	25
2. Installation et configuration de TheHive	26
1. Vue d'ensemble	26
2. Notice d'installation	27
3. Déploiement d'un reverse proxy	31
4. Création d'organisations et ajout d'utilisateurs.....	33
5. Guides de configuration.....	33
6. Créer des tableaux de bord.....	34
7. Créer des champs et des modèles personnalisés.....	36
3. Installation et configuration du cortex	40
1. Prérequis matériels :	40
2. Le guide d'installation pour RPM :	40
3. Analyseurs et répondeurs	46
4. Intégration de TheHive et Cortex.....	49
1. Création d'un utilisateur dédié dans le cortex pour les appels d'API.....	49
2. Créer un tunnel ssh	49
5. Installation et configuration du MISP.....	51
1. Configuration matérielle requise pour le MISP	51
2. Instructions d'installation pour le serveur Ubuntu 20.04.2.0	51
3. Ajout de flux au MISP.....	51
6. Intégration de TheHive et MISP	52
Chapitre 4 : Cas d'utilisation.....	53
1. Introduction.....	54
2. Scénario : Utilisation manuelle	55

3. Scénario : Guide de phishing.....	58
4. Scénario : Playbook Suricata	60
5. Scénario : Kaspersky playbook.....	61
6. Conclusion	62
Conclusion générale	63
Bibliographie / Webographie	65
Annexe.....	- 1 -
1. Installation et configuration de TheHive	- 2 -
2. Création de certificats numériques.....	- 4 -
3. Intégration de TheHive et Cortex.....	- 21 -
4. Installation et configuration du MISP.....	- 23 -
5. Intégration de TheHive et MISP	- 28 -
6. Gravité, TLP et PAP.....	- 31 -
7. Scénario : Utilisation manuelle	- 32 -
8. Scénario : Guide de phishing.....	- 35 -
9. Scénario : Playbook Suricata	- 37 -
10. Scénario : Playbook de Kaspersky.....	- 38 -

Liste des figures

Figure 1 : Présence du Groupe Techso	5
Figure 2 : Alertes de sécurité reçues quotidiennement par les SOC.....	7
Figure 3 : SOC traitant trop d'alertes.....	7
Figure 4 : Temps passé par les membres du SOC sur les alertes de sécurité.....	8
Figure 5 : Diagramme de Gantt ..	11
Figure 6 : Autorisations des profils	18
Figure 7 : Champs observables.....	19
Figure 8 : Architecture corticale	21
Figure 9 : Principaux composants de TheHive	26
Figure 10 : modifications du fichier cassandra.yml	28
Figure 11 : changements dans application.conf cassandra.....	30
Figure 12 : changements d'index application.conf	31
Figure 13 : modifications du système de fichiers application.conf	31
Figure 14 : Architecture de l'instance TheHive	32
Figure 15 : Créer un nouveau tableau de bord (1).	34
Figure 16 : Page Tableau de bord (1)	35
Figure 17 : Page Tableau de bord (2)	35
Figure 18 : Page Tableau de bord (3)	36
Figure 19 : Ajouter un champ personnalisé (1).....	36
Figure 20 : Ajouter un champ personnalisé (2).....	37
Figure 21 : Champs personnalisés	37
Figure 22 : Ajouter un nouveau modèle (1)	38
Figure 23 : Ajouter un nouveau modèle (2)	38
Figure 24 : Ajouter un nouveau modèle (3)	39
Figure 25 : fichier elasticsearch.yml	41
Figure 26 : Cortex première connexion (1).....	42
Figure 27 : Cortex première connexion (2)..	43
Figure 28 : Cortex première connexion (3).....	43
Figure 29 : Première connexion au cortex (4).....	44
Figure 30 : Architecture d'instance Cortex	44
Figure 31 : Créer une organisation dans Cortex.....	46
Figure 32 : Créer un utilisateur dans Cortex.....	46
Figure 33 : Architecture du tunnel SSH.....	49
Figure 34 : Intégration Cortex & TheHive effectuée	50
Figure 35 : La page des cas Hive	55
Figure 36 : Créer un nouveau cas (1).....	56
Figure 37 : Créer un nouveau cas (2).....	56
Figure 38 : Créer un nouvel observable.....	57
Figure 39 : Flux de travail du manuel de hameçonnage.....	58
Figure 40 : Flux de travail du livre de jeu Suricata ..	60
Figure 41 : État du service Suricata systemd	61
Figure 42 : Flux de travail du playbook de Kaspersky	61
Figure 43 : Configuration de la base de données, de la base de données et du système de fichiers	62
Schéma 44 : La page de connexion de TheHive	62

Figure 45 : La page des organisations du Hive.....	-
3 - Figure 46 : première configuration de reverse-proxy.conf.	-
3 - Figure 47 : première configuration de reverse-proxy.conf	4
- Figure 48 : application.conf localhost à l'écoute	4
Figure 49 : Infrastructure PKI	5
Figure 50 : Importer le fichier pkcs12 (1)	6
Figure 51 : Importer le fichier pkcs12 (2).....	7
Figure 52 : Importer le fichier pkcs12 (3).....	7
Figure 53 : https vers TheHive	8
Figure 54 : Changer le mot de passe administrateur (1).....	8
- Figure 55 : Modifier le mot de passe administrateur (2).....	9
- Figure 56 : Modifier le mot de passe administrateur (3)	-
9 - Figure 57 : Créer une organisation (1).....	10
Figure 58 : Créer une organisation (2)	10
Figure 59 : Créer un utilisateur (1)	11
Figure 60 : Créer un utilisateur (2)	11
Figure 61 : Créer un utilisateur (3)	12
Figure 62 : Créer un utilisateur (4)	12
Figure 63 : Créer un utilisateur (5)	13
- Figure 64 : Créer un utilisateur (6)	13
Figure 65 : Créer un nouveau tableau de bord (2)..	-
14 - Figure 66 : Créer un nouveau tableau de bord (3).....	-
14 - Figure 67 : Créer un nouveau tableau de bord (4)	-
15 - Figure 68 : Créer un nouveau tableau de bord (5)	-
15 - Figure 69 : Création d'un nouveau tableau de bord (6).....	-
16 - Figure 70 : Création d'un nouveau tableau de bord (7)	-
16 - Figure 71 : Création d'un nouveau tableau de bord (8)	-
17 - Figure 72 : apt032.appt.emulab.net.conf	-
17 - Figure 73 : Marche arrière fichier de configuration proxy	18
18 - Figure 74 : Configuration Analyseurs Répondeurs	18
18 - Figure 75 : Activer un analyseur (1).....	19
19 - Figure 76 : Activer un analyseur (2).....	19
19 - Figure 77 : Activer un analyseur (3)	20
20 - Figure 78 : Analyser une adresse IP (1)	20
20 - Figure 79 : Analyser une adresse IP (2).....	21
21 - Figure 80 : Créer un utilisateur Cortex à intégrer à TheHive (1)	21
21 - Figure 81 : Créer un utilisateur Cortex à intégrer à TheHive (2)	22
22 - Figure 82 : Configuration de l'intégration Cortex TheHive	23
23 - Figure 83 : Options d'installation du MISP.....	23
23 - Figure 84 : Page de connexion au MISP	24
24 - Figure 85 : MISP changer le mot de passe	24
24 - Figure 86 : MISP ajoute des flux (1).	25
25 - Figure 87 : MISP ajouter des flux (2).....	25
25 - Figure 88 : MISP ajouter des flux (3)	26
26 - Figure 89 : MISP ajouter des flux (4).....	26
26 - Figure 90 : MISP ajouter des flux	

Figure 91 : MISP ajouter des flux (6).....	- 27
- Figure 92 : MISP ajouter des flux (7).....	- 28
- Figure 93 : MISP ajouter des flux (8).....	-
28 - Figure 94 : Clé API MISP (1).....	-
29 - Figure 95 : Clé API MISP (2)	- 29 -
Figure 96 : configuration du MISP application.conf	- 30 -
Figure 97 : Intégration TheHive et MISP.....	- 30
- Figure 98 : Exporter le cas de TheHive vers MISP (1)	- 31
Figure 99 : Exporter le cas de TheHive vers MISP (2)	- 31 -
Figure 100 : Ajouter des motifs MITRE ATT&CK (1).....	- 32 -
Figure 101 : Ajouter des motifs MITRE ATT&CK (2)	- 33 - Figure
102: Données des modèles MITRE ATT&CK	- 33 - Figure
103 : Ajouter des taxonomies MISP (1)	- 34 -
Figure 104 : Ajouter des taxonomies MISP (2)	34
- Figure 105 : Ajouter des taxonomies MISP (3)	35-
- Figure 106 : code python de phishing.....	- 37 -
Figure 107 : Code python Suricata	- 38 -
Figure 108 : Code python de Kaspersky	- 39 -
Image 109 : Cartographie proxy Suricata.....	-
40 - Figure 110 : Mappage proxy Kaspersky....	- 40 -

Liste des tableaux

Tableau 1 : Autorisations de TheHive.....18

Tableau 2 : Champs observables.....20

Tableau 3 : Pré-requis matériels TheHive26

Liste des acronymes

U	N
API : interface de programmation d'applications, 39	
ATT&CK : tactiques, techniques et actions communes	
Connaissance, 32	
C	
CERT : équipe d'intervention en cas d'urgence informatique, 30 ans	
CSIRT : équipe de réponse aux incidents de sécurité informatique, 30	
CSOC : Centre des opérations de cybersécurité, 28	
H	
HIDS : Systèmes de détection d'intrusion sur l'hôte, 36	
I	
IDS : Système de détection d'intrusion, 28	
E/S : sortie d'entrée, 40	
IoC : Indicateurs de compromission, 28	
IP : protocole Internet, 28	
Informatique : technologie de l'information, 28	
M	
MTTD : Temps moyen de détection, 23	
MTTR : Temps moyen de réponse, 23	
N	
NFS : système de fichiers réseau, 40	
	NIDS : Système de détection d'intrusion réseau, 36
	P
	PKI : infrastructure à clé publique, 39
	S
	SIEM : gestion des informations et des événements de sécurité, 28
	SIRP : Plateforme de réponse aux incidents de sécurité, 27, 29
	SOAR : Orchestration de la sécurité, automatisation et
	Réponse, 22
	SOC : Centre des opérations de sécurité, 20
	SSH : shell sécurisé, 39
	SSL : couche de sockets sécurisée, 39
	J
	CONSEIL : Plate-forme de renseignements sur les menaces, 27
	TLP : Protocole des feux de circulation, 33
	TLS : Sécurité de la couche transport, 39
	TTP : Tactiques, techniques et procédures, 28
	tu
	UEBA : Analyse du comportement des utilisateurs et des entités, 28
	URL : Localisateur de ressources uniformes, 33
	V
	VT : VirusTotal, 35

Introduction générale

Orchestration, automatisation et réponse de la sécurité

Les organisations en charge de la cybersécurité ont du pain sur la planche. Ils agissent comme la dernière ligne de défense dans la lutte contre les cybermenaces, protégeant les précieux actifs informatiques de leurs entreprises contre les cyberattaques. Cependant, ce ne sont pas des parias sociaux qui envoient des virus depuis le sous-sol de leurs parents.

Les cybercriminels sont aujourd'hui plus puissants et sophistiqués que jamais. Dans leurs efforts pour voler des données, commettre des fraudes, abuser des ressources et perturber les services, les attaquants sont ingénieux et brutaux. Ils sont également patients et ont beaucoup de chiffres de leur côté.

Les attaquants échangent des informations et investissent dans la recherche et le développement. Ce sont de puissants États-nations et des réseaux criminels organisés.

Les professionnels de la cybersécurité sont bien conscients qu'aucune cyberattaque ne peut être complètement évitée. Bien qu'une solide approche de défense en profondeur soit essentielle, ce n'est pas l'alpha et l'oméga de la cybersécurité. En conséquence, les entreprises changent d'orientation pour inclure une détection et une réponse rapides, la vitesse étant la clé. À quelle vitesse l'équipe peut-elle détecter une menace réelle et mettre fin à une attaque ? Plus il peut détecter et réagir rapidement, plus le risque d'exfiltration de données, de fraude financière et d'interruption de service est faible.

La technologie facilite la conduite des affaires, la connexion avec les gens et la vie.

Cependant, ces développements posent des risques pour la sécurité au travail, à la maison et ailleurs. Les améliorations de la sécurité ont toujours été en contradiction avec les progrès technologiques, et le personnel de sécurité est inévitablement tiré dans les deux sens.

Le nombre d'alertes augmente, les piles de produits de sécurité se multiplient et le paysage des menaces s'étend. Les analystes de la sécurité sont difficiles à trouver et à conserver, ce qui oblige les équipes en sous-effectif à passer au crible les données à la main pendant que les bougies s'éteignent. C'est un travail difficile.

Les équipes de sécurité ont besoin de quelque chose — une technologie, une procédure — qui unifie l'intelligence de plusieurs outils de sécurité et simplifie la visibilité des données. Ils doivent également passer moins de temps sur des tâches répétitives.

L'orchestration de la sécurité occupe une place centrale. Je peux simplement le définir comme le fait de faire fonctionner ensemble une collection de produits de manière coordonnée sous votre contrôle pour protéger la sécurité de votre entreprise.

Chapitre 1 : Contexte général

1. Introduction

Avant d'aborder le cœur technique de notre projet, nous consacrons ce chapitre préliminaire à présenter la société hôte Groupe Techso dont le projet a eu lieu, ses missions, ses activités ainsi que l'équipe de validation qui a supervisé ce travail. Ce projet consiste principalement à orchestrer les outils de cybersécurité utilisés pour défendre les actifs des organisations et à automatiser certains des processus d'enrichissement et de réponse pour permettre aux analystes de se concentrer sur les menaces les plus critiques.

2. La cybersécurité en chiffres

Le Maroc est classé au 34e rang mondial en termes de pays ciblés par les cyberattaques, selon un rapport de Kaspersky [1]. Le Maroc a également été classé troisième dans l'enquête sur les attaques contre les systèmes de contrôle industriels.

L'offre de cybersécurité au Maroc se caractérise par une forte présence internationale comprenant :

- Entreprises américaines (Symantec, Fortinet, Palo Alto Networks...) • Acteurs européens (Bitdefender, Kaspersky...) • Entreprises françaises (Orange Cyberdefense, Thales, Devotea, Atos...)

Entreprises Marocaines de Cybersécurité

- Protection des données

Fondée en 2009, compte plus de 150 employés et fournit une gamme complète de services allant du conseil, de la gestion de l'information, de l'intégration et de la formation à la surveillance de l'infrastructure via son SOC 24/7 [2].

- Groupe LMPS

Fondé en 2007, LMPS Group propose des services de cybersécurité au secteur industriel et automobile en particulier [3].

- Quasi-sécurisé

Nearsecure est un Prestataire de Services d'Audit pour la Sécurité des Systèmes d'Information Sensibles des Infrastructures Critiques (PASSI) certifié par la DGSSI [4].

- Groupe TECHSO

Créé en 2021, le Groupe TECHSO [5] est une entreprise spécialisée dans la cybersécurité, son offre est structurée autour des thématiques suivantes :

Conseil en sécurité

Développement et mise en place d'architectures sécurisées Mise en place de solutions de cybersécurité Accompagnement de la concurrence dans le cadre de projets réglementaires (PCI-DSS, CSP SWIFT, ISO 27001, DNSSI et loi 05-20 etc.)

Les marchés de la cybersécurité

Selon une étude de 2018 de l'Association des Utilisateurs des Systèmes d'Information Marocains (AUSIM) sur le secteur de la cybersécurité au Maroc [1], la grande majorité des entreprises réalisent

nécessité de la cybersécurité, mais les ressources allouées sont insuffisantes. La même étude, portant sur les grandes entreprises du secteur tertiaire, a découvert que :

- 84 % de ces entreprises avaient développé un programme de cybersécurité • 86 % offraient des programmes de formation et de sensibilisation des employés • 86 % avaient adopté une ou plusieurs normes de sécurité (ISO 27001, DNSSI, etc.) • 63 % des organisations avaient deux employés ou moins affectés à cybersécurité • 62% investis sous 1 million MAD par an dans la cybersécurité • 45% envisagent d'augmenter ce montant à court terme

3. Groupe Techso

Le Groupe Techso est une entreprise spécialisée dans la cybersécurité dont les convictions sont fortement liées à ses expériences, à l'expertise et au savoir-faire de son équipe [5].

1. Présentation

Le groupe Techso s'est développé pour inclure trois bureaux locaux dans trois pays distincts : le Maroc, la France et le Sénégal. Avec une taille d'entreprise de 11 à 50 employés.

La résilience cybersécurité de nos clients est notre raison d'être !



Figure 1 : Présence du Groupe Techso

Technoparc, Bd Damman
Bureau 104
20000 Casablanca

25 rue de Ponthieu
75008Paris

EXTERNALISATION EN AFRIQUE
131 Cité Keur Gorgui, VDN,
6ème étage BP : 23 119
Dakar

2. Domaines d'activité et partenaires.

La transformation digitale s'accélère et offre de réelles opportunités pour proposer des services à valeur ajoutée aux entreprises. Cependant, il présente de nombreuses menaces pour les entreprises avec l'ouverture des systèmes d'information à de nouveaux partenaires.

Le Groupe Techso met à votre disposition une équipe d'experts, certifiés ISO 27001, ISO 27005, CISM ou CISSP ou spécialistes en continuité d'activité (CBCP, CBCI, ISO 22301), en investigation

Orchestration, automatisation et réponse de la sécurité

(appellations CCFP, CCE, CHFI, CFCE, GSFA, GSFE GIAC), pour vous accompagner dans vos projets de renforcement de la sécurité de vos données.

1) Offre du Groupe Techso

Soutien

Une équipe d'experts pour vous accompagner et vous conseiller dans la conception et la mise en œuvre de vos projets de cybersécurité.

gestion IT

Mettez une solide expérience dans le domaine de l'externalisation de la cybersécurité à votre service.

Solutions

Votre partenaire stratégique pour la mise en œuvre de vos projets de conception et d'implémentation de solutions techniques en cybersécurité.

Entraînement

Grâce à notre catalogue de formations riche et varié, permettez à vos collaborateurs de développer leur savoir-faire en cybersécurité.

2) Partenaires

Plus de 19 Partenaires dont (Fortinet, IBM, Paloalto, CISCO, Symantec, Elastic, BeyondTrust, Wallix, Tripwire, Kaspersky, PECB, EC-Council, Barracuda...)

4. Contexte du projet et problématique

1. Travailler à travers le bruit

Pas moins de 27 % des experts en informatique ont déclaré recevoir plus d'un million de menaces par jour, tandis que 55 % ont déclaré en recevoir plus de 10 000 <Figure 2>. Bien qu'il soit presque impossible de répondre à un si grand nombre, distinguer les menaces réelles des fausses alertes positives est également un défi de taille. La majorité des professionnels de l'informatique (53 %) ont déclaré que le SOC (Security Operations Center) de leur entreprise avait du mal à faire la distinction entre les problèmes de sécurité critiques et non critiques [6].

Que se passe-t-il s'il y a trop d'alarmes à gérer pour les analystes du SOC ? Dans certaines circonstances, rien du tout. Un pourcentage surprenant de 30 % des personnes interrogées ont déclaré avoir complètement ignoré certains types d'alertes, tandis que 4 % ont déclaré avoir complètement désactivé les alertes de sécurité. Sur une note un peu plus optimiste, 10 % ont déclaré avoir embauché de nouveaux ingénieurs SOC pour les aider à gérer ces alertes, et 57 % ont déclaré avoir modifié leurs politiques pour réduire le volume d'alertes <Figure 3>.



Figure 2 : Alertes de sécurité reçues quotidiennement par les SOC

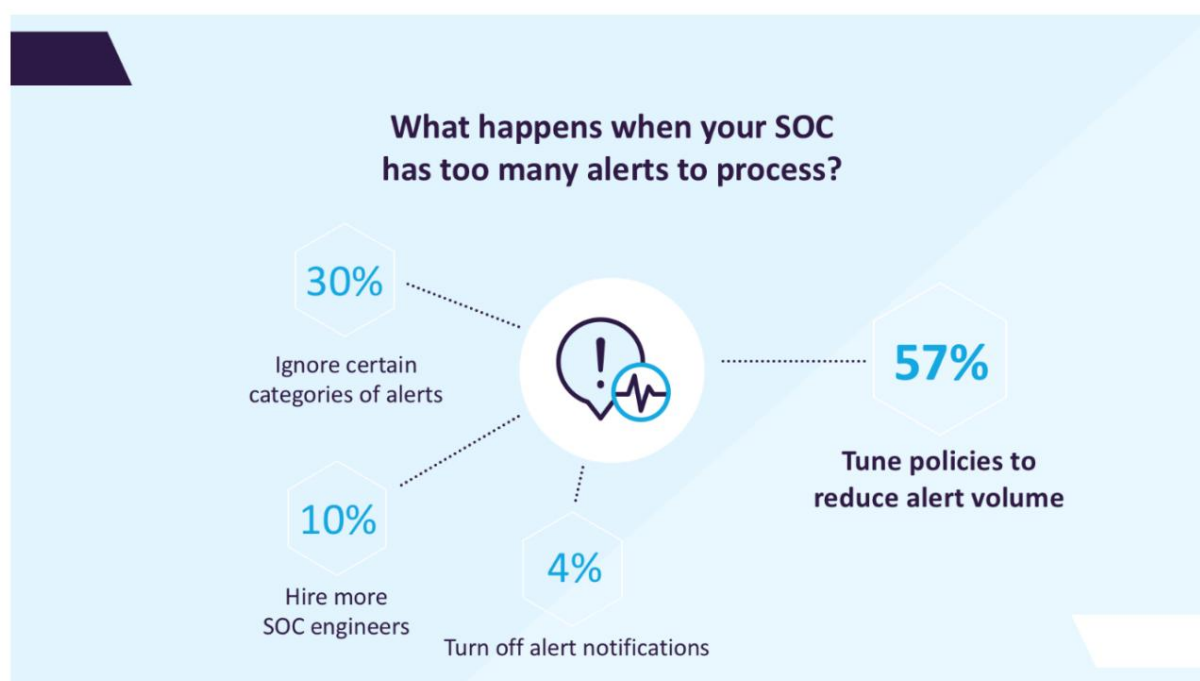


Figure 3 : SOC traitant trop d'alertes

2. La fatigue d'alerte peut conduire à la négligence

L'ampleur des événements quotidiens et le nombre frustrant de faux positifs montrent que le personnel de sécurité n'est pas démotivé lorsqu'il ignore les alertes. Par conséquent, il peut être tentant d'ignorer les futures alertes. Sur la base d'expériences précédentes de faux positifs, 56 % des informaticiens ont reconnu avoir ignoré une alerte dans notre enquête. Les alertes ignorées, en revanche, peuvent entraîner des pertes irréversibles. Les entreprises perdent de l'argent, les équipes SOC perdent du temps et les clients sont mis en danger.

Même si les alertes ne se transforment pas en menaces réelles, elles présentent des défis pour ceux qui doivent y faire face. La rapidité avec laquelle ces notifications arrivent régulièrement crée un environnement de travail exigeant et épuisant pour le personnel du SOC. Seuls 6 % des répondants ont déclaré ne ressentir aucun stress supplémentaire à la suite de ces cas, tandis que 54 % ont déclaré ressentir beaucoup de tension et d'insatisfaction <Figure 4>.

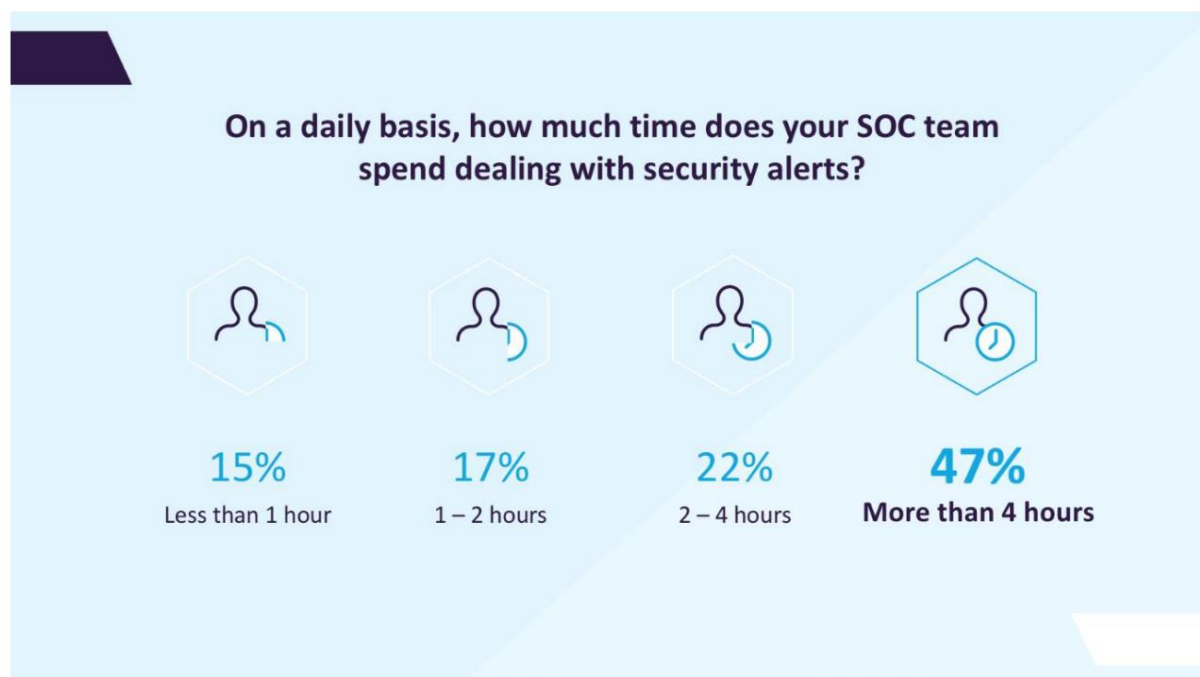


Figure 4 : Temps passé par les membres du SOC sur les alertes de sécurité

3. La solution du projet

L'objectif principal de ce projet est de créer un système d'orchestration, d'automatisation et de réponse de la sécurité, ainsi que d'améliorer le travail du centre des opérations de sécurité et de le rendre plus apte à faire face à des attaques de plus en plus graves.

Jetons un coup d'œil à certains des principaux avantages.

1) Temps de réponse plus rapide

L'orchestration de la sécurité regroupe plusieurs alertes associées provenant de systèmes disparates en un seul incident. En économisant encore plus de temps, l'automatisation de la sécurité permet au système de répondre aux alertes sans intervention humaine dans la mesure du possible. La mise en contexte des données textuelles et l'automatisation du processus de prise de décision permettent un processus de traitement des alertes plus rapide.

2) Optimisation du renseignement sur les menaces

La Threat Intelligence fournit des informations utiles, mais c'est trop souvent l'arbre qui tombe sans que personne ne l'entende. Les analystes du SOC sont constamment confrontés à une surcharge d'informations. Ajouter des renseignements sur les menaces aux piles de mélange sur plus d'informations à trier. Les meilleures plates-formes SOAR (Security Orchestration, Automation and Response) peuvent ingérer des informations sur les menaces et les corréler automatiquement avec des événements en temps réel. Cela soulage les analystes du SOC et fournit des informations immédiatement exploitables aux équipes de réponse aux incidents.

3) Processus standardisés et opérations manuelles réduites

L'automatisation de la sécurité soulage les analystes SOC des tâches banales et répétitives et les inclut dans un processus global de gestion d'un incident donné. Une bonne plate-forme SOAR intégrera ces tâches dans des playbooks qui exposent les étapes de réponse aux incidents de bout en bout.

4) Efficacité opérationnelle

Chaque élément de SOAR contribue à la rationalisation des opérations de sécurité. L'orchestration de la sécurité agrège les données provenant de diverses sources. L'automatisation de la sécurité, quant à elle, peut facilement gérer les alertes et les incidents de faible priorité grâce à l'utilisation de playbooks automatisés. La réponse aux incidents élimine les conjectures du moment dans la gestion des événements, limitant le temps d'attente des cyberattaques et l'impact global sur l'entreprise.

5) Réduire l'impact des cyberattaques

Le temps moyen de détection (MTTD) et le temps moyen de réponse (MTTR) sont des mesures critiques qui affectent l'impact d'une cyberattaque sur une organisation. Plus il faut de temps pour détecter et répondre à une attaque, plus les dommages peuvent être causés et plus l'impact sur l'organisation est important.

SOAR minimise à la fois le MTTD et le MTTR. L'orchestration de la sécurité réduit le MTTD en fournissant des détails riches en contexte sur chaque incident, ce qui permet aux analystes de passer moins de temps à collecter des informations et plus de temps à enquêter sur l'alerte. L'automatisation de la sécurité réduit le MTTR en répondant automatiquement aux alertes et aux incidents en temps réel.

6) Intégration facile de la technologie et des outils

L'un des avantages de l'orchestration de la sécurité est la possibilité de corréler les alertes d'une grande variété de produits et de technologies. Cela va bien au-delà du SIEM. Une plate-forme SOAR doit pouvoir s'intégrer aux produits de diverses technologies de sécurité :

- Sécurité cloud •

Enrichissement des données

- Sécurité des e-mails

- Sécurité des terminaux •

Analyse médico-légale et des logiciels

malveillants • Gestion des identités et des

accès • Informatique et infrastructure

- Sécurité du réseau •

SIEM et gestion des journaux • Threat

Intelligence • Vulnérabilité et gestion

des risques

L'intégration de ces produits dans votre plateforme SOAR devrait être facile. Une place de marché en libre-service peut accéder rapidement à l'intégration d'un produit spécifique. À partir de là, l'intégration est aussi simple que de cliquer sur un bouton et d'insérer des composants dans un playbook.

7) Réduction des coûts

Une entreprise typique réalisera des économies importantes en intégrant une plate-forme SOAR dans son modèle commercial.

- 90 % sur le reporting • 80 % sur la création de playbooks • 70 % sur la gestion des alertes • 60 % sur la formation des analystes • 30 % sur la gestion des équipes

8) Capacités de reporting et de métriques automatisées

Les rapports automatisés ne facilitent pas seulement la vie ; ils éliminent le besoin de métriques produites manuellement. En permettant au personnel du SOC de générer des rapports à la demande - de préférence en un clic - ou automatiquement selon un calendrier, les entreprises reçoivent des métriques fiables et opportunes pour chaque période de rapport. Pour simplifier davantage ce processus, la plupart des outils SOAR fournissent des modèles de rapport et la possibilité de générer des rapports personnalisés.

9) Communication normalisée de réponse aux incidents

La gestion et la réponse aux incidents nécessitent souvent d'atteindre l'extérieur du SOC, en particulier pour les incidents majeurs. Cela signifie que les équipes de réponse aux incidents peuvent inclure des parties prenantes à la fois à l'intérieur et à l'extérieur du SOC, ce qui rend difficile l'établissement d'un flux d'informations fiable et reproductible.

Pour atténuer ce problème, les entreprises forment souvent un centre de contrôle de mission pour gérer les incidents prioritaires. Une bonne plate-forme SOAR aura une fonction de salle de guerre virtuelle pour garantir que la communication critique est normalisée afin d'empêcher tout membre de l'équipe, des relations publiques et des RH au service juridique en passant par la suite C, de manquer des informations critiques lors d'une réponse à un incident [7].

5. Gestion de projet – Diagramme de Gantt

Le diagramme de Gantt est le diagramme le plus utilisé en gestion de projet ; il permet d'organiser un projet et de définir l'ordre dans lequel les tâches doivent être réalisées. Il est généralement présenté sous la forme d'un graphique à barres horizontales. Ces derniers sont de différentes longueurs et représentent la chronologie du projet, qui peut inclure des séquences de tâches, des durées et des dates de début et de fin pour chaque tâche. Ils montrent également à quel point une tâche a progressé. Un diagramme de Gantt peut également être utilisé pour planifier, gérer et contrôler les tâches et les ressources d'un projet individuel.

<Figure 5> représente le diagramme de Gantt qui donne une visibilité sur l'avancement global du projet, afin d'assurer le bon déroulement du projet, il est très nécessaire de le diviser en tâches distinctes, en précisant la durée de chaque mission.

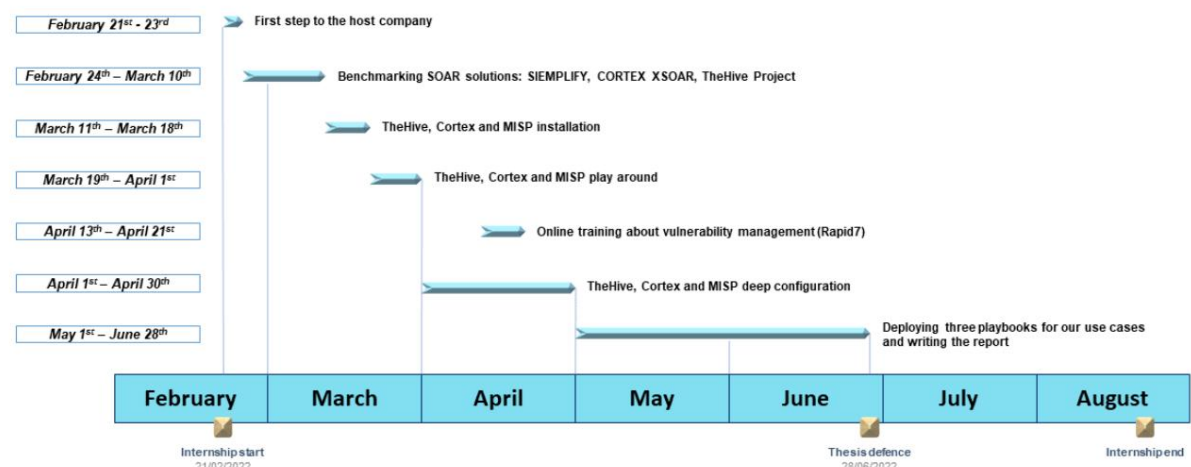


Figure 5 : Diagramme de Gantt

6. Conclusion

Dans ce chapitre, nous avons examiné l'industrie de la cybersécurité au Maroc, ainsi que l'entreprise hôte, qui a fonctionné comme notre principale organisation, comme exemple des types de services de sécurité donnés. Ensuite, nous nous sommes penchés sur le contexte du projet et la problématique à laquelle presque tous les centres d'opérations de sécurité sont confrontés : le bruit du nombre massif d'alertes reçues chaque jour, qui peut conduire à une fatigue d'alerte, qui à son tour peut conduire à une négligence, dangereuse pour un entreprise qui accorde toute sa confiance à l'équipe SOC. Enfin et surtout, il y avait le contexte du projet, qui apportait la réponse à toutes les questions précédentes.

Chapitre 2 : Orchestration de la sécurité, Automatisation et réponse

1. Introduction

Un SOC (Security Operations Center) est un lieu centralisé de surveillance et de contrôle réguliers de la sûreté et de la sécurité de l'entreprise. En utilisant les données des terminaux, des journaux, des systèmes de sécurité et des flux réseau, l'objectif principal du SOC est d'améliorer les capacités de détection, d'investigation et de réponse aux incidents. En outre, un SOC efficace peut aider les entreprises à améliorer la connaissance de la situation et à accroître le déploiement des ressources de l'entreprise pour répondre aux problèmes de sécurité. Les cybermenaces, en revanche, constituent un sérieux défi pour le SOC. Le nombre d'alertes générées par ces attaques croît de manière exponentielle, obligeant les professionnels de la sécurité à travailler tard. Alors, comment pouvons-nous rationaliser et organiser le travail de l'équipe, afin qu'elle puisse se concentrer sur les menaces réelles et critiques plutôt que de perdre du temps sur des tâches redondantes ?

2. Définition de l'orchestration, de l'automatisation et de la réponse de la sécurité

SOAR (Security Orchestration, Automation and Response) fait référence à la convergence de trois marchés technologiques distincts : l'orchestration et l'automatisation de la sécurité, les SIRP (plateforme de réponse aux incidents de sécurité) et les plateformes de renseignements sur les menaces (TIP).

Les technologies SOAR permettent aux organisations de collecter et d'agréger de grandes quantités de données de sécurité et d'alertes à partir d'un large éventail de sources. Cela permet de créer des processus automatisés pour répondre aux événements de sécurité de bas niveau et de standardiser les procédures de détection et de correction des menaces.

Le terme a été initialement inventé par le cabinet de recherche Gartner, qui a depuis décrit trois capacités principales des technologies SOAR :

- Workflow de réponse aux incidents •
Enrichissement des données
- Automatisation des contrôles de sécurité

3. Objectif d'orchestration, d'automatisation et de réponse de la sécurité

Travailler dans les opérations de sécurité peut être une lutte constante. La rapidité et l'efficacité sont essentielles, mais il peut être difficile de s'assurer que tous vos systèmes fonctionnent en harmonie. Les analystes sont souvent submergés par le volume d'alertes provenant de systèmes disparates. L'obtention et la corrélation des données nécessaires pour séparer les véritables menaces des faux positifs peuvent être une tâche onéreuse. La coordination des mesures d'intervention appropriées pour remédier à ces menaces est un autre défi.

Le but de la sécurité SOAR est d'atténuer tous ces défis en améliorant l'efficacité.

Il fournit un processus standardisé d'agrégation de données pour faciliter l'analyse humaine et machine et automatise les processus de détection et de réponse pour aider à réduire la fatigue des alertes, permettant aux analystes de se concentrer sur les tâches qui nécessitent une analyse et une intervention humaines plus approfondies.

4. Cas d'utilisation de l'orchestration de la sécurité, de l'automatisation et de la réponse

Les cas d'utilisation courants de la sécurité SOAR incluent :

- Un volume élevé de processus de sécurité manuels, créant un besoin d'automatisation

- Assistance supplémentaire avec réponse aux incidents requise par l'équipe de sécurité interne
- Évaluation et réponse aux e-mails de phishing
- Plusieurs outils et solutions de cybersécurité utilisés

5. Avantages de l'orchestration, de l'automatisation et de la réponse de la sécurité

Face à des menaces en constante évolution, à une pénurie de personnel de sécurité qualifié et à la nécessité de gérer et de surveiller des parcs informatiques en pleine croissance, SOAR aide les entreprises de toutes tailles à améliorer leur capacité à détecter et à réagir rapidement aux attaques. Il répond aux besoins de cybersécurité en :

1. Fournir des renseignements de meilleure qualité

La lutte contre les menaces de cybersécurité de plus en plus sophistiquées nécessite une compréhension approfondie des TTP des attaquants et la capacité d'identifier les IoC (indicateurs de compromis). En agrégeant et en validant les données d'un large éventail de sources, y compris les plates-formes de renseignement sur les menaces, les échanges et les technologies de sécurité telles que les pare-feu, les systèmes de détection d'intrusion, les technologies SIEM et UEBA, SOAR aide les SOC à devenir plus axés sur le renseignement. Cela signifie que le personnel de sécurité est en mesure de contextualiser les incidents, de prendre des décisions plus éclairées et d'accélérer la détection et la réponse aux incidents.

2. Améliorer l'efficacité et l'efficacité des opérations

La gestion de nombreuses technologies de sécurité disparates peut mettre à rude épreuve le personnel de sécurité. Non seulement les systèmes ont besoin d'une surveillance constante pour garantir leur intégrité et leurs performances continues, mais les milliers d'alarmes quotidiennes qu'ils génèrent peuvent également entraîner une fatigue des alertes. Cette situation est exacerbée par la commutation constante entre plusieurs systèmes, ce qui coûte du temps et des efforts aux équipes, tout en augmentant les risques d'erreurs.

Les solutions SOAR aident les CSOC à automatiser et semi-automatiser certaines des tâches quotidiennes et banales des opérations de sécurité. En présentant l'intelligence et les contrôles à travers une seule fenêtre et en utilisant l'IA et l'apprentissage automatique, les outils SOAR peuvent réduire considérablement la nécessité pour les équipes SOC de passer d'une technologie à une autre.

La sécurité SOAR peut également aider à garantir que les processus sont gérés plus efficacement et à améliorer la productivité et la capacité des organisations à traiter davantage d'incidents sans qu'elles aient à recruter plus de personnel. Cela signifie que l'un des principaux avantages de SOAR est qu'il aide le personnel de sécurité à travailler plus intelligemment plutôt que plus durement.

3. Amélioration de la réponse aux incidents

Une réponse rapide est essentielle pour minimiser le risque d'infractions et limiter les dommages et les perturbations considérables qu'elles peuvent causer. SOAR aide les organisations à réduire le temps moyen de détection (MTTD) et le temps moyen de réponse (MTTR) en permettant aux alertes de sécurité d'être qualifiées et corrigées en quelques minutes, plutôt qu'en jours, semaines et mois.

SOAR permet également aux équipes de sécurité d'automatiser les procédures de réponse aux incidents (appelées playbooks). Les réponses automatisées peuvent inclure le blocage d'une adresse IP sur un pare-feu ou un système IDS, la suspension de comptes d'utilisateurs ou la mise en quarantaine des terminaux infectés d'un réseau.

4. Rationalisation des rapports et de la capture des connaissances

Dans de nombreux centres d'opérations de cybersécurité, les travailleurs de première ligne peuvent consacrer un temps disproportionné à la gestion des cas, à la création de rapports et à la documentation des procédures de réponse aux incidents. En agrégeant des renseignements provenant d'un large éventail de sources et en présentant ces informations via des tableaux de bord personnalisés, SOAR peut aider les organisations à réduire la paperasserie tout en améliorant la communication entre la suite C et le personnel de première ligne.

En automatisant les tâches et les procédures, SOAR permet également aux organisations de conserver des connaissances clés face à la pénurie mondiale de compétences en cybersécurité.

L'exécution plus rapide des tâches signifie un meilleur délai de résolution. Ceci est vital car plus les menaces restent longtemps sans réponse, plus les risques de dommages et de perturbations sont grands.

6. Orchestration, automatisation et réponse de la sécurité

analyse comparative

Selon le site Web bien connu Gartner [8] (qui est une société de recherche et de conseil, qui fournit des informations liées à la technologie à ses clients pour prendre les bonnes décisions.) SOAR fait référence aux technologies qui permettent aux organisations de collecter des intrants surveillés par l'équipe des opérations de sécurité. Par exemple, les alertes du système SIEM et d'autres technologies de sécurité - où l'analyse et le tri des incidents peuvent être effectués en exploitant une combinaison de puissance humaine et machine - aident à définir, hiérarchiser et piloter des activités de réponse aux incidents standardisées. Les outils SOAR permettent à une organisation de définir des procédures d'analyse et de réponse aux incidents dans un format de flux de travail numérique.

Le marché compte une variété d'opposants qui proposent des solutions SOAR, chacun avec ses avantages et ses inconvénients, on peut citer :

TheHive Project : La version initiale a eu lieu en 2014. La version 4 est une source gratuite, tandis que la version 5 est payante et appartient à la société Strangbee. Il convient de noter qu'il ne possède pas toutes les fonctionnalités de SOAR, mais il peut être complété par d'autres outils pour y parvenir. TheHive n'est qu'un SIRP.

ReflexSOAR : en mai 2022, un autre SOAR open source a été publié ; vous pouvez employer l'équipe pour installer le produit open source puisque "c'est leur source de revenus".

Cortex XSOAR : Paloalto Networks (anciennement Demisto) dispose d'une solution commerciale qui a dominé le marché.

Siemplify : Google Cloud Platform a acquis une solution commerciale (elle conserve le même nom qu'avant l'acquisition)

Il y en a tellement d'autres sur le marché comme PhishER de Knowbe4, Swimlane de Swimlane, InsightConnect de Rapid7, FortiSOAR de Fortinet etc.

Pour le classement de l'enquête de Gartner, on retrouvera les solutions commerciales en tête, en effet il n'y a pas d'avis pour les solutions open-source donc on peut juste comparer les solutions payantes. Pour les solutions SOAR payantes leaders, on trouve InsightConnect, PhishER, Swimlane etc. et Siemplify est mieux noté que Cortex XSOAR sur le site de Gartner.

Nous pouvons également les comparer sur d'autres sites Web d'analyse comparative tels que PeerSpot [9], nous constaterons également qu'il ne contient que des informations sur les solutions commerciales.

En raison du coût élevé des licences commerciales des solutions SOAR, qui peuvent être aussi bas que 20 000 \$ par an pour les offres les plus basses, nous travaillerons avec TheHive 4 et l'étendrons pour développer une solution SOAR open source complète pour notre projet continu. En dehors de cela, les solutions commerciales sont moins ou non personnalisables car nous n'avons pas accès à la source

code, ce qui est une chose terrible pour une équipe qui veut développer sa propre solution et la concurrencer ; vous êtes coincé avec les intégrations restreintes de l'entreprise propriétaire.

7. Le projet Hive

1. La définition du projet Hive

TheHive Project est une plate-forme de réponse aux incidents de sécurité open source et disponible gratuitement lancée en 2014, conçue pour aider les analystes et les praticiens de la sécurité travaillant dans les SOC, les CSIRT et les CERT à suivre, enquêter et agir sur les incidents de sécurité identifiés de manière rapide et collaborative.

Les analystes de la sécurité peuvent collaborer simultanément sur des enquêtes, garantissant que les informations en temps réel relatives aux cas, tâches, observables et IoC nouveaux ou existants sont disponibles pour tous les membres de l'équipe.

TheHive Project opère sous le guide de trois fonctions principales :

- Collaborer : plusieurs analystes d'une même organisation peuvent travailler simultanément sur le même dossier. Grâce à ses capacités de diffusion en direct, tout le monde peut garder un œil sur les cas en temps réel.
- Élaborer : Les enquêtes correspondent aux cas. Les détails de chaque cas peuvent être décomposés en tâches associées, qui peuvent être créées à partir de zéro ou via un moteur de modèle. De plus, les analystes peuvent enregistrer leurs progrès, joindre des artefacts de preuve et assigner des tâches sans effort. • Agir : un processus de triage rapide peut être pris en charge en permettant aux analystes d'ajouter des éléments observables à leurs cas, en tirant parti des balises, en signalant les IoC et en identifiant les éléments observables précédemment vus pour alimenter leurs renseignements sur les menaces.

TheHive permet aux analystes d'une organisation de travailler simultanément sur le même dossier. Cela est dû au riche ensemble de fonctionnalités de la plate-forme et aux intégrations qui prennent en charge les flux de travail des analystes.

Les fonctionnalités incluent :

- Gestion des cas/tâches : chaque enquête est censée correspondre à un cas été créé. Chaque cas peut être décomposé en une ou plusieurs tâches pour plus de granularité et même être transformé en modèles pour une gestion plus facile. De plus, les analystes peuvent enregistrer leurs progrès, joindre des éléments de preuve ou des fichiers remarquables, ajouter des balises et d'autres archives aux cas.
- Triage des alertes : les cas peuvent être importés à partir d'alertes SIEM, de rapports par e-mail et d'autres sources d'événements de sécurité. Cette fonctionnalité permet à un analyste de parcourir les alertes importées et de décider si elles doivent ou non être transformées en enquêtes ou en réponse à un incident.

- Enrichissement observable avec Cortex : L'une des principales intégrations de fonctionnalités prises en charge par TheHive est Cortex, un moteur d'analyse observable et de réponse active. Cortex permet aux analystes de collecter plus d'informations à partir des indicateurs de menace en effectuant une analyse de corrélation et en développant des modèles à partir des cas.
- Réponse active : TheHive permet aux analystes d'utiliser des répondeurs et d'exécuter des actions actives pour communiquer, partager des informations sur les incidents et prévenir ou contenir une menace.
- Tableaux de bord personnalisés : les statistiques sur les cas, les tâches, les observables, les métriques et bien plus peuvent être compilées et distribuées sur des tableaux de bord qui peuvent être utilisés pour générer des KPI utiles au sein d'une organisation.
- Intégration MISP intégrée : Une autre intégration utile est avec MISP, une menace

plate-forme de renseignement pour le partage, le stockage et la corrélation des indicateurs de compromission d'attaques ciblées et d'autres menaces. Cette intégration permet aux analystes de créer des cas à partir d'événements MISP, d'importer des IOC ou d'exporter leurs propres indicateurs identifiés vers leurs communautés MISP.

Les autres intégrations notables prises en charge par TheHive sont DigitalShadows2TH et ZeroFox2TH, des extensions gratuites et open-source des sources d'alerte de DigitalShadows et ZeroFox respectivement. Ces intégrations garantissent que les alertes peuvent être ajoutées dans TheHive et transformées en nouveaux cas à l'aide de modèles de réponse aux incidents prédéfinis ou en s'ajoutant à des cas existants.

2. Le vocabulaire de la Ruche :

TheHive prend en charge différents rôles pour les utilisateurs. Selon que vous êtes un administrateur de la plateforme, un administrateur d'une organisation ou un analyste, vous pouvez avoir accès et exécuter différentes actions dans la plateforme.

1) La liste complète des autorisations comprend :

gérerOrganisation (1)	Créer et mettre à jour une organisation
gérer la configuration (1)	Mettre à jour la configuration
gérerProfil (1)	Créer, mettre à jour et supprimer des profils
balise de gestion (1)	Créer, mettre à jour et supprimer des balises
gérerCustomField (1)	Créer, mettre à jour et supprimer des champs personnalisés
gérerCase	Créer, mettre à jour et supprimer des cas
gérerObservable	Créer, mettre à jour et supprimer des Observables
gérerALert	Créer, mettre à jour et importer des alertes
gérer l'utilisateur	Créer, mettre à jour et supprimer des utilisateurs
manageCaseTemplate	Créer, mettre à jour et supprimer des modèles de cas
gérerTâche	Créer, mettre à jour et supprimer des tâches
gérerPartager	Partager le cas, la tâche et l'observable avec d'autres organisations

gérerAnalyser (2)	Exécuter Analyser
gérerAction (2)	Exécuter des actions
manageAnalyserTemplate (2)	Créer, mettre à jour et supprimer des modèles d'analyseur

Tableau 1 : Autorisations TheHive

Remarque :

Notez que (1) Les organisations, la configuration, les profils et les balises sont des objets globaux. Les autorisations associées ne sont effectives que sur l'organisation « admin ». (2) Les actions, l'analyse et le modèle ne sont disponibles que si le connecteur Cortex est activé <Tableau 1>.

En plus d'ajouter de nouveaux profils d'utilisateurs, l'administrateur peut également effectuer d'autres opérations telles que la création de champs personnalisés de cas, de types observables personnalisés, de modèles d'analyseur personnalisés et l'importation de TTP à partir du cadre MITRE ATT&CK (Adversarial Tactics, Techniques and Common Knowledge) <Figure 6> .

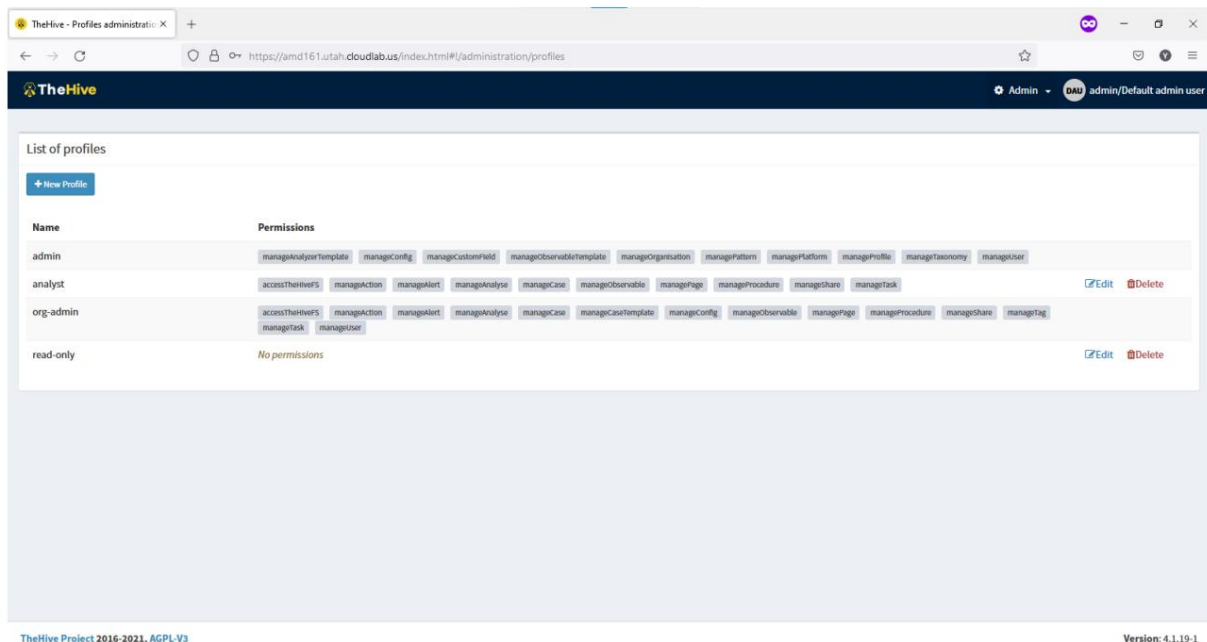
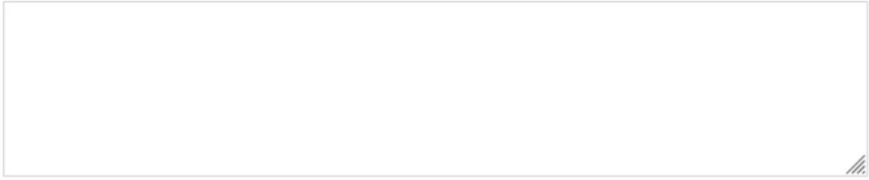


Figure 6 : Autorisations des profils

2) Les détails de l'onglet Observables :

Type * 

Value * 

☒ One observable per line (0 observables)
☐ One single multiline observable

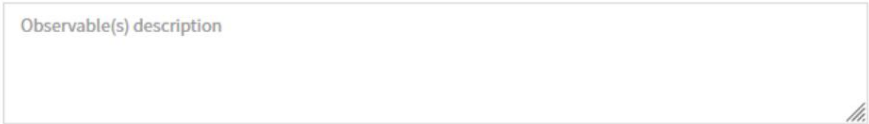
TLP *    

Is IOC 

Has been sighted 

Ignore for similarity 

Tags *** 

Description *** 

***** Required field ******* At least, one required field

Figure 7 : Champs observables

Champ	Description	Exemples
Taper *:	Le type de données observable	Adresse IP, hachage, Domaine
Valeur *:	Votre valeur observable	8.8.8.8, 127.0.0.1
Un observable par ligne :	Créez un observable par ligne insérée dans le champ de valeur.	
Une seule observable multiligne :	Créer un observable, peu importe le nombre de lignes	URL longues
TLP* :	Définissez ici la manière dont les informations doivent être partagées.	
IoC :	Vérifiez si cet observable est considéré comme un Indicateur de Compromis	Emote IP
A été aperçu :	Cet observable a-t-il été aperçu sur votre système d'information ?	

Ignorer pour similarité :	Ne pas corréler cet observable avec d'autres observables similaires.	
Mots clés **:	Balises d'informations perspicaces.	adresse IP malveillante ; MITRE Tactique
Description **:	Description de l'observable	

Tableau 2 : Champs observables

3. Fonctionnalités de TheHive

- Authentification
- Tableaux de bord
- Fusion de cas •

Filtrage des cas et observables • MISP et Cortex

Avis sur g2.com [10] sur l'utilité de TheHive

8.Cortex

Cortex vise à relever un défi auquel les SOC, les CSIRT et les chercheurs en sécurité sont confrontés dans le processus de renseignement sur les menaces, de criminalistique numérique et de réponse aux incidents : comment évaluer les observables acquis à grande échelle à l'aide d'un seul outil plutôt que de plusieurs.

TheHive Project a conçu Cortex, un outil open source et gratuit, spécifiquement à cet effet.

Les adresses IP et e-mail, les URL, les noms de domaine, les fichiers et les hachages peuvent tous être évalués individuellement ou en bloc à l'aide d'une interface Web. L'API Cortex REST permet aux analystes d'automatiser ces processus.

1.Architecture

Cortex est écrit en Scala. Le front-end utilise AngularJS avec Bootstrap. Son API REST est sans état, ce qui lui permet d'être évolutive horizontalement. Les analyseurs fournis sont écrits en Python. Des analyseurs supplémentaires peuvent être écrits en utilisant le même langage ou tout autre langage pris en charge par Linux <Figure 8>.

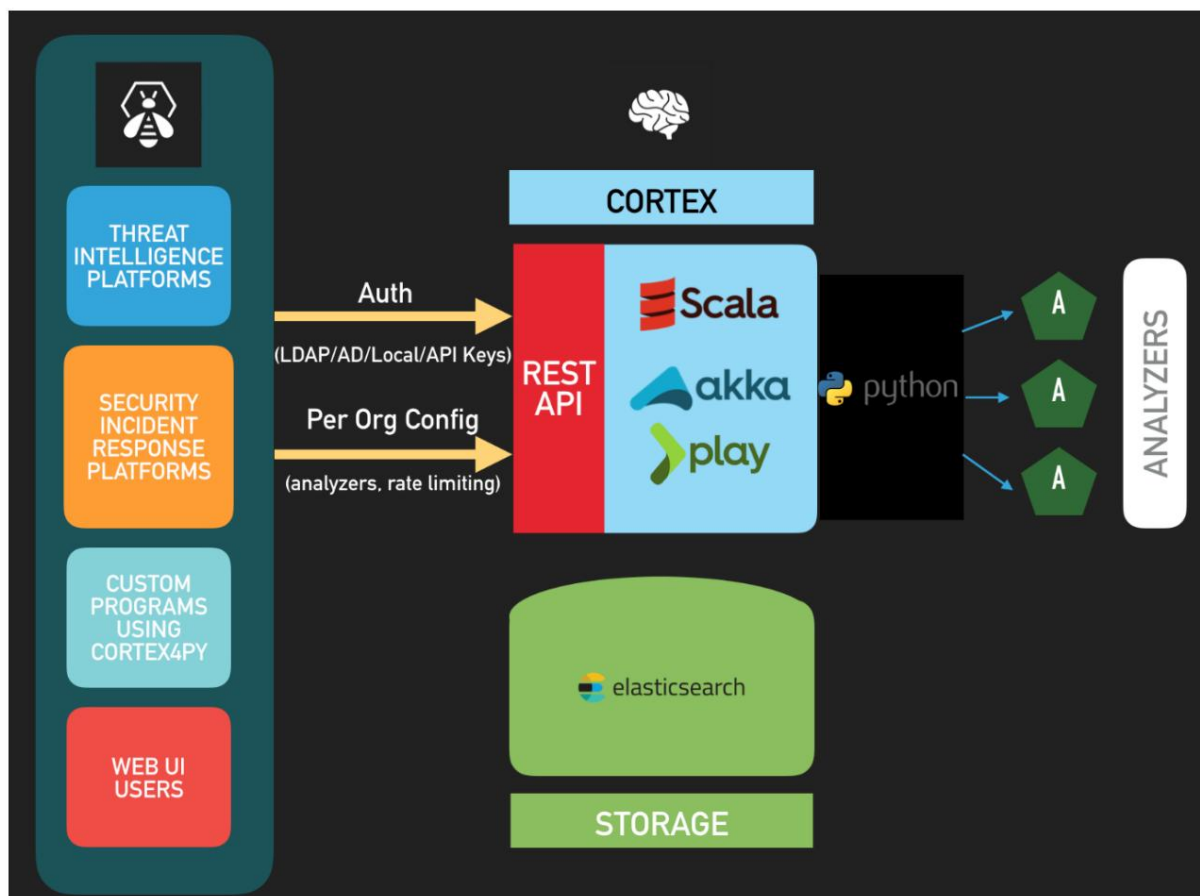


Figure 8 : Architecture corticale

2. Analyseurs et répondeurs

Grâce à Cortex, vous pouvez analyser différents types d'observables à l'aide de certaines d'analyseurs. En mai 2022, plus de 185 analyseurs et 52 répondeurs étaient accessibles au public. La plupart des analyseurs viennent dans différentes saveurs. Par exemple, à l'aide de l'analyseur VirusTotal, vous pouvez soumettre un fichier à VT ou simplement consulter le dernier rapport disponible associé à un fichier ou à un hachage. La liste complète des analyseurs, y compris les saveurs et les exigences, est conservée dans le Cortex Analyzers Requirements Guide. Idem pour les répondeurs car ils sont tout comme les analyseurs, la différence est qu'au lieu d'analyser, ils répondent par une certaine action (blocage d'IP, de domaine, de mise en quarantaine d'un point de terminaison, ...).

9. MISP

1. Définition du DMU

MISP (Malware Information Sharing Platform) est une plateforme open source d'informations sur les menaces qui facilite la collecte, le stockage et la distribution de renseignements sur les menaces et les IoC liés aux logiciels malveillants, aux cyberattaques, à la fraude financière ou à toute autre intelligence au sein d'une communauté de membres de confiance.

Le partage d'informations suit un modèle distribué, avec des communautés fermées, semi-privées et ouvertes (publiques) prises en charge. De plus, les informations sur les menaces peuvent être distribuées et

Orchestration, automatisation et réponse de la sécurité

consommée par les systèmes de détection d'intrusion réseau (NIDS), les outils d'analyse des journaux et les systèmes de gestion des informations et des événements de sécurité (SIEM).

MISP est effectivement utile pour les cas d'utilisation suivants :

- Ingénierie inverse des logiciels malveillants : Partage d'indicateurs de logiciels malveillants pour comprendre le fonctionnement des différentes familles de logiciels malveillants.
- Enquêtes de sécurité : rechercher, valider et utiliser des indicateurs pour enquêter sur les failles de sécurité. • Analyse du renseignement : collecte d'informations sur les groupes adverses et leurs capacités.
- Application de la loi : Utilisation d'indicateurs pour soutenir les enquêtes médico-légales. • Analyse des risques : Recherche de nouvelles menaces, de leur probabilité et de leur occurrence. • Analyse de fraude : Partage d'indicateurs financiers pour détecter la fraude financière.

2. Fonctionnalités MISP

MISP fournit les fonctionnalités de base suivantes :

- Base de données du CIO : elle permet de stocker des informations techniques et non techniques sur les échantillons de logiciels malveillants, les incidents, les attaquants et les renseignements.
- Corrélation automatique : identification des relations entre les attributs et les indicateurs à partir de logiciels malveillants, de campagnes d'attaque ou d'analyses.
- Partage de données : cela permet le partage d'informations à l'aide de différents modèles de distributions et entre différentes instances MISP.
- Fonctionnalités d'importation et d'exportation : cela permet l'importation et l'exportation d'événements dans différents formats pour intégrer d'autres systèmes tels que NIDS, HIDS et OpenIOC. • Graphique d'événements : présente les relations entre les objets et les attributs identifiés à partir d'événements.
- Prise en charge de l'API : prend en charge l'intégration avec ses propres systèmes pour récupérer et exporter des événements et intelligence.

Les termes suivants sont couramment utilisés au sein du MISP et sont liés aux fonctionnalités décrites ci-dessus et à l'utilisation générale de la plate-forme :

- Événements : collecte d'informations liées contextuellement. • Attributs : points de données individuels associés à un événement, tel qu'un réseau ou un système indicateurs.
- Objets : compositions d'attributs personnalisés. • Références d'objet : relations entre différents objets. • Observations : occurrences spécifiques à un moment donné d'un point de données ou d'un attribut détecté pour fournir plus de crédibilité. • Balises : étiquettes attachées aux événements/attributs. • Taxonomies : les bibliothèques de classification sont utilisées pour étiqueter, classer et organiser les informations. • Galaxies : éléments de la base de connaissances utilisés pour étiqueter les événements/attributs. • Indicateurs : éléments d'information qui peuvent détecter une cyberactivité suspecte ou malveillante.

10. Conclusion

Nous avons vu dans ce chapitre comment SOAR peut aider le travail d'une équipe SOC en lui permettant de se concentrer sur les risques réels plutôt que sur un flux constant d'alarmes. Nous avons examiné la définition, l'objectif, les cas d'utilisation et les avantages de l'orchestration, de l'automatisation et de la réponse de la sécurité. Après cela, nous avons comparé quelques systèmes SOAR (à la fois commerciaux et open source) pour arriver au SOAR que nous utiliserons dans le projet à venir. Ensuite, nous avons passé en revue les outils que nous utiliserons, tels que Cortex et MISP, ainsi que notre composant principal, TheHive. Voyons comment nous pouvons mettre tous ces outils ensemble dans une situation pratique.

Chapitre 3 : Installation et configuration (TheHive, Cortex et MISP)

1. Introduction

Dans ce chapitre, nous verrons comment installer et configurer les trois outils qui aideront notre système SOAR à fonctionner avec succès. Nous verrons également quelques outils supplémentaires différents pour améliorer la sécurité des connexions de nos principaux outils (comme la mise en place d'une infrastructure à clé publique "PKI"), et le déploiement de proxys inverses pour forcer SSL/TLS depuis et vers les trois outils mentionnés, ainsi que le déploiement de certains tunnels SSH de transfert de port à des fins de services. Enfin, nous verrons comment nous pouvons utiliser le langage de programmation Python pour développer nos propres processus afin d'automatiser les opérations allant de l'enrichissement à la réponse.

TheHive est une plate-forme de réponse aux incidents de sécurité que nous allons améliorer tout au long de ce projet pour construire notre propre plate-forme d'automatisation et de réponse à l'orchestration de la sécurité en utilisant une combinaison de différents outils tels que Cortex avec ses analyseurs intégrés pour les processus d'enrichissement, les répondeurs pour simplifier la prise d'actions contre les menaces. , et son API REST pour une meilleure automatisation des tâches. Nous verrons également comment créer des playbooks à l'aide de scripts python, des API TheHive4py et Cortex4py pour TheHive et Cortex. Enfin, si nous travaillons avec une quantité de données aussi précieuse et vaste, nous devons créer notre propre base de données pour un accès facile. et la personnalisation pour répondre à nos besoins futurs, d'où la raison pour laquelle nous utiliserons MISP (Malware Information Security Platform), qui est spécialement conçu pour traiter ces données.

2. Installation et configuration de TheHive

1. Vue d'ensemble

L'évolutivité de TheHive lui permet d'être configuré en tant que serveur autonome ou en tant que nœuds à l'intérieur d'un cluster.

N'importe quel nombre de nœuds peut s'appuyer sur une base de données et un système de fichiers également configurés en tant que serveurs autonomes ou en cluster.



Figure 9 : Composants principaux de TheHive

1) Choisissez une configuration

L'architecture modulaire lui permet de prendre en charge plusieurs types de bases de données, de système de stockage de fichiers et de système d'indexation. Les choix initiaux faits avec l'architecture cible et la configuration sont cruciaux, en particulier pour la base de données.

Prérequis matériels

La configuration matérielle requise dépend du nombre d'utilisateurs simultanés et de la façon dont ils utilisent le système. Le tableau suivant donne quelques informations pour choisir le matériel.

nombre d'utilisateurs	CPU	RAM
< 3	2	4-8
< 10	4	8-16
< 20	8	16-32

Tableau 3 : Prérequis matériels TheHive

2) Choisissez une base de données

Une fois la configuration cible identifiée, le premier choix à faire est la base de données. Même les bases de données Berkeley DB et Cassandra locales sont prises en charge, nous vous recommandons d'utiliser Apache Cassandra, qui est une base de données évolutive et hautement disponible, même pour les serveurs autonomes.

3) Choisissez un système de stockage de fichiers

Comme pour les bases de données, plusieurs options existent concernant le système de fichiers.

Fondamentalement, pour les configurations autonomes, l'utilisation du système de fichiers local est la solution la plus simple. Si vous installez un cluster, plusieurs options s'offrent à vous :

- Utilisation d'un dossier NFS partagé •

- Utilisation d'Apache Hadoop, un système de fichiers distribué • Utilisation

- d'un service de stockage compatible S3 ; par exemple, avec Min.IO

4) Choisissez un système d'indexation

Introduit avec TheHive 4.1 pour augmenter les performances, TheHive s'appuie sur un processus d'indexation dédié. Avec une configuration autonome, l'utilisation d'un index local avec Lucene est suffisante.

Dans le cas d'un cluster, tous les nœuds doivent se connecter au même index : une instance d'Elasticsearch est alors requise.

2. Manuel d'installation

Le guide suivant vous permet de préparer, d'installer et de configurer TheHive et ses prérequis pour les systèmes d'exploitation basés sur Debian.

Si vous souhaitez compiler TheHive à partir de sources, vous pouvez suivre ce guide [11].

Guide étape par étape

Il s'agit d'un guide d'installation et de configuration étape par étape pour rendre l'instance TheHive 4 opérationnelle. Ce guide est illustré d'exemples pour les systèmes basés sur Debian.

Commencez par les ajustements suivants pour tout mettre en ordre.

Passer en mode racine :

```
sudo-i
```

Modifiez le nom d'hôte :

```
nom d'hôte
```

Ouvrez /etc/hosts :

```
nano /etc/hosts
```

Ajoutez le nom d'hôte "127.0.0.1 thehive" dans le fichier /etc/hosts :

Mettez à jour votre liste de packages :

```
mise à jour appropriée
```

Machine virtuelle Java

Installez Java Virtual Machine 'la version 8 est recommandée' :

```
apt install -y openjdk-8-jre-sans tête
```

Alors

```
echo JAVA_HOME="/usr/lib/jvm/java-8-openjdk-amd64" >> /etc/environnement
```

```
exporter JAVA_HOME="/usr/lib/jvm/java-8-openjdk-amd64"
```

REMARQUE :

TheHive peut être chargé par Java 11, mais pas la version stable de Cassandra, qui nécessite toujours Java 8.

Si vous configurez un cluster pour la base de données distinct des serveurs TheHive :

- Les nœuds Cassandra peuvent être chargés par Java 8
- Les nœuds TheHive peuvent être chargés par Java 11

Orchestration, automatisation et réponse de la sécurité

Pour les serveurs autonomes, avec TheHive et Cassandra sur le même système d'exploitation, nous vous recommandons de n'installer que Java 8 pour les deux applications.

Base de données Cassandra

Apache Cassandra est une base de données évolutive et hautement disponible. TheHive prend en charge la dernière version stable 3.11.x de Cassandra.

Installez Cassandra à partir du référentiel :

```
curl -fsSL https://www.apache.org/dist/cassandra/KEYS | sudo apt-clé ajouter -
```

```
echo "deb http://www.apache.org/dist/cassandra/debian 311x main" | sudo \ tee -a /etc/apt/sources.list.d/cassandra.sources.list
```

mise à jour appropriée

```
apt install -y cassandra
```

Commencez par changer le cluster_name avec 'thp'. Exécutez la commande cqlsh :

```
cqlsh localhost 9042
```

L'invite cqlsh vous sera présentée, entrez l'instruction de mise à jour :

```
UPDATE system.local SET cluster_name = 'thp' where key='local';
```

Quittez l'invite "cqlsh":

sortie

Exécutez ensuite la commande :

vidage de l'outil de nœud

Configurez Cassandra en éditant le fichier /etc/cassandra/cassandra.yaml :

```
nano /etc/cassandra/cassandra.yaml
```

Le contenu devrait ressembler à <Figure 10> :

```
# contenu de /etc/cassandra/cassandra.yaml

cluster_name : 'thp'
listen_address : localhost # adresse pour les nœuds rpc_address :
localhost # adresse pour les clients seed_provider : - class_name :
org.apache.cassandra.locator.SimpleSeedProvider

paramètres : #
  Ex : "<ip1>,<ip2>,<ip3>" - seeds :
  "127.0.0.1" # self pour le premier nœud data_file_directories : - '/var/lib/
cassandra/data'

répertoire_commitlog : '/var/lib/cassandra/commitlog' répertoire_caches_sauvés :
'/var/lib/cassandra/caches_sauvés' répertoire_astuces : - '/var/lib/cassandra/hints'
```

Figure 10 : modifications du fichier cassandra.yml

Redémarrez le service Cassandra :

Orchestration, automatisation et réponse de la sécurité

redémarrage du service cassandra

Seules les parties grises du fichier `/etc/cassandra/cassandra.yaml` nous intéressent, recherchez-les et remplacez-les par les ensembles ci-dessus.

Par défaut, les données sont stockées dans `/var/lib/Cassandra`

Par défaut, Cassandra écoute sur 7000/tcp (inter-nœud), 9042/tcp (client).

Installation de TheHive

Cette partie contient des instructions pour installer TheHive.

Installez TheHive :

```
curl \
https://raw.githubusercontent.com/TheHive-Project/TheHive/master/PGP-PUBLIC-KEY | sudo apt-clé ajouter -
```

```
echo 'deb https://deb.thehive-project.org version principale' | sudo tee -a \ /etc/apt/sources.list.d/thehive-
project.list
```

mise à jour appropriée

```
apt installer thehive4
```

Moteur d'indexation

A partir de TheHive 4.1.0, une solution pour stocker les index de données est nécessaire. Ces index doivent être uniques et identiques pour tous les nœuds du cluster TheHive.

- TheHive intègre un moteur Lucene que vous pouvez utiliser pour un serveur autonome • Pour les configurations de clusters, une instance d'Elasticsearch est requise

Créez un dossier dédié aux index d'hébergement pour TheHive :

```
mkdir -p /opt/thp/thehive/index
```

Changez la propriété du répertoire en utilisateur hive :

```
chown thehive:thehive -R /opt/thp/thehive/index
```

Stockage de fichiers

Pour les serveurs de production et de test autonomes, nous vous recommandons d'utiliser le système de fichiers local. Cette option est parfaite pour les serveurs autonomes. Faire cela:

Créez le répertoire de stockage des fichiers :

```
mkdir -p /opt/thp/laruche/fichiers
```

Changez la propriété du répertoire en utilisateur hive :

```
chown -R thehive:thehive /opt/thp/thehive/files
```

La configuration du Hive

Cette partie contient des instructions pour configurer TheHive.

Les configurations suivantes sont requises pour démarrer TheHive avec succès :

Orchestration, automatisation et réponse de la sécurité

- Configuration de la clé secrète •

Configuration de la base de données

- Configuration du stockage de fichiers

Configuration de la clé secrète

La clé secrète est automatiquement générée et stockée dans `/etc/thehive/secret.conf` par le script d'installation du package.

Base de données

Pour utiliser la base de données Cassandra, le fichier de configuration TheHive `/etc/thehive/application.conf` doit être modifié et mis à jour avec les lignes suivantes :

Ouvrez le fichier :

```
nano /etc/thehive/application.conf
```

Le contenu devrait ressembler à <Figure 11> :

```
db
{ fournisseur : janusgraph
  janusgraph { stockage
    { backend : cql nom d'hôte :
      ["127.0.0.1"] # adresses
      IP du nœud de départ #nom d'utilisateur : "<cassandra_username>"
      #password : "<cassandra_passowrd" cql { cluster-name : thp keyspace :
      thehive local-datacenter: datacenter1 # replication-factor: 2 read-consistency-
      level: ONE write-consistency-level: ONE
    }
  }
}
```

Figure 11 : modifications de cassandra application.conf

Index

Mettez à jour la configuration `db.storage` en modifiant le fichier `/etc/thehive/application.conf` pour utiliser un serveur autonome :

Le contenu devrait ressembler à <Figure 12> :

```
db
{ fournisseur : janusgraph
  janusgraph { stockage { [..]

  }
  ## Configuration de l'index
  index.search {
```

```

        backend : répertoire
        lucene : /opt/thp/thehive/index
    }
}
}

```

Figure 12 : modifications de l'index application.conf

Système de fichiers

Si vous choisissez de stocker des fichiers sur le système de fichiers local, ajoutez les lignes suivantes au fichier de configuration TheHive `/etc/thehive/application.conf`

Le contenu devrait ressembler à <Figure 13> :

```

stockage
{ fournisseur = localfs
  localfs.location = /opt/thp/thehive/files }

```

Figure 13 : modifications du système de fichiers application.conf

Le fichier de configuration `/etc/thehive/application.conf` doit ressembler à <Figure 43>, voir Annexe.

Enregistrez le fichier et exécutez le service :

```
service de démarrage de la ruche
```

Nous pouvons voir que TheHive fonctionne bien avec :

```
entretenir le statut de la ruche
```

Remarque

Veuillez noter que le service peut prendre un certain temps pour démarrer. Une fois lancé, vous pouvez lancer votre navigateur et vous connecter à `http://YOUR_SERVER_ADDRESS:9000/`.

Dans notre cas, nous naviguerons vers:

`http://amd161.utah.cloudlab.us:9000/`

vous pouvez voir la page de connexion dans la <Figure 44> et la page des organisations <Figure 45> dans l'annexe.

L'utilisateur admin par défaut est `admin@thehive.local` avec le mot de passe `secret`. Il est recommandé de changer le mot de passe par défaut.

3. Déployer un proxy inverse

Nous pouvons utiliser un proxy inverse dans la même instance pour protéger notre connexion à TheHive (les développeurs de TheHive le proposent car il manque un moyen intégré pour le faire.), faisant ressembler la topologie à ceci :

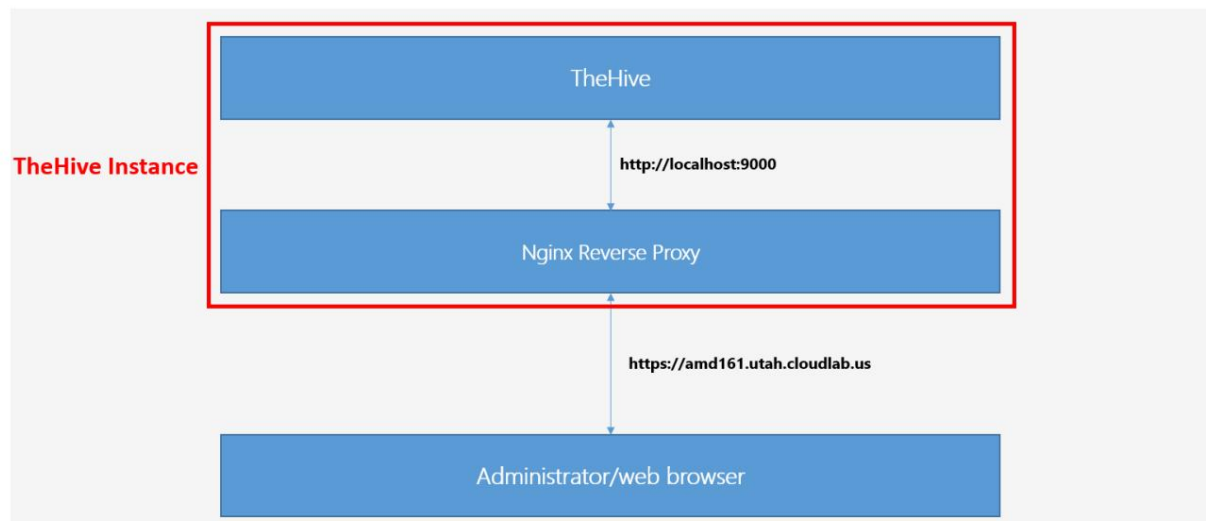


Figure 14 : Architecture des instances TheHive

Tout d'abord, nous allons utiliser NGINX comme proxy inverse, alors installons-le :

```
mise à jour sudo apt
```

```
sudo apt install -y nginx
```

Nous pouvons voir que NGINX est opérationnel avec :

```
statut systemctl nginx
```

Voyons comment cela fonctionnera (en mappant le port localhost 9000 sur le https://amd161.utah.cloudlab.us exposé).

Remarque

Pour notre application, nous avons besoin d'un certificat SSL numérique.

Pour cela, rendez-vous dans la section "Créer des certificats numériques" en annexe pour voir comment cela fonctionne puis revenez ici pour terminer les réglages.

Chemins vers les actifs critiques (certificats, clés privées, mots de passe) :

certificats

/etc/ssl/certs

clés privées

/etc/ssl/privé

phrases secrètes

note : nous n'avons pas un tel répertoire, nous devons donc le créer d'abord :

```
mkdir -p /etc/ssl/pass
```

Nous allons mettre la phrase secrète de notre clé privée dans le fichier /etc/ssl/pass/phrase.pass

Le fichier /etc/nginx/sites-available/reverse-proxy.conf devrait ressembler à <Figure 46> et <Figure 47> en annexe.

Après cela, nous devons exposer TheHive pour écouter uniquement sur l'hôte local, nous devons donc ajouter l'adresse:port au bas du fichier `/etc/thehive/application.conf`

```
http.adresse=127.0.0.1
```

```
http.port=9000
```

Cela devrait ressembler à la <Figure 48> dans l'annexe.

Relions maintenant le site disponible au site activé et redémarrons NGINX pour appliquer les modifications :

```
sudo ln -s /etc/nginx/sites-available/reverse-proxy.conf \ /etc/nginx/sites-enabled/reverse-proxy.conf
```

```
test de configuration du service nginx
```

```
redémarrage du service sudo nginx
```

```
statut systemctl nginx
```

Redémarrez également TheHive pour appliquer les modifications :

```
sudo systemctl redémarrer la ruche
```

4. Création d'organisations et ajout d'utilisateurs

Tout d'abord, nous devons modifier le mot de passe de l'administrateur après avoir sécurisé notre connexion à l'instance TheHive. Voir Annexe <Figure 54>, <Figure 55> et <Figure 56>.

Après cela, créons une nouvelle organisation "techsogroup", puis créons des utilisateurs au sein de celle-ci. Voir Annexe <Figure 57> et <Figure 58>.

Maintenant que nous avons notre nouvelle organisation, ajoutons un nouvel utilisateur et définissons-lui un mot de passe. Voir Annexe <Figure 59> à <Figure 64>.

Nous pouvons générer la clé API à partir de la même page <Figure 64>. Il sera utile pour automatiser les tâches à l'avenir.

Remarque :

Chaque profil d'utilisateur a une liste prédéfinie d'autorisations (peut être personnalisée) qui permettraient à l'utilisateur d'effectuer différentes tâches en fonction de son rôle. Lorsqu'un profil a été sélectionné, vous verrez les autorisations qui lui sont indiquées ci-dessous.

5. Guides de configuration

La configuration de TheHive se trouve dans des fichiers stockés dans le dossier `/etc/thehive` :

`application.conf` contient tous les paramètres et options

`logback.xml` est dédié à la gestion des logs

`/etc/laruche/`

|--- `application.conf`

|--- `logback.xml`

|--- `secret.conf`

Un fichier `secret.conf` séparé est automatiquement créé par le paquet Debian. Ce fichier doit contenir un secret qui doit être utilisé par une instance.

Lorsque nous démarrons une instance Cortex et MISP, nous devrions envisager d'apporter quelques modifications au fichier de configuration `application.conf`

6. Créer des tableaux de bord

Une fois TheHive installé, opérationnel. Nous devons créer nos tableaux de bord personnalisés pour visualiser la circulation des données sur notre instance et mieux comprendre ce qui se passe dans le monde.

Alors, voyons comment en créer un.

Après vous être connecté à l'utilisateur administrateur de l'organisation, cliquez simplement sur « Tableaux de bord » dans la barre de menus, puis cliquez sur « Créer un nouveau tableau de bord ».

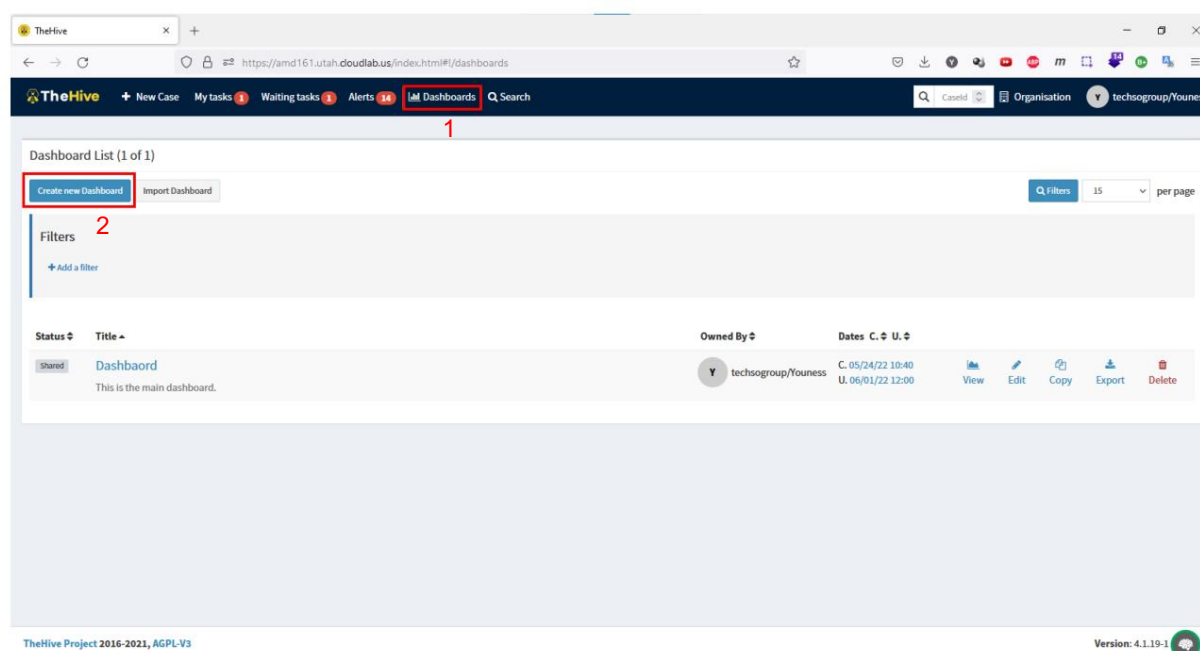


Figure 15 : Créer un nouveau tableau de bord (1)

Pour voir le processus complet de création d'un tableau de bord, passez à l'annexe <Figure 65> à <Figure 71>.

Pour moi, je me suis retrouvé avec les éléments suivants <Figure 16>, <Figure 17> et <Figure 18> :

Orchestration, automatisation et réponse de la sécurité

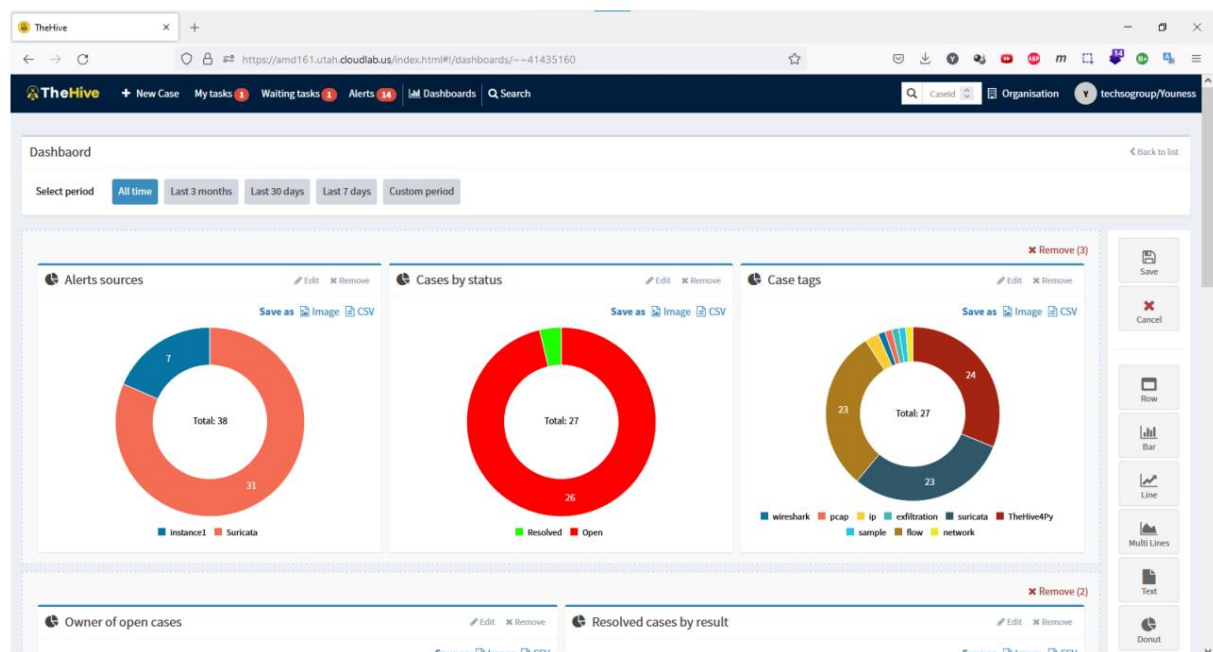


Figure 16 : Page Tableau de bord (1)

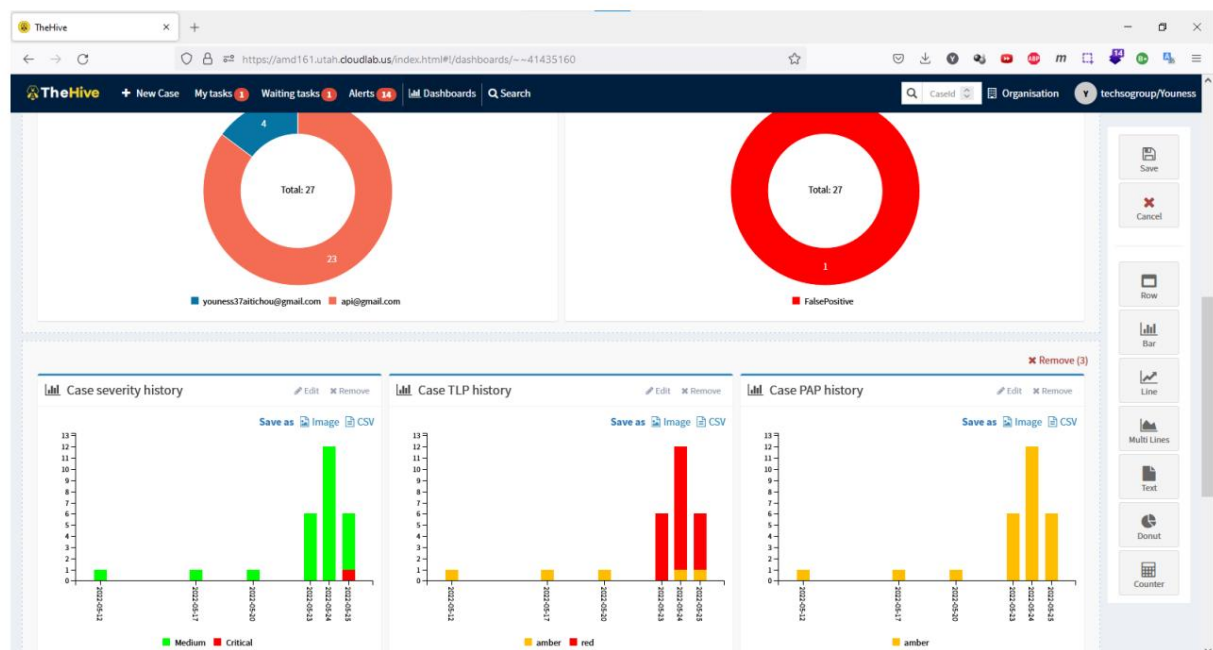


Figure 17 : Page Tableau de bord (2)

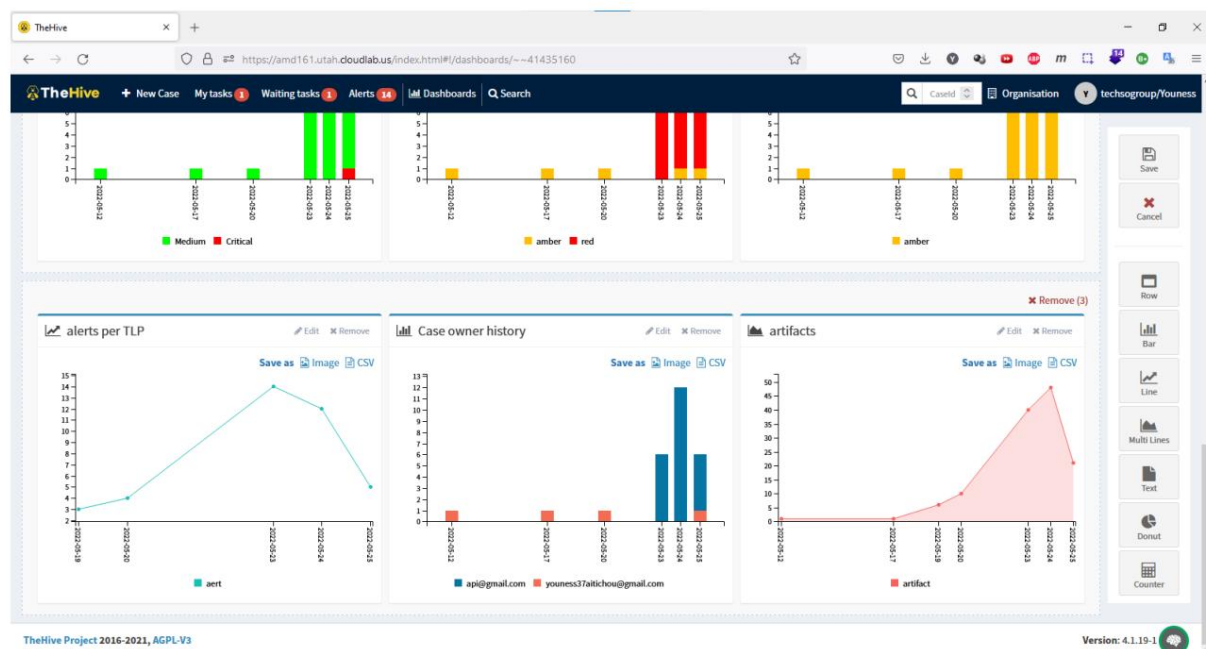


Figure 18 : Page Tableau de bord (3)

Maintenant, nous sauvegardons notre tableau de bord et l'utilisons pour visualiser nos données.

Malheureusement, nous ne pouvons pas exporter les rapports des tableaux de bord dans TheHive comme d'autres plates-formes SOAR, mais nous pouvons enregistrer nos widgets sous forme d'images, de CSV ou de HTML. Et utilisez-le pour créer nos rapports manuellement. Comme nous pouvons également intégrer notre propre code qui le fait pour nous.

7. Créez des champs et des modèles personnalisés

Pour créer un champ personnalisé, connectez-vous au compte super administrateur (qui peut créer des organisations et distribuer des autorisations), puis suivez les étapes ci-dessous <Figure 19> :

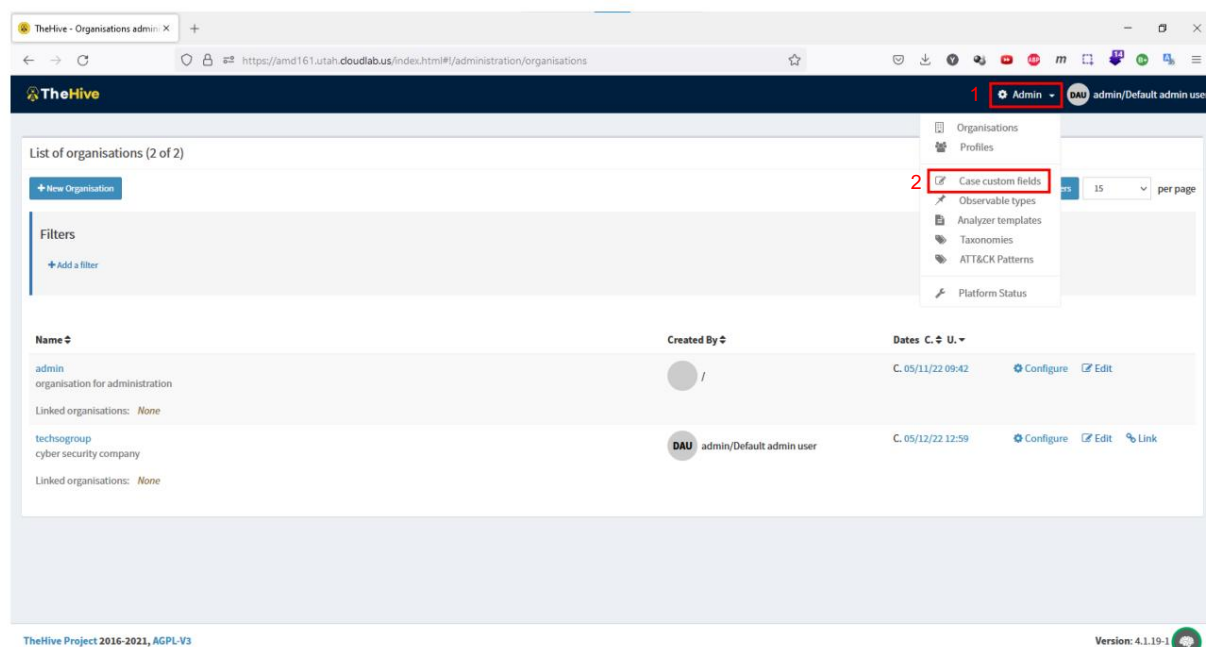


Figure 19 : Ajouter un champ personnalisé (1)

Appuyez maintenant sur Ajouter un champ personnalisé et remplissez les blancs, enregistrez à la fin <Figure 20>.

Orchestration, automatisation et réponse de la sécurité

The screenshot shows the 'Add custom field' modal in TheHive. The form contains the following fields:

- Name ***: sha256
- Internal Reference ***: sha256
- Description ***: sha256 hash
- Type ***: string
- Possible values**: Possible values, one per line (text area)
- Is mandatory**: ☐

Buttons: Cancel, Save field.

Background table (Case custom fields (10)):

Type	Name	Internal Reference	Description	Mandatory	Options	Actions
STRING	Destination IP	destination-ip	Suricata Event Destination IP	No	None	[Edit] [Delete]
INTEGER	Destination Port	destination-port	Suricata Event Destination Port	No	None	[Edit] [Delete]
STRING	Event Type	event-type	Suricata Event Type	No	flow dns	[Edit] [Delete]
STRING	Flow ID	flow-id	Suricata Flow ID	No	None	[Edit] [Delete]
STRING	Ingress Interface	ingress-interface	Suricata Ingress Interface	No	None	[Edit] [Delete]
STRING	JSON Details	json-details	Suricata Event JSON Details	No	None	[Edit] [Delete]
STRING	Protocol	protocol	Suricata Event Protocol	No	TCP DNS	[Edit] [Delete]
STRING	Source IP	source-ip	Suricata Event Source IP	No	None	[Edit] [Delete]
INTEGER	Source Port	source-port	Suricata Event Source IP	No	None	[Edit] [Delete]
STRING	TimeStamp	timestamp	Suricata Alert Timestamp	No	None	[Edit] [Delete]

Figure 20 : Ajouter un champ personnalisé (2)

Pour ajouter d'autres champs personnalisés, jouez simplement avec ces valeurs et vous aurez terminé. Nous allons avoir besoin des champs personnalisés pour créer nos propres modèles.

Pour le modèle Suricata, j'ai ajouté ces champs personnalisés <Figure 21>.

The screenshot shows the 'Case custom fields (10)' list in TheHive. The table contains the following data:

Type	Name	Internal Reference	Description	Mandatory	Options	Actions
STRING	Destination IP	destination-ip	Suricata Event Destination IP	No	None	[Edit] [Delete]
INTEGER	Destination Port	destination-port	Suricata Event Destination Port	No	None	[Edit] [Delete]
STRING	Event Type	event-type	Suricata Event Type	No	flow dns	[Edit] [Delete]
STRING	Flow ID	flow-id	Suricata Flow ID	No	None	[Edit] [Delete]
STRING	Ingress Interface	ingress-interface	Suricata Ingress Interface	No	None	[Edit] [Delete]
STRING	JSON Details	json-details	Suricata Event JSON Details	No	None	[Edit] [Delete]
STRING	Protocol	protocol	Suricata Event Protocol	No	TCP DNS	[Edit] [Delete]
STRING	Source IP	source-ip	Suricata Event Source IP	No	None	[Edit] [Delete]
INTEGER	Source Port	source-port	Suricata Event Source IP	No	None	[Edit] [Delete]
STRING	TimeStamp	timestamp	Suricata Alert Timestamp	No	None	[Edit] [Delete]

Figure 21 : Champs personnalisés

Construisons maintenant notre modèle.

Connectez-vous au compte administrateur de l'organisation et suivez les étapes ci-dessous <Figure 22>.

Orchestration, automatisation et réponse de la sécurité

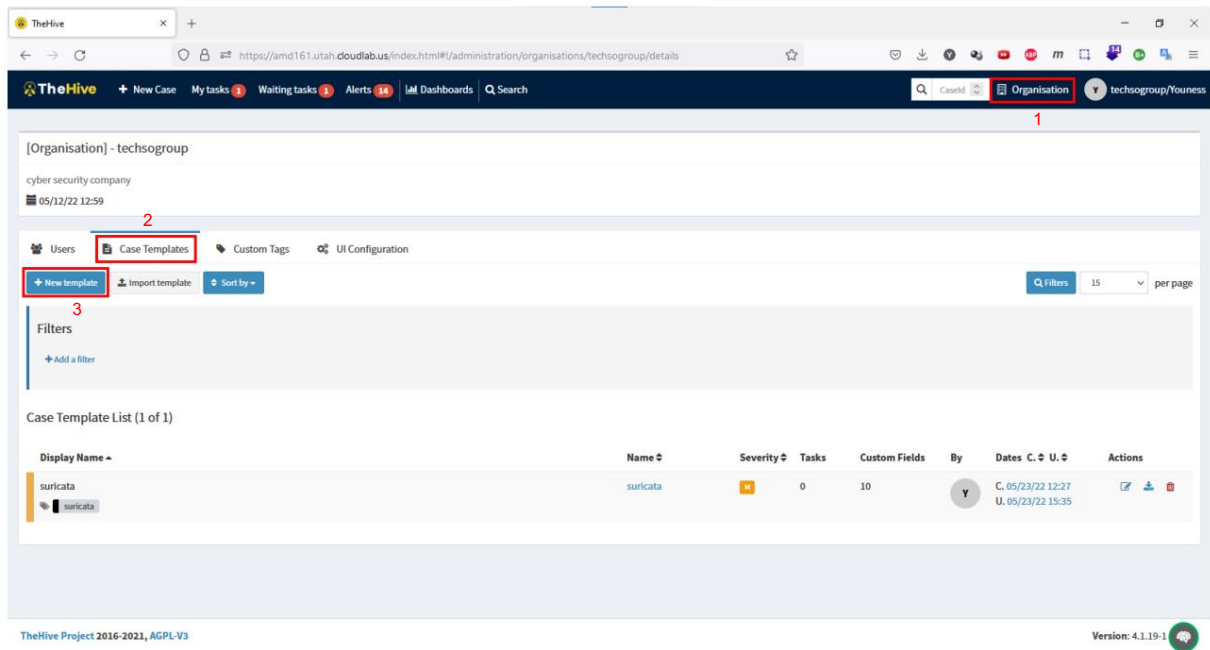


Figure 22 : Ajouter un nouveau modèle (1)

Comme toujours, nous remplissons les blancs et nous définirons les valeurs par défaut pour la gravité, TLP et PAP pour ce modèle <Figure 23>.

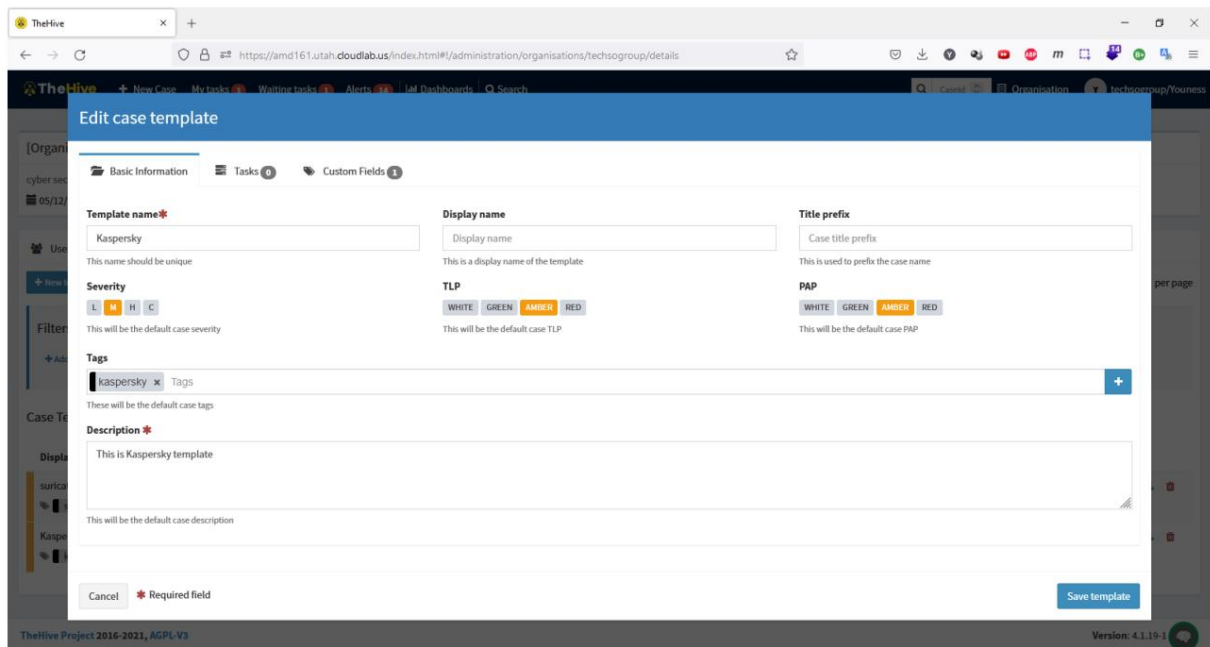


Figure 23 : Ajouter un nouveau modèle (2)

Pour l'onglet des champs personnalisés, nous pouvons ajouter les champs personnalisés créés précédemment <Figure 24>.

Orchestration, automatisation et réponse de la sécurité

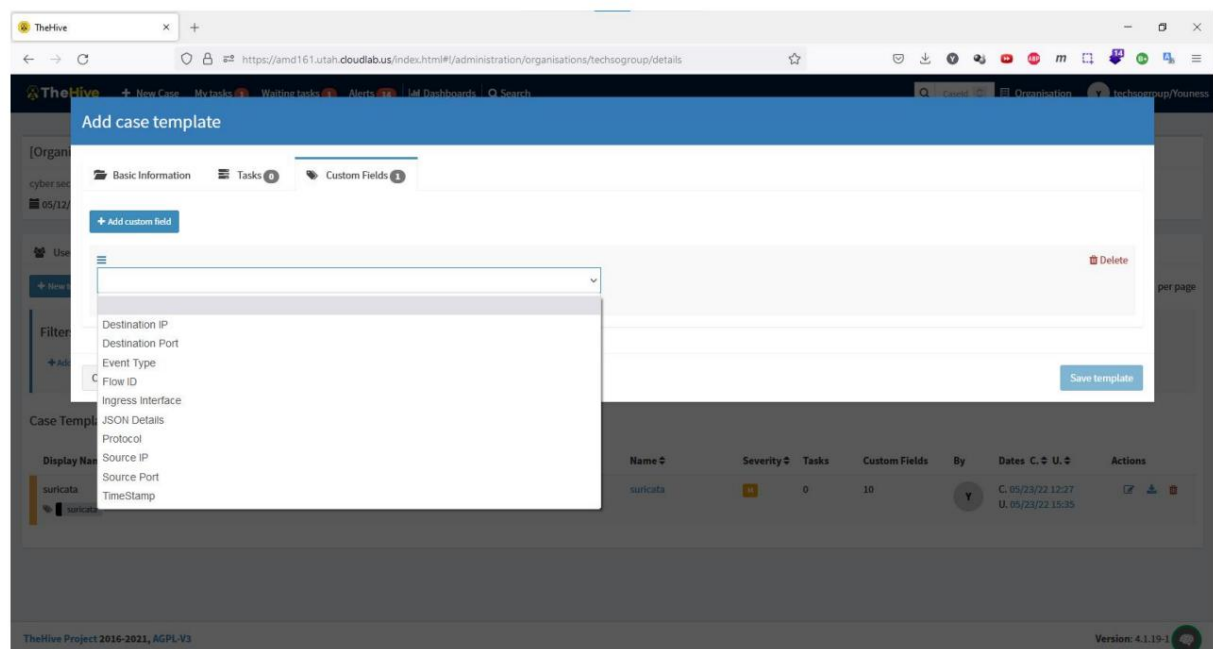


Figure 24 : Ajouter un nouveau modèle (3)

Et ici, nous avons notre modèle prêt à l'emploi.

3. Installation et configuration du cortex

1. Prérequis matériels :

Cortex utilise une machine virtuelle Java. Nous vous recommandons d'utiliser une machine virtuelle avec 8 vCPU, 8 Go de RAM et 10 Go de disque. Vous pouvez également utiliser une machine physique avec des spécifications similaires.

Dans notre cas, nous utiliserons Centos7.

2. Le guide d'installation de RPM :

La version finale de Cortex.

Le référentiel de version contient des packages pour Cortex 3.0.1+ qui prennent en charge Elasticsearch version 7.x.

Nous devons donc d'abord installer Elasticsearch.

1) Installer et configurer Elasticsearch

Installation d'Elasticsearch :

Importez la clé GPG :

```
sudo-i
```

```
rpm --import https://artifacts.elastic.co/GPG-KEY-elasticsearch
```

Ajoutez le dépôt :

```
cat > /etc/yum.repos.d/elastic.repo << EOF
```

```
[elasticsearch-7.x]
```

```
name=dépôt Elasticsearch pour les packages 7.x
```

```
baseurl=https://artifacts.elastic.co/packages/7.x/yum
```

```
gpgcheck=1
```

```
gpgkey=https://artifacts.elastic.co/GPG-KEY-elasticsearch
```

```
activer=1
```

```
actualisation automatique=1
```

```
type=tr/min-md
```

```
EOF
```

Installez le package Elasticsearch :

```
yum install elasticsearch-7.17.3
```

Nous devons maintenant éditer le fichier `/etc/elasticsearch/elasticsearch.yml`

```
nano /etc/elasticsearch/elasticsearch.yml
```

Ajoutez les lignes ci-dessous :

```
cluster.name : ruche
```

```
réseau.hôte : 127.0.0.1
nœud.nom : nœud-1
cluster.initial_master_nodes : ["nœud-1"]
thread_pool.search.queue_size : 100000
```

Illustration 25 : fichier elasticsearch.yml

Commençons Elasticsearch

```
systemctl démarrer elasticsearch.service
```

```
état systemctl elasticsearch.service
```

L'état doit être actif (en cours d'exécution). S'il ne fonctionne pas, vous pouvez vérifier pourquoi dans les journaux.

Notez que par défaut, la base de données est stockée dans /var/lib/elasticsearch et les logs dans /var/log/elasticsearch

Installons maintenant Cortex.

2) Installation de la version stable de Cortex

Les packages Debian sont publiés sur le référentiel de packages DEB. Tous les packages sont signés à l'aide de la clé GPG 562CBC1C de la ruche. Le référentiel principal est un référentiel hérité et contient des packages pour Cortex 3.0.1 qui ne prennent pas en charge la version 7.x d'Elasticsearch, mais la version 6.x. (que nous venons d'installer il y a peu).

Installation corticale :

Importez la clé GPG :

```
sudo rpm --import \ https://
raw.githubusercontent.com/TheHive-Project/TheHive/master/PGP-PUBLIC-KEY
```

Configurez votre système pour connecter le référentiel RPM.

Créez le fichier "/etc/yum.repos.d/thehive-project.repo":

```
nano /etc/yum.repos.d/thehive-project.repo
```

Le contenu devrait ressembler à ceci :

```
[le-projet-ruche]
```

```
activé=1
```

```
priorité=1
```

```
name=Dépôt RPM TheHive-Project
```

```
baseurl=https://rpm.thehive-project.org/release/noarch
```

```
gpgcheck=1
```

Ensuite, vous pourrez installer Cortex 3.1.0+ le package en utilisant yum :

```
miam installer cortex
```

Le seul paramètre requis pour démarrer Cortex est la clé du serveur play.http.secret.key.

```
(chat << _EOF_
```

Orchestration, automatisation et réponse de la sécurité

```
# Clé secrète #  
~~~~~ # La clé  
secrète est utilisée pour sécuriser les fonctions cryptographiques.  
# Si vous déployez votre application sur plusieurs instances veillez à utiliser la même clé ! play.http.secret.key="$(cat /dev/  
urandom | tr -dc 'a-zA-Z0-9' | fold -w 64 | head -n 1)"  
_EOF_  
| sudo -a /etc/cortex/application.conf
```

Démarrez maintenant Cortex :

```
systemctl démarrer le cortex
```

Une fois lancé, vous pouvez lancer votre navigateur et vous connecter à [http://](http://YOUR_SERVER_ADDRESS:9001/)

YOUR_SERVER_ADDRESS:9001/ :

Dans notre cas c'est :

<http://apt032.apr.emulab.net:9001/>

La première connexion doit ressembler à <Figure 26> :

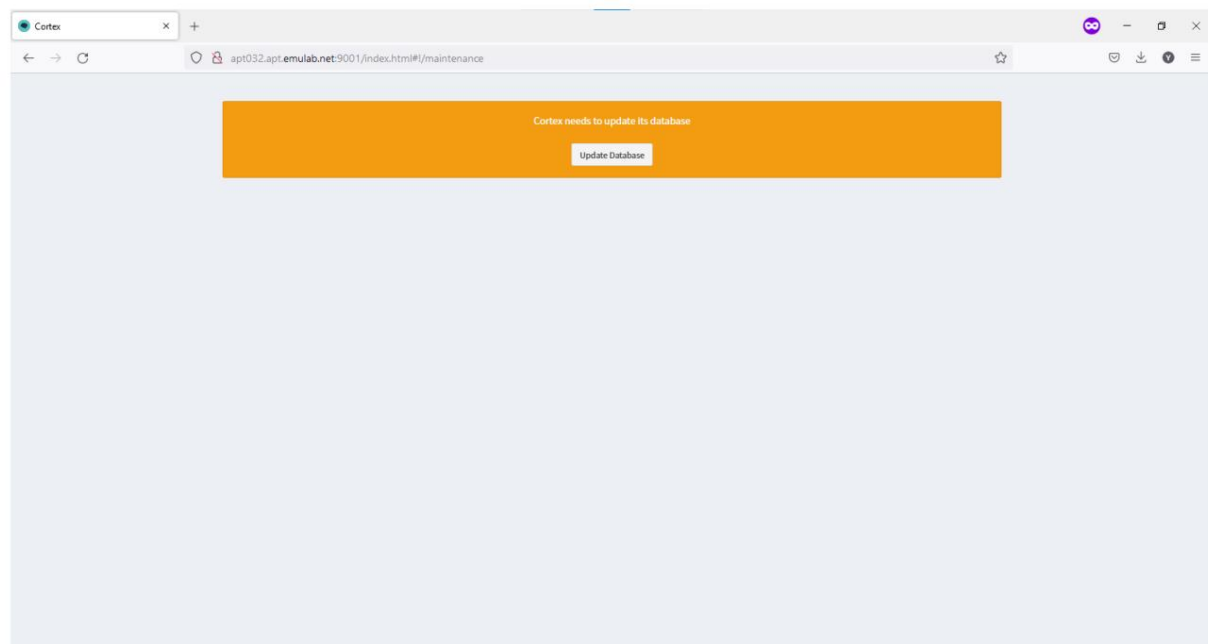


Figure 26 : Cortex première connexion (1)

Cliquez sur "mettre à jour la base de données". Elasticsearch devrait maintenant créer un index pour Cortex. Après cela, vous devriez faire face à cette page <Figure 27>.

Orchestration, automatisation et réponse de la sécurité

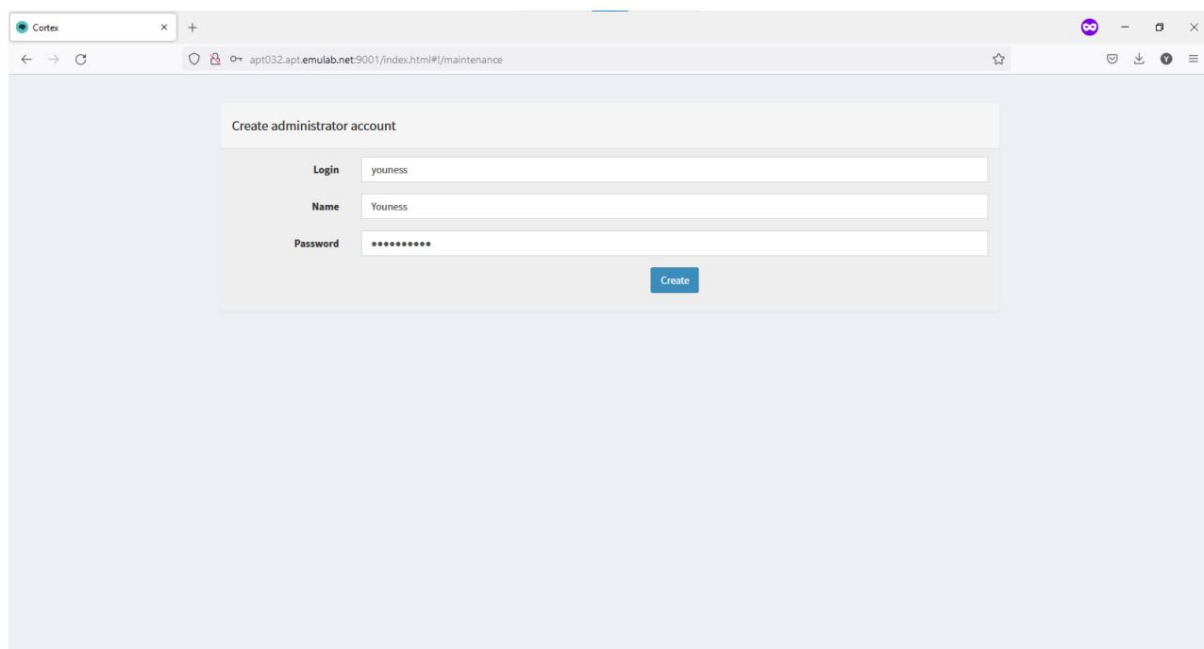


Figure 27 : Cortex première connexion (2)

Entrez votre nom d'utilisateur, votre nom et votre mot de passe pour le compte administrateur. Nous voici <Figure 28> et Figure 29 :



Figure 28 : Première connexion au cortex (3)

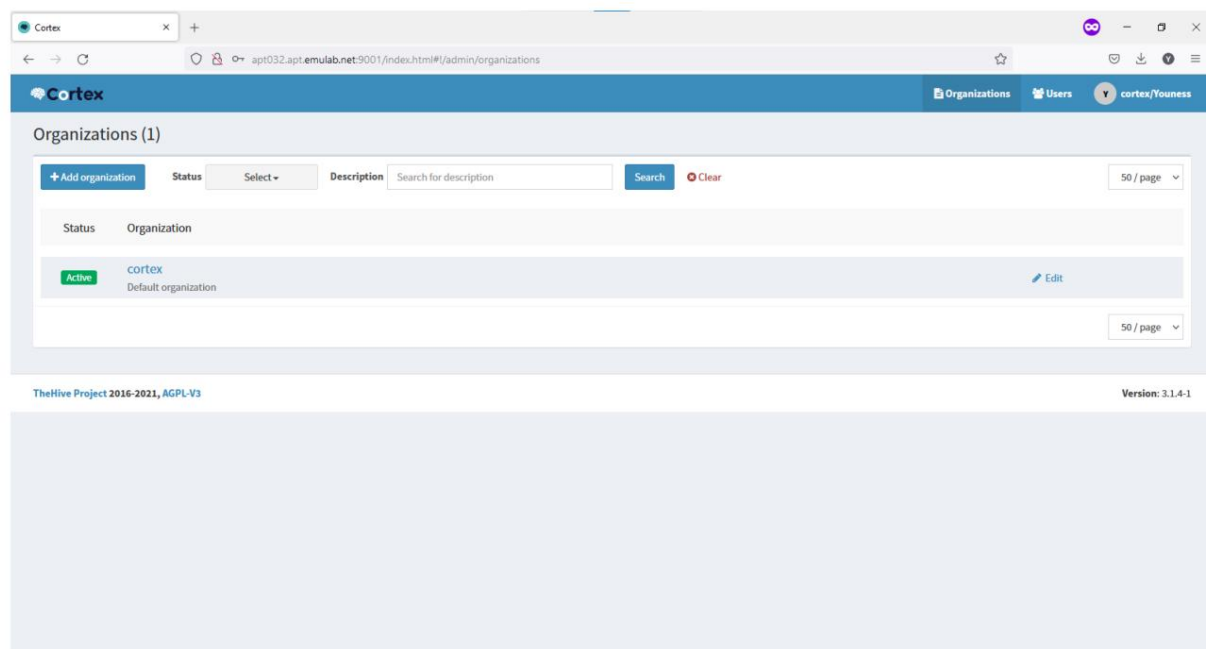


Figure 29 : Première connexion au cortex (4)

Nous pouvons utiliser un proxy inverse dans la même instance pour protéger notre connexion à Cortex (les développeurs de TheHive le proposent car il manque un moyen intégré pour le faire.), faisant ressembler la topologie à ceci :

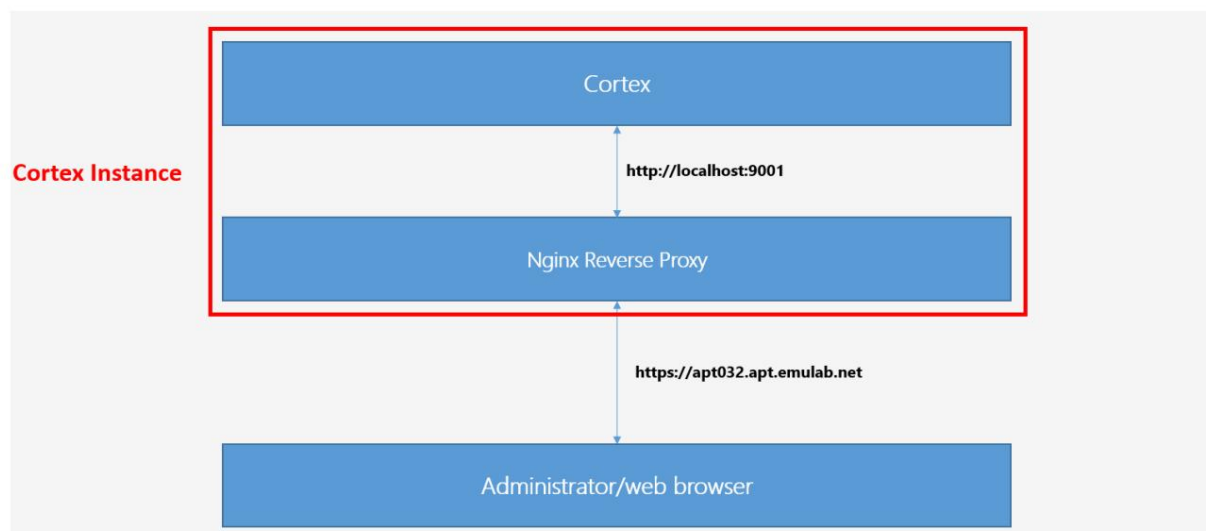


Figure 30 : Architecture d'instance Cortex

Tout d'abord, nous allons utiliser NGINX comme proxy inverse, alors installons-le :

```
sudo-i
```

```
miam mise à jour
```

```
miam installer nginx
```

Voyons comment cela fonctionnera (en mappant le port localhost 9001 sur le https://apt032.apt.emulab.net exposé).

Remarque

Pour notre application, nous avons besoin d'un certificat SSL numérique.

Pour cela, rendez-vous dans la section "Créer des certificats numériques" en annexe puis revenez ici pour terminer les réglages (c'est la même chose que la mise en place du certificat pour TheHive).

Configuration des chemins vers notre certificat, notre clé privée et notre phrase de passe :

```
cd /etc/ssl/
```

```
openssl req -x509 -newkey rsa:2048 -keyout /etc/ssl/private/ssl-cert-snakeoil.key -out /etc/ssl/certs/ssl-cert-snakeoil.pem
```

```
echo youness37 >> pass/phrase.pass
```

La phrase secrète de notre clé privée se trouve dans le fichier /etc/ssl/pass/phrase.pass

Le fichier /etc/nginx/nginx.conf devrait ressembler à ceci :

Nous devons créer le fichier /etc/nginx/conf.d/apt032.apr.emulab.net.conf.

```
nano /etc/nginx/conf.d/apt032.apr.emulab.net.conf
```

Il devrait avoir les configurations comme <Figure 72> et <Figure 73>, voir l'annexe.

Après cela, nous devons exposer Cortex pour écouter uniquement sur l'hôte local, nous devons donc ajouter l'adresse:port au bas du fichier /etc/cortex/application.conf :

```
http.adresse=127.0.0.1
```

```
http.port=9001
```

Redémarrez NGINX et Cortex pour appliquer les modifications :

```
systemctl restart nginx
```

```
systemctl restart cortex
```

Vous êtes maintenant prêt à utiliser la version https de Cortex.

3) Créer une organisation

L'organisation cortex par défaut ne peut pas être utilisée à d'autres fins que la gestion des administrateurs globaux (utilisateurs avec le rôle superAdmin), des organisations et de leurs utilisateurs associés. Il ne peut pas être utilisé pour activer/désactiver ou configurer des analyseurs. Pour ce faire, vous devez créer votre propre organisation dans Cortex en cliquant sur le bouton Ajouter une organisation <Figure 31>.

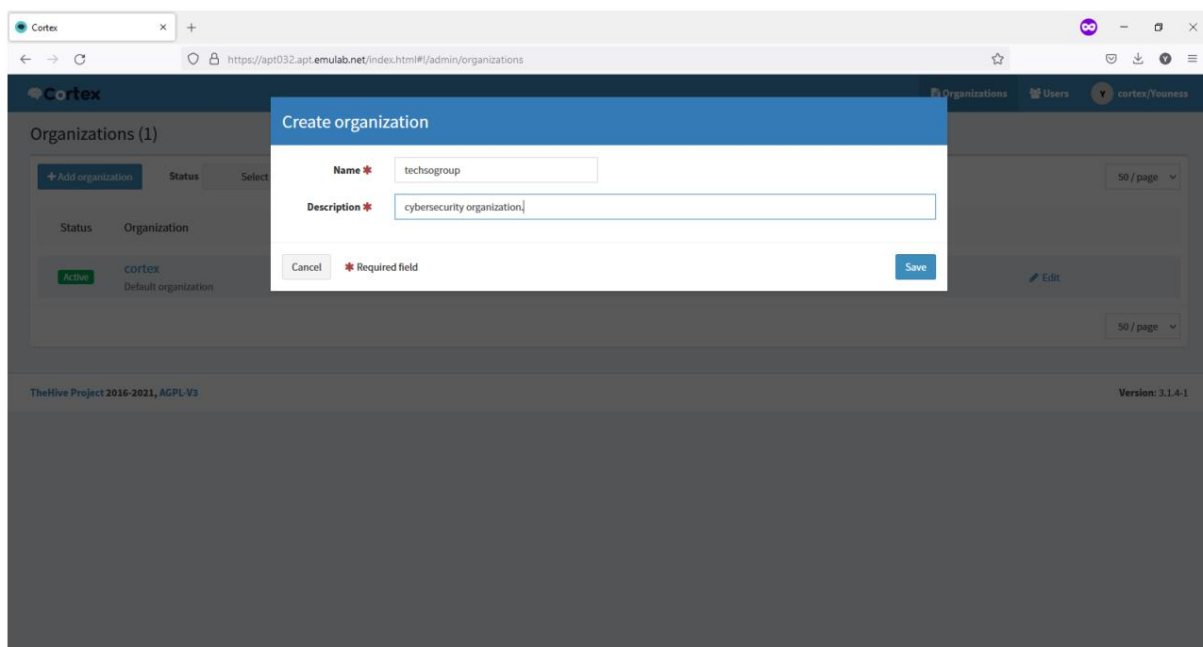


Figure 31 : Créer une organisation dans Cortex

4) Créer un administrateur d'organisation

Créez un compte pour l'administrateur de l'organisation (utilisateur avec un rôle orgAdmin) <Figure 32>.

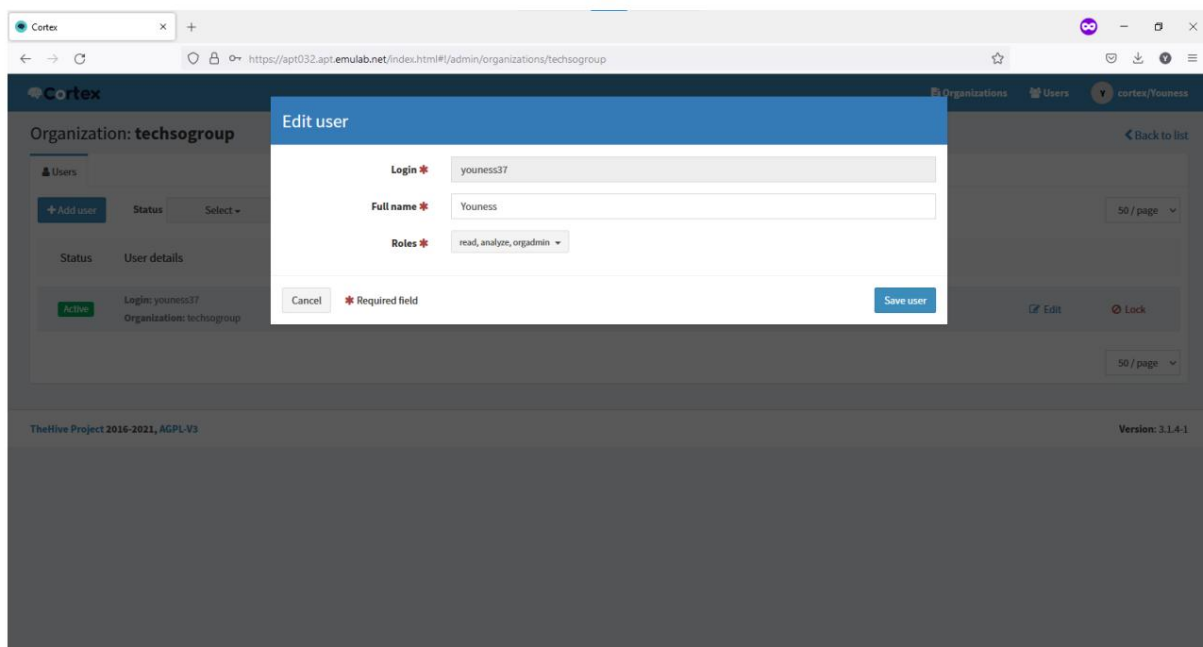


Figure 32 : Créer un utilisateur dans Cortex

Donnez ensuite un mot de passe à cet utilisateur. Après cela, déconnectez-vous et reconnectez-vous en utilisant le nouveau compte d'utilisateur.

3. Analyseurs et intervenants

Les analyseurs et les réponds sont des applications autonomes gérées et exécutées par le moteur central Cortex. Ils ont leur propre référentiel GitHub dédié [12].

1) Mise en place

Actuellement, tous les analyseurs et répondeurs supportés par TheHive Project sont écrits en Python 2 ou 3. Ils ne nécessitent aucune phase de construction mais leurs dépendances doivent être installées. Avant de continuer, nous devons installer les dépendances du package système requises par certains d'entre eux :

Installez python2, pip2, python3 et pip3

```
sudo-i
```

```
miam installer python2 python3 python2-pip python3-pip
```

Avant de continuer, vous devrez installer les dépendances du package système requises :

```
yum install -y python-pip python2.7-dev python3-pip python3-dev ssdeep \ libfuzzy-dev libfuzzy2 libimage-exiftool-perl libmagic1 build-essential \ git libssl-dev
```

Pour mettre à jour pip2 :

```
cd/opt
```

```
curl https://bootstrap.pypa.io/pip/2.7/get-pip.py --output get-pip.py
```

```
sudo python2 get-pip.py
```

```
pip2 -V
```

Pour mettre à jour pip3 :

```
pip3 installer --upgrade pip
```

```
pip3 -V
```

Pour mettre à jour les outils de configuration :

```
sudo pip2 install -U setuptools && sudo pip3 install -U setuptools
```

Une fois terminé, clonez le référentiel Cortex-analyzers dans le répertoire de votre choix (Dans notre cas /opt/).

Installation d'analyseurs et de répondeurs :

```
cd/opt
```

```
git clone https://github.com/TheHive-Project/Cortex-Analyzers
```

Chaque analyseur est livré avec son propre fichier requirements.txt compatible pip.

Vous pouvez installer toutes les exigences avec les commandes suivantes :

```
for I in $(find Cortex-Analyzers -name 'requirements.txt'); faire sudo -H \ pip2 install -r $I; fait && \
```

```
for I in $(find Cortex-Analyzers -name 'requirements.txt'); faire sudo -H \ pip3 install -r $I || vrai; fait
```

Maintenant que tout est installé, nous devons indiquer à Cortex où trouver les analyseurs et les répondeurs.

Le fichier application.conf doit ressembler à la <Figure 74>. Voir annexe.

Orchestration, automatisation et réponse de la sécurité

Les chemins vers nos analyseurs et répondeurs sont /opt/Cortex-Analyzers/analyzers et /opt/Cortex-Analyzers/responders.

Nous devons maintenant redémarrer le cortex pour appliquer les modifications.

Pour se familiariser avec l'utilisation des analyseurs, voir le scénario dans l'annexe <Figure 75> à <Figure 79>.

4. Intégration de TheHive et Cortex

1. Création d'un utilisateur dédié dans le cortex pour les appels d'API.

Au sein de l'organisation techsogroup en cortex, nous allons créer un utilisateur dédié avec les permissions de lecture, d'analyse et une clé API que nous utiliserons pour nos requêtes <Figure 80>, <Figure 81> en annexe.

Pour sécuriser la connexion entre TheHive et Cortex, nous devons créer un tunnel ssh entre eux.

2. Créer un tunnel SSH

Avant de passer par la procédure technique, voyons ce que nous allons réaliser, vous remarquerez dans la <Figure 33> que nous créons un transfert de port local et distant à l'aide de tunnels SSH.

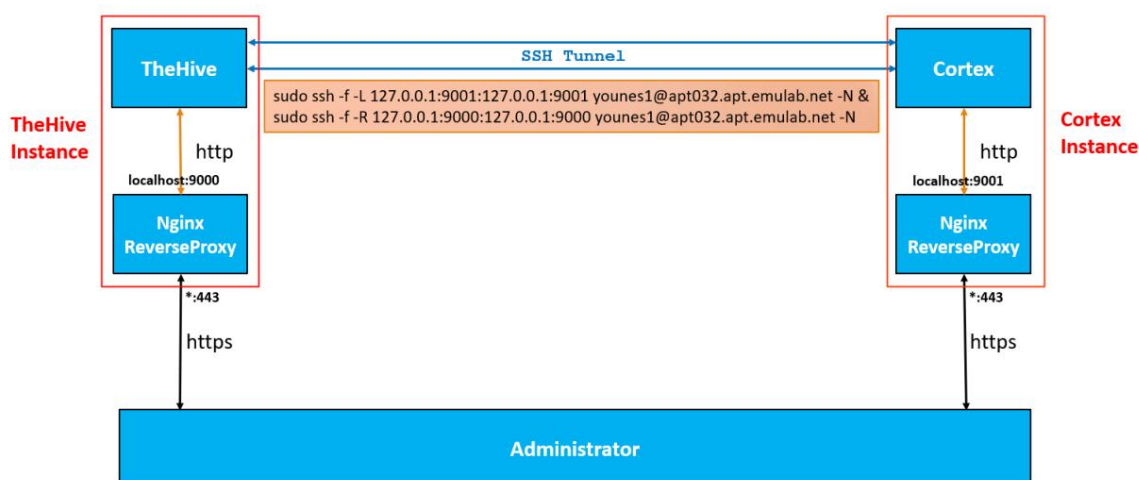


Figure 33 : Architecture du tunnel SSH

1) Créez des clés ssh dans l'instance TheHive.

Dans cette phase, nous devons créer des clés ssh pour nous connecter à l'instance Cortex, pour ce faire, reportez-vous à l'annexe.

```
sudo ssh younes1@apt032.appt.emulab.net
```

2) Créer un tunnel ssh

En fait, notre objectif est de créer un tunnel ssh entre les deux instances, mais avant cela, nous devons d'abord copier le cortex (clé privée) vers ~/.ssh/ sur l'instance TheHive et exécuter les commandes suivantes :

```
sudo systemctl redémarrer ssh
```

```
eval `ssh-agent -s`
```

```
sudo ssh-add ~/.ssh/cortex
```

Ensuite, nous devons exécuter la commande suivante :

```
sudo ssh -f -L 127.0.0.1:9001:127.0.0.1:9001 \
younes1@apt032.appt.emulab.net -N & \
```

Orchestration, automatisation et réponse de la sécurité

```
sudo ssh -f -R 127.0.0.1:9000:127.0.0.1:9000 \
younes1@apt032.apt.emulab.net -N
```

Nous avons maintenant un mappage entre l'hôte local des deux instances et les deux ports 9001 .

De plus, nous avons un mappage entre l'hôte local des deux instances et les deux ports 9000 .

Réinitialisons l' adresse:port pour Cortex dans le fichier application.conf pour communiquer uniquement via <http://127.0.0.1:9001> <Figure 82>, voir Annexe.

Redémarrez TheHive et connectez-vous à son interface Web. Vous devriez voir que le cortex est connecté à TheHive.

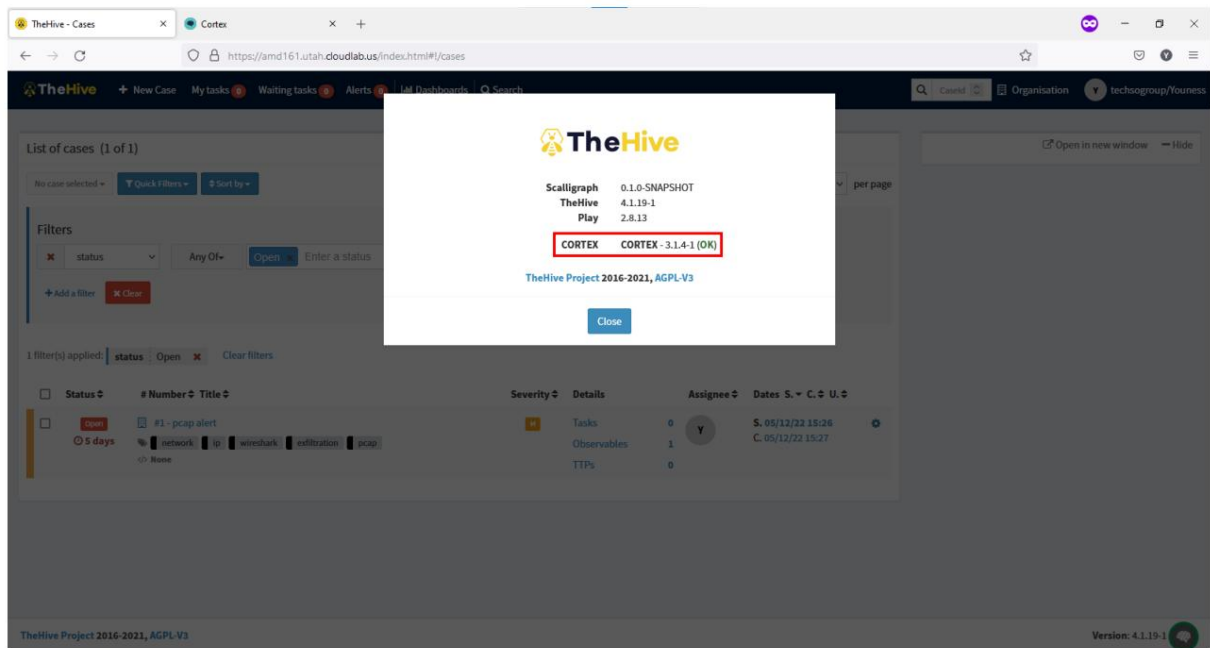


Figure 34 : Intégration Cortex & TheHive effectuée

5. Installation et configuration du MISP

1. Configuration matérielle requise pour MISP

Informations de base sur l'utilisation des ressources MISP :

MISP est fait pour être déployable sans consommer 8 Go de RAM lorsqu'il est vide. Vous pouvez l'exécuter sur une machine de 2 Go de RAM, avec un disque limité tel que 30 Go. Bien sûr, il peut fonctionner avec moins, mais vous serez limité plus tard lorsque des échantillons seront téléchargés, par exemple.

2. Instructions d'installation pour le serveur Ubuntu 20.04.2.0

Pour installer MISP, tout ce que nous devons faire est ce qui suit sur une distribution propre et prise en charge.

```
wget -O /tmp/INSTALL.sh \ https://  
raw.githubusercontent.com/MISP/MISP/2.4/INSTALL/INSTALL.sh
```

Nous devons spécifier l'option d'installation ; nous avons les options dans la <Figure 83>, voir l'annexe.

Tapez la commande suivante pour voir les options dont dispose MISP :

```
bash /tmp/INSTALL.sh
```

Pour nous, nous devons tout installer, nous utiliserons donc l'option -A comme suit :

```
bash /tmp/INSTALL.sh -A
```

On nous demandera si nous acceptons la création d'un utilisateur MISP dédié au service MISP, nous taperons y.

Une fois l'installation terminée, nous pouvons accéder à notre `https://<ip-address>` et nous connecter avec les informations d'identification par défaut.

Utilisateur : `admin@admin.test`

Mot de passe : `administrateur`

Ensuite, il nous sera demandé de changer le mot de passe <Figure 84> et <Figure 85> en annexe.

3. Ajouter des flux au MISP

La première chose que nous devons faire après la connexion est d'activer certains flux (qui sont des sources d'informations avec lesquelles nous voulons nous synchroniser).

Pour ce faire, vérifiez le processus dans l'annexe <Figure 86> à <Figure 93>.

6. Intégration de TheHive et MISP

Une autre caractéristique importante de TheHive et MISP est que nous pouvons les combiner pour obtenir des renseignements de MISP à TheHive, ainsi que pousser nos enquêtes terminées de TheHive à MISP pour servir de renseignements pour nous ou pour quiconque que nous avons partagé avec les ensembles de notre MISP dans le avenir.

Pour intégrer TheHive et MISP, nous aurons d'abord besoin d'une clé API MISP, alors créons-en une :

Administration => Liste des clés d'authentification => +Ajouter une clé d'authentification

Voir comment dans l'annexe <Figure 94> et <Figure 95>.

Configurons maintenant le côté TheHive pour pouvoir communiquer avec l'instance MISP.

Accédez à application.conf dans l'instance TheHive et ajoutez les lignes dans <Figure 96> dans annexe.

Après cela, l'interface TheHive devrait ressembler à quelque chose comme <Figure 97>.

Comme nous pouvons comprendre que nous pouvons pousser notre enquête de TheHive à MISP et c'est aussi simple qu'un clic sur un bouton <Figure 98> et <Figure 99> en annexe.

Chapitre 4 : Cas d'utilisation

1. Introduction

L'orchestration et l'automatisation de la sécurité aident les équipes à améliorer leur posture de sécurité et à augmenter leur productivité tout en gardant le contrôle sur les processus informatiques et de sécurité critiques. Définir les points sensibles auxquels votre entreprise doit s'attaquer est un bon point de départ avant de rechercher une solution d'orchestration et d'automatisation de la sécurité. Tenez compte des éléments suivants :

Avez-vous trop d'alertes pour que votre personnel de sécurité puisse les traiter efficacement et en temps opportun ?

Votre personnel présente-t-il des signes d'épuisement professionnel ?

Avez-vous des problèmes pour trouver et garder du personnel de sécurité ?

Votre équipe et vous-même passez-vous trop de temps à obtenir et à évaluer des données ?

Votre temps moyen pour réagir à un danger augmente-t-il ?

L'étape suivante consiste à établir vos cas d'utilisation les plus courants ou les tâches sur lesquelles les membres de votre équipe passent le plus de temps. Certaines entreprises, par exemple, verraient des avantages immédiats à automatiser la réponse aux attaques de logiciels malveillants, car il s'agit de leur problème le plus grave. Pour mieux gérer un nombre croissant de menaces et donner un contexte plus pertinent aux analystes, d'autres entreprises pourraient bénéficier de la synchronisation de la chasse aux menaces et de l'enrichissement des données. processus.

Connaître les cas d'utilisation que vous pouvez gérer avec l'orchestration et l'automatisation, puis hiérarchiser ceux qui peuvent apporter un bénéfice immédiat, vous aidera à affiner votre recherche de la meilleure solution pour un retour sur investissement plus rapide.

Dans notre cas, nous avons vu ce qu'est SOAR, pourquoi nous en avons besoin et comment installer et configurer notre système SOAR jusqu'à présent. Alors, que diriez-vous de passer à quelques cas d'utilisation pour mieux comprendre notre plateforme ?

Pour ces scénarios, nous verrons une utilisation pratique de TheHive manuellement, puis nous utiliserons Python, des analyseurs et l'API TheHive4py pour développer des playbooks d'enrichissement.

remarque

TheHive4py est une API REST qui permet aux analystes de créer des cas à partir de différentes sources telles qu'un e-mail ou un SIEM. Par exemple, un SOC peut demander à sa circonscription d'envoyer des rapports d'e-mails suspects à une boîte aux lettres spécifique qu'un script interroge à intervalles réguliers. Lorsqu'un nouvel e-mail est reçu, le script l'analyse puis appelle TheHive4py pour envoyer une alerte à TheHive. Les analystes peuvent alors prévisualiser l'alerte et, s'ils le jugent intéressant, ils peuvent l'importer en tant que cas et commencer à travailler dessus en collaboration grâce au flux en direct de TheHive.

2. Scénario : utilisation manuelle

Nous avons capturé le trafic réseau sur notre réseau après des soupçons d'exfiltration de données sur le réseau. Ce trafic correspond aux connexions FTP qui ont été établies. Notre tâche est d'analyser le trafic et de créer un dossier sur TheHive pour faciliter le déroulement d'une enquête.

Avec l'utilisateur analyste créé précédemment, nous pouvons effectuer la création d'un cas.

Une fois que l'analyste s'est connecté au tableau de bord, il sera accueilli par la page des cas.

En haut, diverses options de menu sont répertoriées qui permettent à l'utilisateur de créer de nouveaux cas et de voir leurs tâches et alertes. Une liste des cas actifs sera remplie sur la console centrale lorsque les analystes les créeront <Figure 35>.

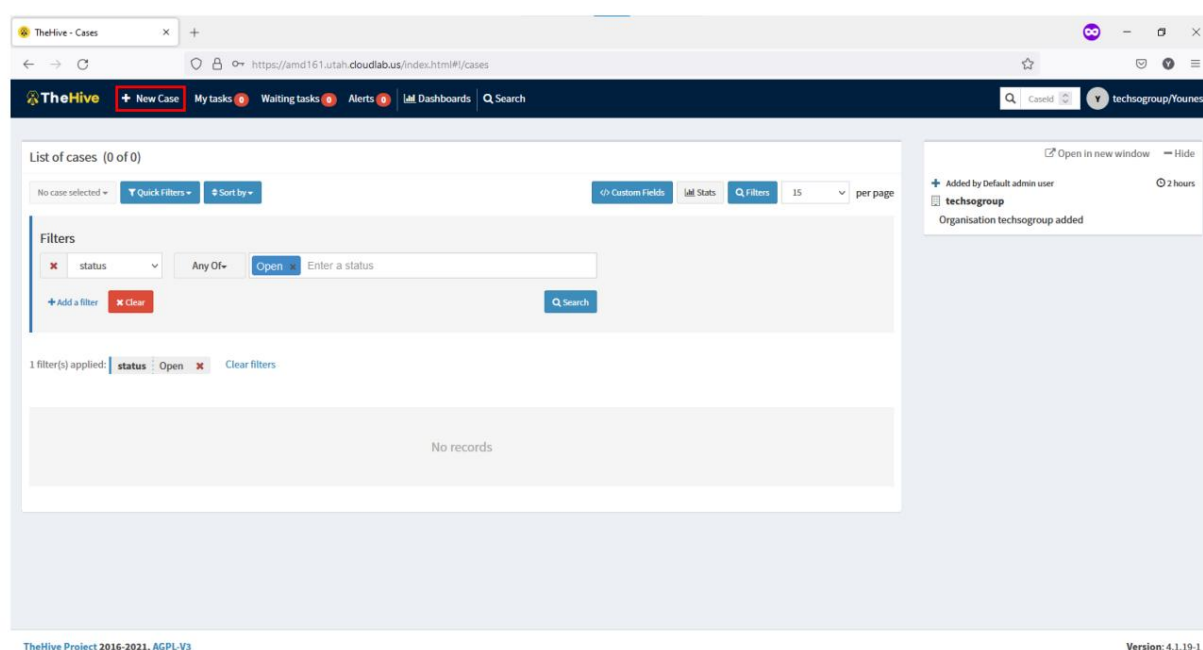


Figure 35 : La page des cas de TheHive

En cliquant sur "Nouveau cas" comme dans la <Figure 35>, une fenêtre contextuelle s'ouvre, fournissant à l'analyste les différentes options de création de cas prises en charge par TheHive.

Voir l'annexe pour en savoir plus sur [la gravité, le TLP et le PAP](#).

Dans cet esprit, nous ouvrons un nouveau dossier et remplissons les détails de notre enquête, comme indiqué ci-dessous. De plus, nous ajoutons quelques tâches au cas qui guideraient l'enquête sur le événement.

Remplissez les blancs et validez <Figure 36>.

Orchestration, automatisation et réponse de la sécurité

TheHive - New case

https://amd161.utah.cloudlab.us/index.html#/cases

TheHive + New Case My tasks Waiting tasks Alerts Dashboards Search

Create a new case

List of cases (0 of 0)

No case selected Quick Filters Sort by

Filters

status Any Of

Add a filter Clear

1 filter(s) applied status Open Clear filter

TheHive Project 2016-2021, AGPL-V3

Case details

Title * pcap alert Date * 12-05-2022 15:26

Severity * L H C TLP * WHITE GREEN AMBER RED PAP * WHITE GREEN AMBER RED

Tags

pcap network wireshark exfiltration ip Case tags

Description * Suspicious traffic captured by wireshark.

Case tasks

Task title Add task

No tasks have been specified

Cancel * Required field + Create case

Added by Default admin user techsogroup organisation techsogroup added 2 hours

Version: 4.1.10-1

Figure 36 : Créer un nouveau cas (1)

Après la création du cas <Figure 37>, nous pouvons ajouter des tâches aux membres de notre équipe, des observables liés au cas, des TTP, des pièces jointes, etc.

TheHive - Case #1: pcap alert

https://amd161.utah.cloudlab.us/index.html#/case/~20512/details

TheHive + New Case My tasks Waiting tasks Alerts Dashboards Search

Case #1 - pcap alert

Youness 05/12/22 15:27 2 minutes

Sharing (0) Close Flag Merge Remove

Details Tasks Observables TTPs

Basic Information

Title pcap alert

Severity L

TLP TLP:AMBER

PAP PAP:AMBER

Assignee Youness

Date 05/12/22 15:27

Tags network ip wireshark exfiltration pcap

Additional information Layout

No additional information have been specified

Description

Suspicious traffic captured by wireshark.

Added by Youness pcap alert description: Suspicious traffic captured by wireshark. #1 - pcap alert 7 minutes

Open in new window Hide

Figure 37 : Créer un nouveau cas (2)

Nous pouvons voir comment ajouter les modèles MITRE ATT&CK à l'instance TheHive dans l'annexe <Figure 100>, <Figure 101> et <Figure 102>.

Créez un observable pour le cas sur lequel nous travaillons et remplissez les cases avec les informations requises <Figure 38>.

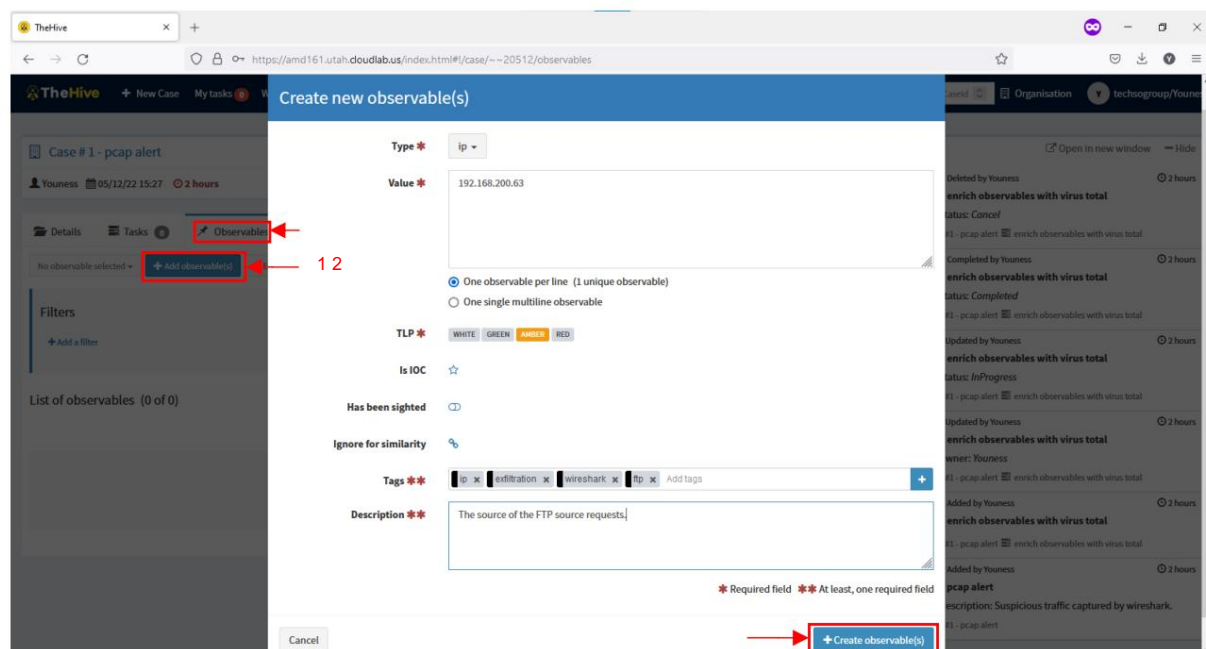


Figure 38 : Créer un nouvel observable

Dans notre scénario, nous ajoutons l'adresse IP 192.163.200.63 comme observable car cette adresse IP est la source des requêtes FTP. Selon la situation de votre analyse, cet observable peut être marqué comme un IoC ou s'il a déjà été aperçu dans une enquête différente.

Comme il s'agit d'une enquête d'exfiltration, c'est la tactique spécifique choisie et suivie par la technique spécifique T1048.003 pour l'exfiltration sur un protocole non crypté/obscurci non C2.

Donc, pour le spécifier, allez dans l'onglet TTP et ajoutez-le.

Et nous en avons fini avec cette simple utilisation manuelle de TheHive.

3. Scénario : manuel de phishing

Selon le Verizon Data Breach Digest [13], les attaques de phishing jouent un rôle dans 92 % des failles de sécurité.

Nous allons maintenant écrire un script qui accomplit les tâches suivantes :

- Utilisez le mode ssl imap "nom d'utilisateur et mot de passe" pour vous connecter à un serveur de messagerie. • Obtenez les e-mails qui sont stockés dans le dossier de la boîte de réception.
- À partir de l'e-mail brut, extrayez les URL, les adresses e-mail et les adresses IP. • Créez une alerte, puis convertissez-la en incident. Enfin, ajoutez des observables à ce cas, qui sont les URL, e-mails et IP que nous avons découverts auparavant.
- Analysez ces observables avec des analyseurs.

Nous allons créer un playbook simple qui peut se connecter à la boîte de réception d'un e-mail, récupérer les e-mails de ce dossier et en extraire des éléments observables tels que des adresses IP, des domaines, des adresses e-mail. Ensuite, envoyez-les à VirusTotal pour les analyser et stockez-les dans TheHive en tant que cas afin que l'analyste trouve les observables avec des données d'enrichissement, puis il fera ce qu'il faut pour empêcher que cela ne se produise.

Nous avons besoin de quelques modules avant de commencer, en supposant que nous avons déjà installé python3 dans notre instance :

```
pip install imaplib email re uuid thehive4py
```

Le code que nous utiliserons se trouve dans la <Figure 106> en annexe.

La <Figure 39> montre comment fonctionne le playbook et ses composants.

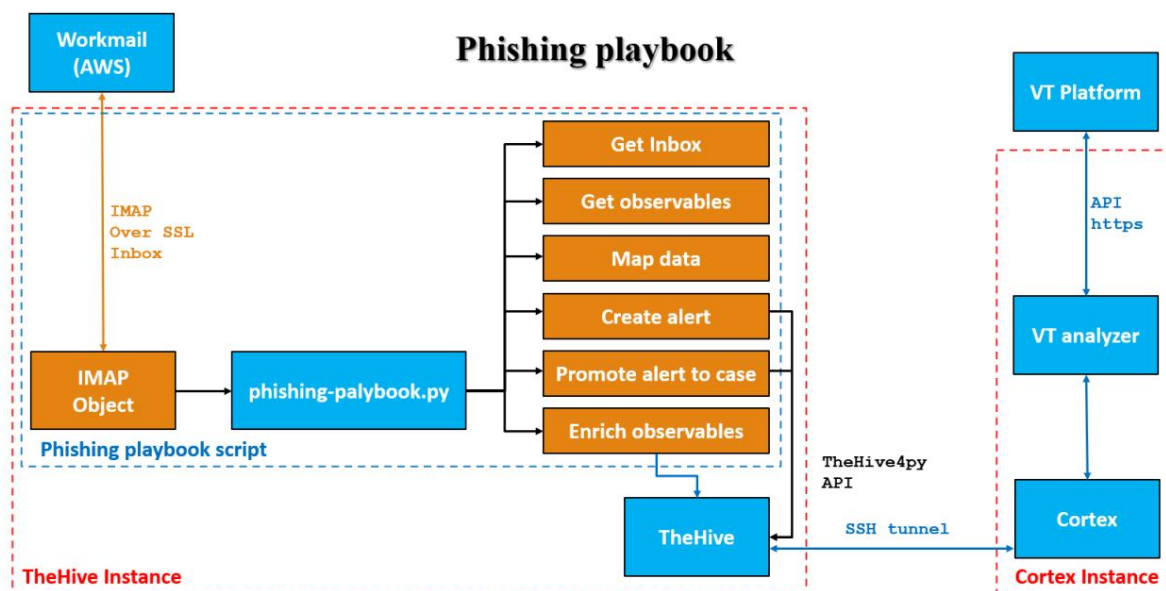


Figure 39 : Flux de travail du playbook de hameçonnage

voyons ce qu'il fait étape par étape:

- Importation des bibliothèques nécessaires. • Créer un objet API TheHive pour s'authentifier

- Définir la fonction pour :
 - o Obtenir des urls o
 - Obtenir des adresses email o
 - Obtenir des adresses IPv4 o Définir
 - une connexion à la fonction email o Définir une
 - fonction get inbox o Définir une fonction create
 - analyse pour créer le flux dans TheHive et enrichir les observables
- À la fin, notre fonction principale aura une combinaison de la fonction précédente à l'intérieur d'un
tandis que la boucle consiste à regarder dans la boîte de réception et à en extraire des données.

Pendant que votre code est opérationnel, vous pouvez le déployer en tant que service systemd pour empêcher son arrêt, de sorte qu'à chaque fois qu'il s'arrête, il redémarre à nouveau.

Faisons ce service systemd :

```
sudo nano /etc/systemd/system/phishing-playbook.service
```

Remplissez le fichier avec les éléments suivants :

```
[Unit]
Description=Manuel de phishing [Service]

Type=simple
ExecStart=/usr/bin/python3 /workflows/phishing-playbook.py & Restart=toujours [Installer]

WantedBy=multi-utilisateur.cible
```

Remarque

Notez que j'ai créé le dossier /workflows et je le ferai pour les playbooks que je crée. Pour mentionner que nous avons déjà python3 dans notre instance, nous devons donc simplement installer les exigences du script avant de l'exécuter.

Exécutez les commandes suivantes :

```
rechargement du démon systemctl
```

```
systemctl activer le phishing-playbook.service
```

```
systemctl démarrer phishing-playbook.service
```

```
état systemctl hameçonnage-playbook.service
```

Ça y est nous pouvons utiliser le playbook.

4. Scénario : Playbook de Suricata

Dans ce scénario, nous allons créer un playbook qui traite les alertes provenant d'une instance suricata car les données JSON le mappent à un modèle prédéfini dans TheHive en utilisant des champs et des modèles personnalisés, en créant des alertes dans TheHive et en leur ajoutant des observables en tant qu'adresses IP, valoriser ces alertes aux cas et enrichir les observables collectées <Figure 40>.

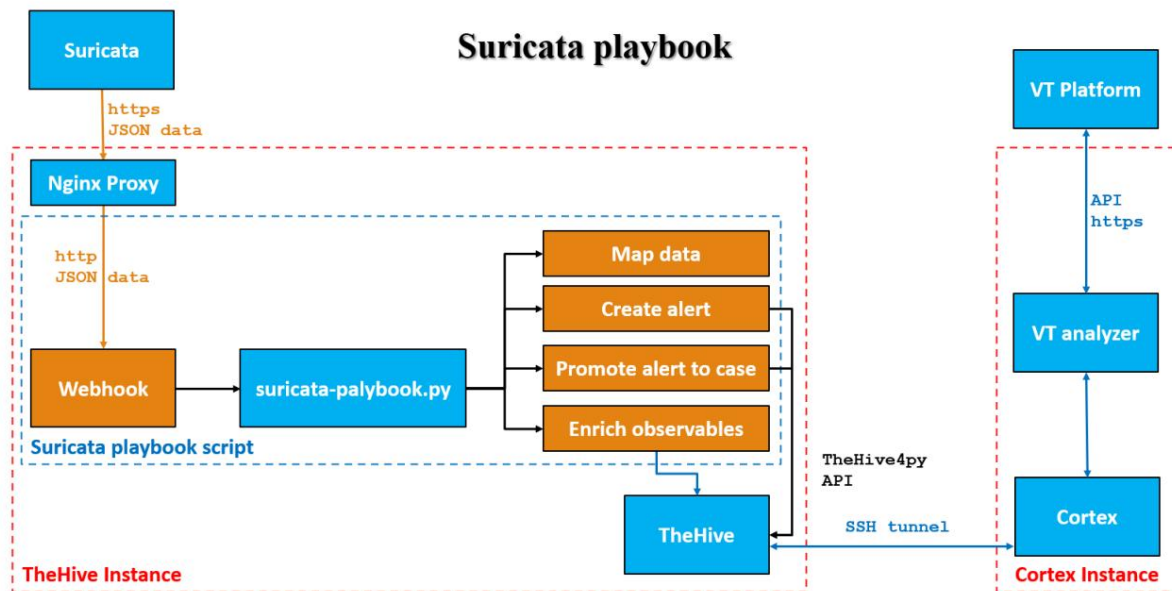


Figure 40 : Flux de travail du livre de jeu Suricata

Le code se trouve dans l'annexe <Figure 107>.

Pour rendre la persistance, nous pouvons ajouter un service système comme nous l'avons fait avec le playbook de phishing.

```
sudo-i
```

```
nano /etc/systemd/system/suricata-playbook.service
```

Le contenu de ce fichier devrait ressembler à ceci :

```
[Unit]
Description=Livre de jeu Suricata [Service]

Type=simple
ExecStart=/usr/bin/python3 /workflows/suricata-playbook.py & Restart=toujours [Installer]

WantedBy=multi-utilisateur.cible
```

Après cela, nous devons recharger le démon et activer le service (enable : chaque fois que l'instance démarre, elle démarre avec, start : elle ne démarre que pour l'instant, mais si un redémarrage se produit, elle ne démarre pas :

```
rechargement du démon systemctl
```

```
systemctl activer suricata-playbook.service
```

```
systemctl démarrer suricata-playbook.service
```

```
état systemctl suricata-playbook.service
```

L'état devrait ressembler à ceci :

```
root@ip-10-10-10-58:/etc/systemd/system# systemctl status suricata-playbook.service
● suricata-playbook.service - Suricata playbook
   Loaded: loaded (/etc/systemd/system/suricata-playbook.service; enabled; vendor preset: enabled)
   Active: active (running) since Wed 2022-06-08 16:54:34 UTC; 1min 14s ago
     Main PID: 20944 (python3)
       Tasks: 1 (limit: 9522)
      Memory: 25.6M
    CGroup: /system.slice/suricata-playbook.service
            └─20944 /usr/bin/python3 /workflows/suricata-playbook.py &

Jun 08 16:54:34 ip-10-10-10-58 systemd[1]: Started Suricata playbook.
Jun 08 16:54:35 ip-10-10-10-58 python3[20944]: * Serving Flask app 'suricata-playbook' (lazy loading)
Jun 08 16:54:35 ip-10-10-10-58 python3[20944]: * Environment: production
Jun 08 16:54:35 ip-10-10-10-58 python3[20944]: WARNING: This is a development server. Do not use it in a production deployment.
Jun 08 16:54:35 ip-10-10-10-58 python3[20944]: Use a production WSGI server instead.
Jun 08 16:54:35 ip-10-10-10-58 python3[20944]: * Debug mode: off
Jun 08 16:54:35 ip-10-10-10-58 python3[20944]: * Running on http://127.0.0.1:5001 (Press CTRL+C to quit)
```

Figure 41 : État du service Suricata systemd

Remarque :

Découvrez comment définir le transfert du webhook dans l'annexe de ce script de playbook <Figure 109>.

5. Scénario : Playbook de Kaspersky

Dans ce scénario, nous allons créer un playbook qui traite les alertes provenant d'une instance kaspersky en tant que données XML, le mapper à un modèle prédéfini dans TheHive à l'aide de champs et de modèles personnalisés, créer des alertes dans TheHive et leur ajouter des observables en tant que MD5 Hash , valoriser ces alertes en cas et enrichir les observables collectés <>.

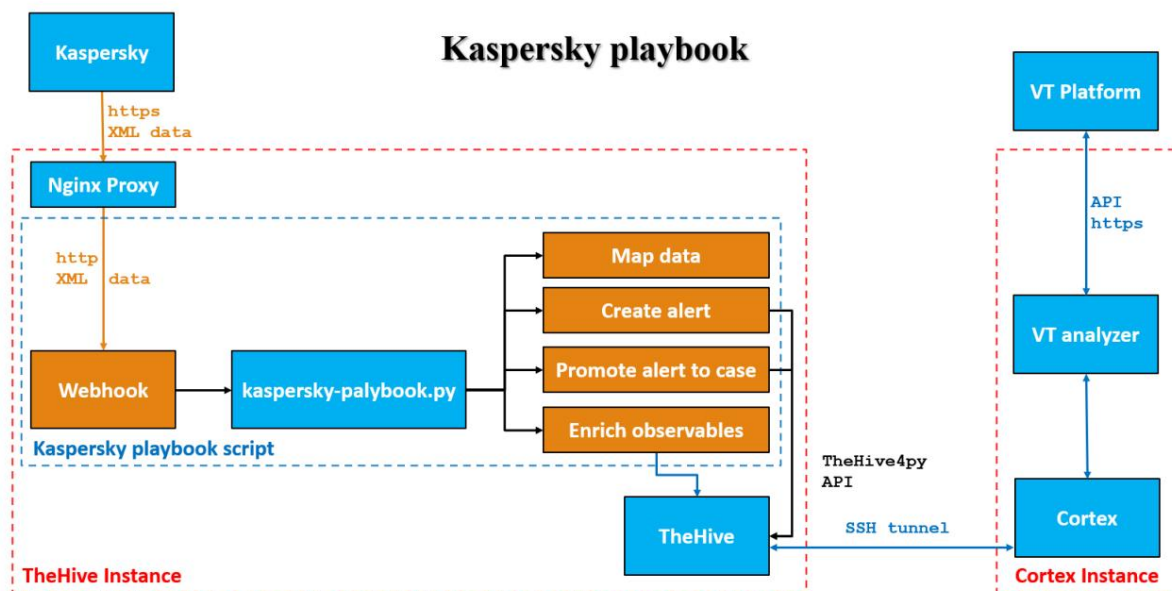


Figure 42 : Flux de travail du livre de jeu de Kaspersky

Le code se trouve dans l'annexe <Figure 108>.

Pour maintenir la disponibilité du playbook avec le service systemd :

```
sudo-i
```

```
nano /etc/systemd/system/kaspersky-playbook.service
```

Voici le contenu du fichier de service Kaspersky :

```
[Unit]
Description=Livret Kaspersky
```

```
[Service]
Tapez=simple
ExecStart=/usr/bin/python3 /workflows/kaspersky-playbook.py & Restart=always [Installer]

WantedBy=multi-utilisateur.cible
```

Appliquer les modifications avec :

```
rechargement du démon systemctl
```

```
systemctl activer kaspersky-playbook.service
```

```
systemctl démarrer kaspersky-playbook.service
```

```
état systemctl kaspersky-playbook.service
```

Remarque :

Découvrez comment définir le transfert du webhook dans l'annexe de ce script de playbook <Figure 110>.

6. Conclusion

Dans ce chapitre, nous avons découvert comment gérer manuellement un exemple d'alerte qui était une activité FTP suspecte que nous avons identifiée à tort comme une exfiltration, puis nous avons réussi à apprendre à utiliser python et l'API hive4py pour créer des playbooks personnalisés que nous pouvons intégrer à l'instance hive. et automatiser certaines tâches, telles que la création de cas à partir des sorties Suricata et Kaspersky et l'enrichissement des observables qu'ils contiennent. Pour souligner que python et thehive4py peuvent être utilisés à diverses autres fins, telles que la construction d'un bac à sable pour analyser des données ou répondre à une menace spécifique.

Conclusion générale

Ce fut un grand voyage pour en savoir plus sur "l'orchestration, l'automatisation et la réponse de la sécurité", découvrir le rôle qu'il joue en simplifiant le style de vie du centre des opérations de sécurité. Le Security Operations Center n'est rien d'autre qu'un groupe de personnes dédiées à l'analyse et à la réponse aux menaces de sécurité. Nous avons vu qu'ils ont un énorme problème face au nombre massif d'alertes qu'ils reçoivent quotidiennement, après cela, nous avons vu que SOAR pourrait être une bonne solution pour eux, en particulier qu'il peut centraliser leur travail en utilisant différentes interfaces vers une interface centralisée. , il peut également automatiser des tâches telles que l'enrichissement à partir d'autres plates-formes, l'analyse à l'aide de nos outils dédiés tels que les bacs à sable, et répondre à un indicateur de compromis spécial que nous avons découvert tout au long de notre analyse. Nous avons de nombreux produits SOAR commerciaux et quelques produits open source qui peuvent les concurrencer. Le SOAR que nous choisissons de mettre en œuvre utilisera TheHive comme composant central, Cortex pour effectuer l'analyse et la réponse et nous ajouterons également une plate-forme de partage d'informations sur les logiciels malveillants pour renforcer notre base de renseignements à l'aide de flux délégués et personnalisés. À la fin, nous avons vu comment nous pouvons utiliser python et thehive4py pour créer nos exemples de playbooks pour l'enrichissement afin de traiter les données provenant de Suricata (Network Intrusions), Kaspersky (Host Intrusions) et de la boîte de réception des e-mails (Phishing and social engineering Intrusions).

Bibliographie / Webographie

<https://www.imperva.com/blog/27-percent-of-it-professionals-receive-more-than-1-million-security-alerts-daily/>

<https://github.com/TheHive-Project/TheHive>

<https://github.com/TheHive-Project/Cortex>

<https://github.com/MISP/>

<https://docs.thehive-project.org/thehive/thehive/>

<https://github.com/TheHive-Project/CortexDocs>

<https://www.misp-project.org/documentation/>

<https://www.rapid7.com/info/security-orchestration-and-automation-playbook/>

<https://thehive-project.github.io/TheHive4py/reference/api/>

<https://github.com/TheHive-Project/Cortex4py/blob/master/Usage.md>

<https://tryhackme.com/room/thehiveproject>

<https://tryhackme.com/room/misp>

https://www.youtube.com/watch?v=VqIuP0AOCBg&list=PLB6hQ_WpB6U16_P_VyRIKerjI71ZVsdb (OpenSecure)

<https://www.youtube.com/watch?v=t6PqjLIVgdA&list=PLy-SBx6KOBefrug9439Chopi5aFdWup> (BlackPerl)

<https://www.youtube.com/watch?v=aM7czPsQyal&list=PLhSWiKucshm4CfNjKm7cxxjmj8LfxRXdp> (CIRCL Luxembourg)

[1 en ligne]. Disponible : <https://www.tradecommissioner.gc.ca/morocco-maroc/market-reports-etudes-de-marches/0005881.aspx?lang=fra>.

[2] [En ligne]. Disponible : <https://www.dataprotect.ma/en/cybersecurity.php>.

[3] [En ligne]. Disponible : <https://www.lmps-group.com/en/>.

[4] [En ligne]. Disponible : <https://www.nearsecure.com/>.

[5] [En ligne]. Disponible : <https://www.techsogroup.com/>.

[6] [En ligne]. Disponible : <https://www.imperva.com/blog/27-percent-of-it-professionals-receive-more-than-1-million-security-alerts-daily/>.

[7] [En ligne]. Disponible : <https://www.siemplify.co/blog/security-orchestration-automation-response-benefits/>.

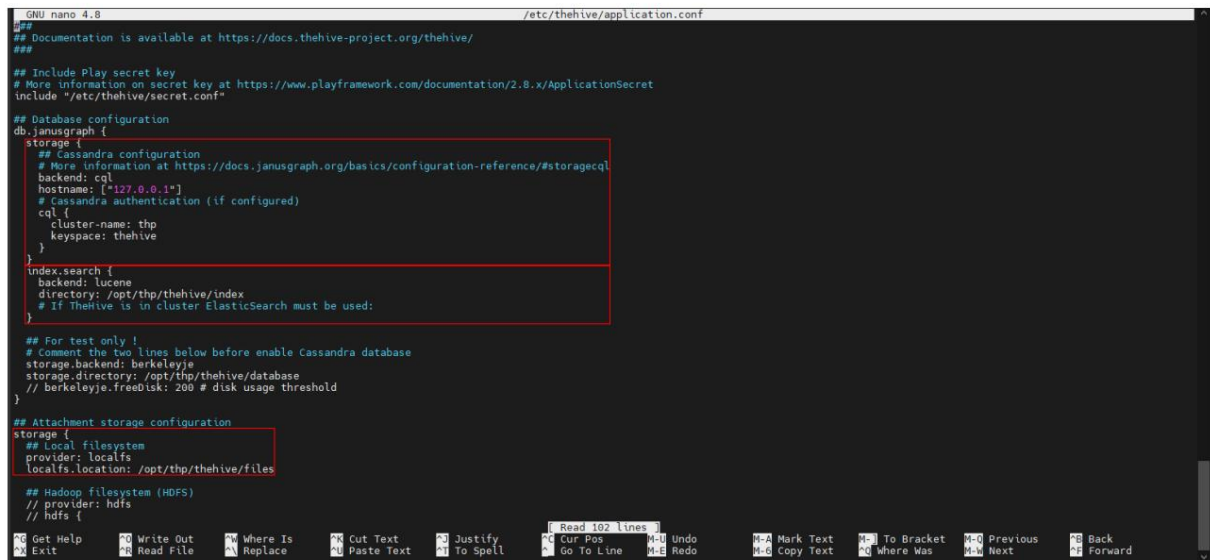
[8] [En ligne]. Disponible : <https://www.gartner.com/en/information-technologie/glossaire/sécurité-orchestration-automatisation-réponse-soar>.

- [9] [En ligne]. Disponible : https://www.peerspot.com/products/comparisons/palo-alto-networks-cortex-xsoar_vs_siemplify.
- [10] [En ligne]. Disponible : <https://www.g2.com/products/thehive/reviews>.
- [11] [En ligne]. Disponible : <http://docs.thehive-project.org/thehive/installation-and-configuration/installation/build-sources/>.
- [12] [En ligne]. Disponible : <https://github.com/TheHive-Project/Cortex-Analyzers>.
- [13] [En ligne]. Disponible : <https://www.rapid7.com/info/security-orchestration-and-automation-playbook/>.
- [14] M. toi.
- [15] w. sait, "c'est ça".
- [16] TechsoGroup, [En ligne]. Disponible : <https://www.techsogroup.com/>.
- [17] [En ligne]. Disponible : <https://www.techsogroup.com/>.
- [18] [En ligne]. Disponible : https://cassandra.apache.org/doc/latest/getting_started/configuring.html.
- [19] [En ligne]. Disponible : https://docs.datastax.com/en/ddac/doc/datastax_enterprise/config/configTOC.html.
- [20] [En ligne]. Disponible : <http://docs.thehive-project.org/thehive/operations/cassandra-sécurité/>.
- [21] [En ligne]. Disponible : http://docs.thehive-project.org/thehive/installation-and-configuration/architecture/3_nodes_cluster/.
- [22] [En ligne]. Disponible : http://docs.thehive-project.org/thehive/installation-and-configuration/architecture/3_nodes_cluster/.
- [23] [En ligne]. Disponible : <http://docs.thehive-project.org/thehive/installation-and-configuration/installation/step-by-step-guide/>.

Annexe

1. Installation et configuration de TheHive

fichier application.conf



```
GNU nano 4.8 /etc/thehive/application.conf
##
## Documentation is available at https://docs.thehive-project.org/thehive/
##
## Include Play secret key
# More information on secret key at https://www.playframework.com/documentation/2.8.x/ApplicationSecret
include "/etc/thehive/secret.conf"

## Database configuration
db.janusgraph {
  storage {
    ## Cassandra configuration
    # More information at https://docs.janusgraph.org/basics/configuration-reference/#storagecql
    backend: cql
    hostname: ["127.0.0.1"]
    # Cassandra authentication (if configured)
    cql {
      cluster-name: thp
      keyspace: thehive
    }
  }
  index.search {
    backend: lucene
    directory: /opt/thp/thehive/index
    # If TheHive is in cluster ElasticSearch must be used:
  }
}

## For test only !
# Comment the two lines below before enable Cassandra database
storage.backend: berkeleyje
storage.directory: /opt/thp/thehive/database
// berkeleyje.freeDisk: 200 # disk usage threshold
}

## Attachment storage configuration
storage {
  ## Local filesystem
  provider: localfs
  localfs.location: /opt/thp/thehive/files

  ## Hadoop filesystem (HDFS)
  // provider: hdfs
  // hdfs {

```

Figure 43 : Configuration de la base de données, de la base de données et du système de fichiers

La page de connexion de TheHive

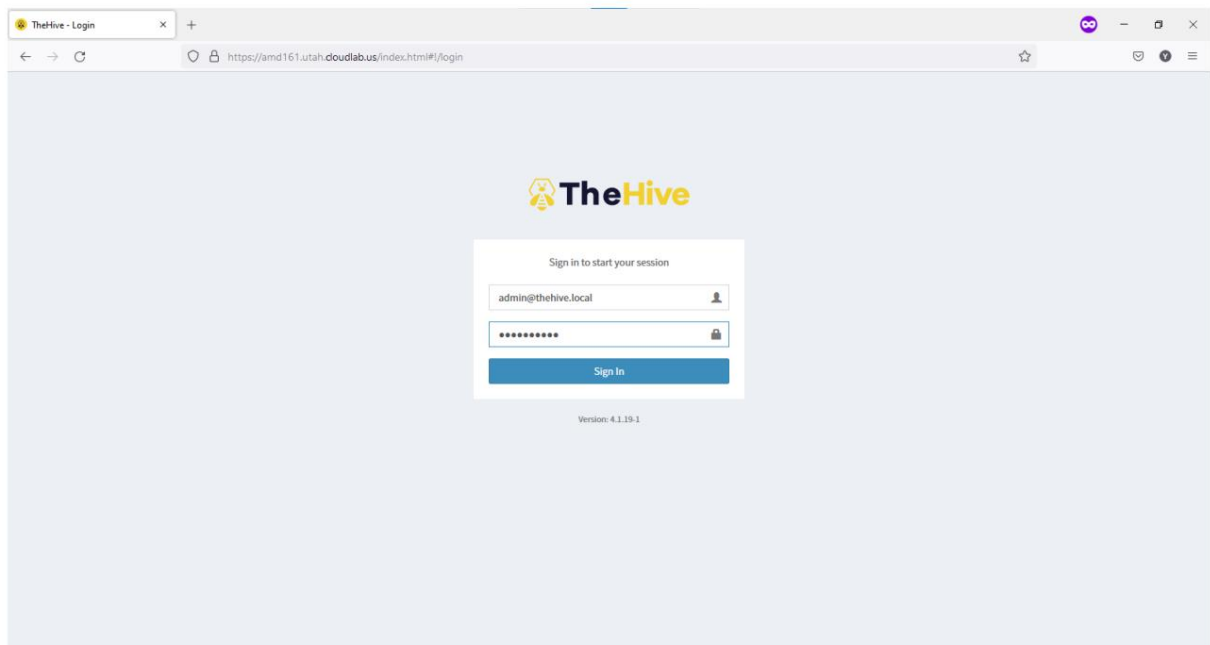


Figure 44 : Page de connexion TheHive

Orchestration, automatisation et réponse de la sécurité

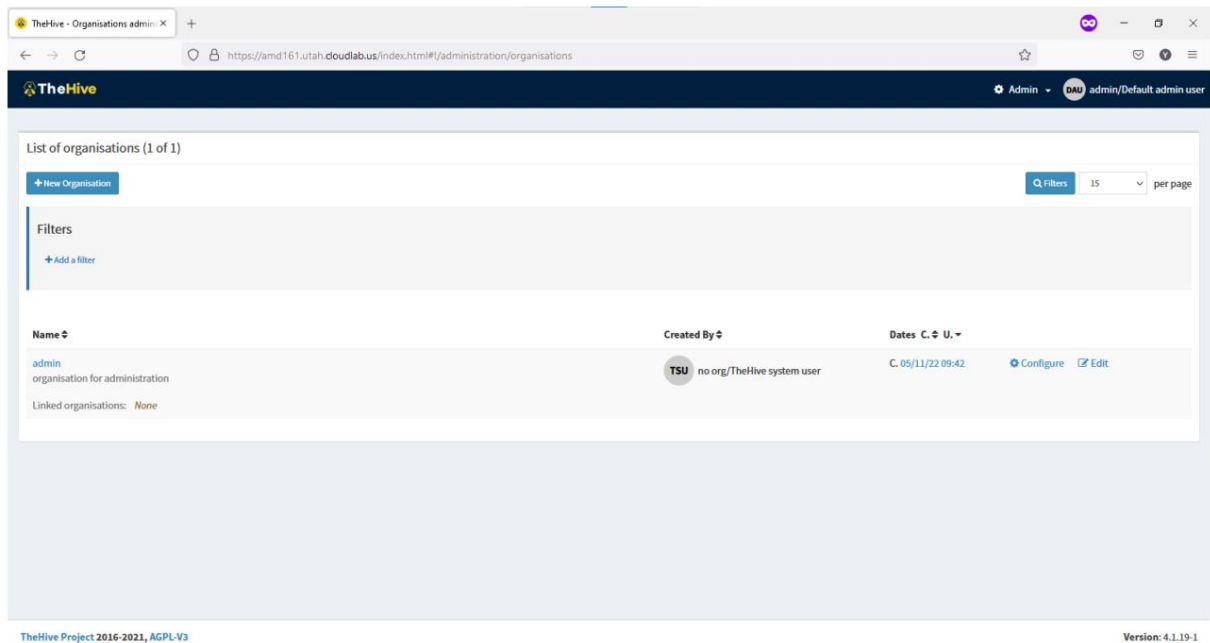


Figure 45 : La page des organisations de TheHive

fichiers reverse-proxy.conf et application.conf

```
fichier_mot_de_passe_ssl /etc/ssl/pass/phrase.pass ; serveur {

    écouter 443 ssl ; # le port sur lequel votre instance écoute nom_serveur
    amd161.utah.cloudlab.us ;

    certificat_ssl /etc/ssl/certs/thehive-cert.pem ; clé_certificat_ssl /etc/ssl/private/
    thehive-privateKey.pem ;

    proxy_connect_timeout 600 ;
    proxy_send_timeout 600 ; proxy_read_timeout 600 ;
    send_timeout 600 ; client_max_body_size

                                20M;

    proxy_buffering désactivé ;
    client_header_buffer_size 8k ;

    emplacement / {
        add_header Strict-Transport-Security "max-age=31536000 ; includeSubDomains" ; proxy_pass http://127.0.0.1:9000/ ;
        # l'ip de votre instance interne proxy_http_version 1.1 ; proxy_set_header Connexion "" ; }

    }

serveur
{ écouter 80 default_server ; écouter [::]:80
  default_server ; nom du serveur _ ; renvoie 301
  https://$host$request_uri ;

}
```

Figure 46 : première configuration de reverse-proxy.conf

```

GNU nano 4.8 reverse-proxy.conf
ssl_password_file /etc/ssl/openssl.cnf
server {
    listen 443 ssl; # the port that ur instance listen to
    server_name amd161.utah.cloudlab.us;

    ssl_certificate /etc/ssl/certs/thehive-cert.pem;
    ssl_certificate_key /etc/ssl/private/thehive-privateKey.pem;

    proxy_connect_timeout 600;
    proxy_send_timeout 600;
    proxy_read_timeout 600;
    send_timeout 600;
    client_max_body_size 20M;
    proxy_buffering off;
    client_header_buffer_size 8k;

    location / {
        add_header Strict-Transport-Security "max-age=31536000; includeSubDomains";
        proxy_pass http://127.0.0.1:9000; # the ip of ur internal instance
        proxy_http_version 1.1;
        proxy_set_header Connection "";
    }
}

server {
    listen 80 default_server;
    listen [::]:80 default_server;
    server_name _;
    return 301 https://$host$request_uri;
}

```

Figure 47 : première configuration de reverse-proxy.conf

1. Le chemin vers la phrase secrète pour ouvrir la clé privée
2. La configuration et le mappage https
3. La redirection forcée de http vers https pour sécuriser toutes les connexions

```

GNU nano 4.8 /etc/thehive/application.conf
# More information at https://github.com/TheHive-Project/TheHive4Docs/TheHive4/Administration/Connectors.md
# Enable Cortex connector
// play.modules.enabled += org.thp.thehive.connector.cortex.CortexModule
cortex {
    servers: [
        {
            name: "local" # Cortex name
            url: "http://localhost:9001" # URL of Cortex instance
            auth {
                type: "bearer"
                key: "****" # Cortex API key
            }
            wsConfig {} # HTTP client configuration (SSL and proxy)
        }
    ]
}

## MISP configuration
# More information at https://github.com/TheHive-Project/TheHive4Docs/TheHive4/Administration/Connectors.md
# Enable MISP connector
// play.modules.enabled += org.thp.thehive.connector.misp.MispModule
misp {
    interval: 1 hour
    servers: [
        {
            name: "local" # MISP name
            url: "http://localhost/" # URL of MISP
            auth {
                type: key
                key: "****" # MISP API key
            }
            wsConfig {} # HTTP client configuration (SSL and proxy)
        }
    ]
}

# Define maximum size of attachments (default 10MB)
//play.http.parser.maxDiskBuffer: 1GB

# Allow TheHive to only listen on localhost
http.address=127.0.0.1
http.port=9000

```

Figure 48 : application.conf localhost en écoute

2. Création de certificats numériques

Nous mettrons en place l'infrastructure à clé publique suivante :

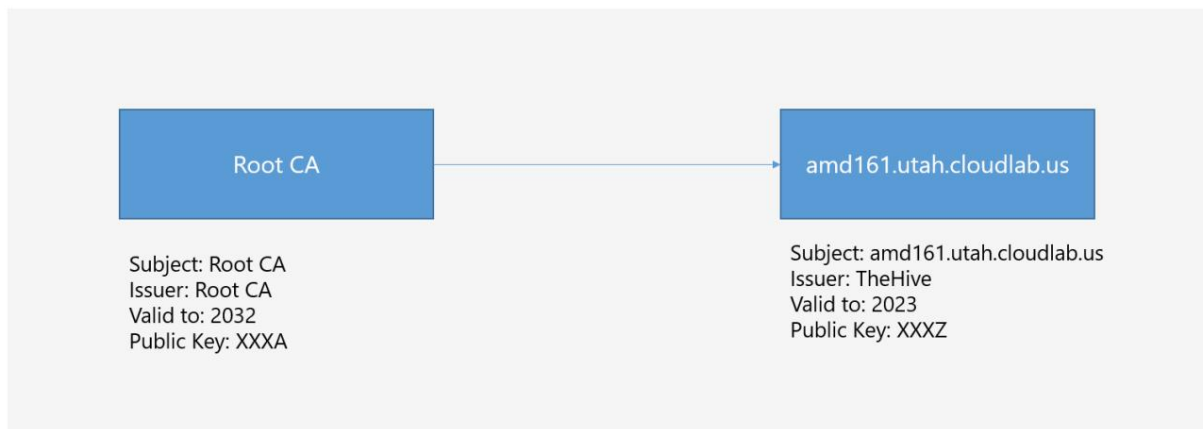


Figure 49 : Infrastructure PKI

Nous devons d'abord créer notre certificat racine, puis le certificat TheHive.

Créez un certificat auto-signé :

Pour le certificat racine, nous allons générer la clé privée et autosigner le certificat :

```
mkdir /openssl_cert
```

```
cd /openssl_cert
```

```
openssl genrsa -out autorité.key -des3 4092
```

```
openssl req -new -x509 -days 365 -key authority.key -out auth.cert
```

Remarque :

Le "Nom commun (par exemple, nom de domaine complet du serveur ou VOTRE nom) [] ." doit être apt036.apr.emulab.net

La phrase de passe que j'ai utilisée est youness37

Créez un certificat pour TheHive :

Générez la requête :

```
openssl genrsa -out thehive-privateKey.pem -des3 2048
```

```
openssl req -new -key thehive-privateKey.pem -out demand.serv
```

Signez maintenant la demande :

```
sudo openssl x509 -req -in demand.serv -out thehive-cert.pem -CA \ /openssl_cert/auth.cert -CAkey /
openssl_cert/authority.key \ -CAcreateserial -CAserial serial.ser -days 365
```

Copiez maintenant thehive-cert.pem dans /etc/ssl/certs et copiez thehive-privateKey.pem dans /etc/ssl/private sur l'instance TheHive

Remarque :

Le "Nom commun (par exemple, nom de domaine complet du serveur ou VOTRE nom) [] ." doit être amd161.utah.cloudlab.us

La phrase de passe que j'ai utilisée est youness37

Orchestration, automatisation et réponse de la sécurité

Vous pouvez utiliser les commandes suivantes pour vérifier la hiérarchie

```
openssl x509 -in auth.cert -subject -issuer -dates -noout
```

```
openssl x509 -in thehive-cert.pem -subject -issuer -dates -noout
```

```
openssl vérifier -CAfile auth.cert thehive-cert.pem
```

N'oubliez pas d'ajouter le fichier de phrase secrète dont nous avons parlé

Ajoutez la phrase secrète au fichier /etc/ssl/pass/phrase.pass :

```
nano /etc/ssl/pass/phrase.pass
```

Le contenu devrait ressembler à ceci :

```
youness37
```

Redémarrez NGINX et vérifiez que l'état est actif sur l'instance TheHive :

```
redémarrage du service sudo nginx
```

```
statut systemctl nginx
```

Pour rendre le certificat digne de confiance par notre navigateur Web, nous devons exporter un fichier pkcs12 et le placer au même emplacement que les autres certificats de confiance sur notre navigateur. Faire cela:

Générez le fichier pkcs12 (qui contient le certificat hive-cert et la clé privée hive de l'instance hive)

```
openssl pkcs12 -export -out envelop_serv.pfx -in thehive-cert.pem -inkey \ thehive-privateKey.pem
```

Nous devons maintenant charger le fichier dans le navigateur. Pour ce faire, accédez à la page des paramètres et recherchez "cert", puis sélectionnez le bouton "afficher les certificats". Après cela, importez le fichier pkcs12, il vous sera demandé d'entrer la phrase secrète, puis appuyez sur OK.

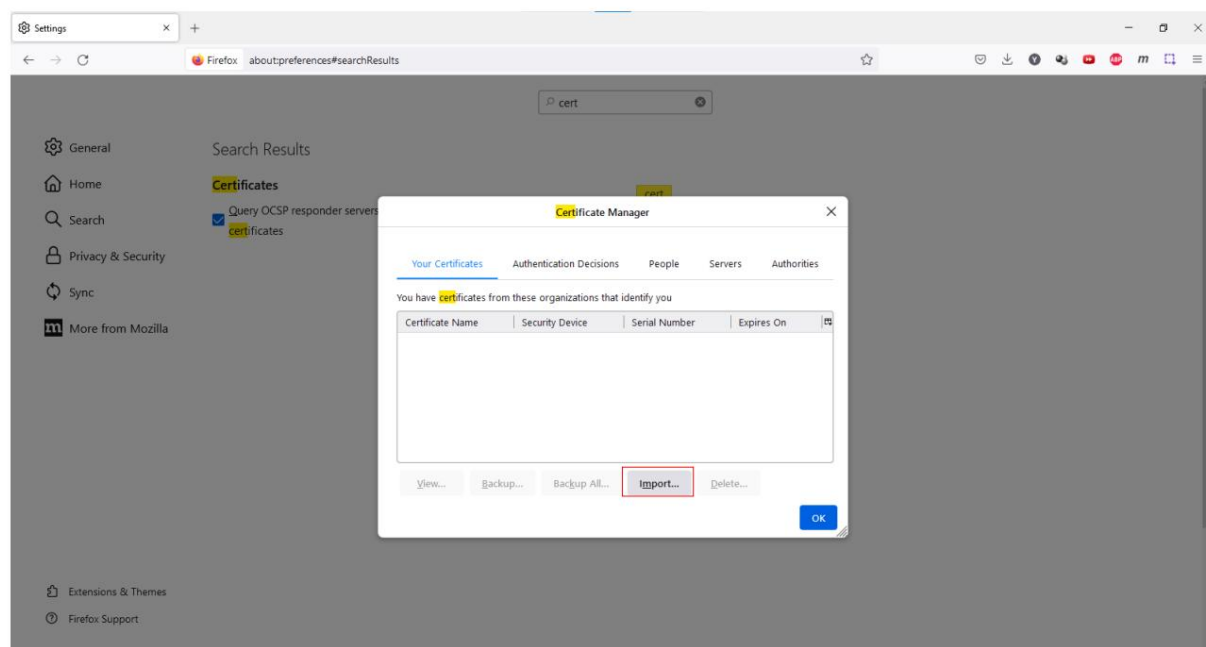


Figure 50 : Importer le fichier pkcs12 (1)

Orchestration, automatisation et réponse de la sécurité

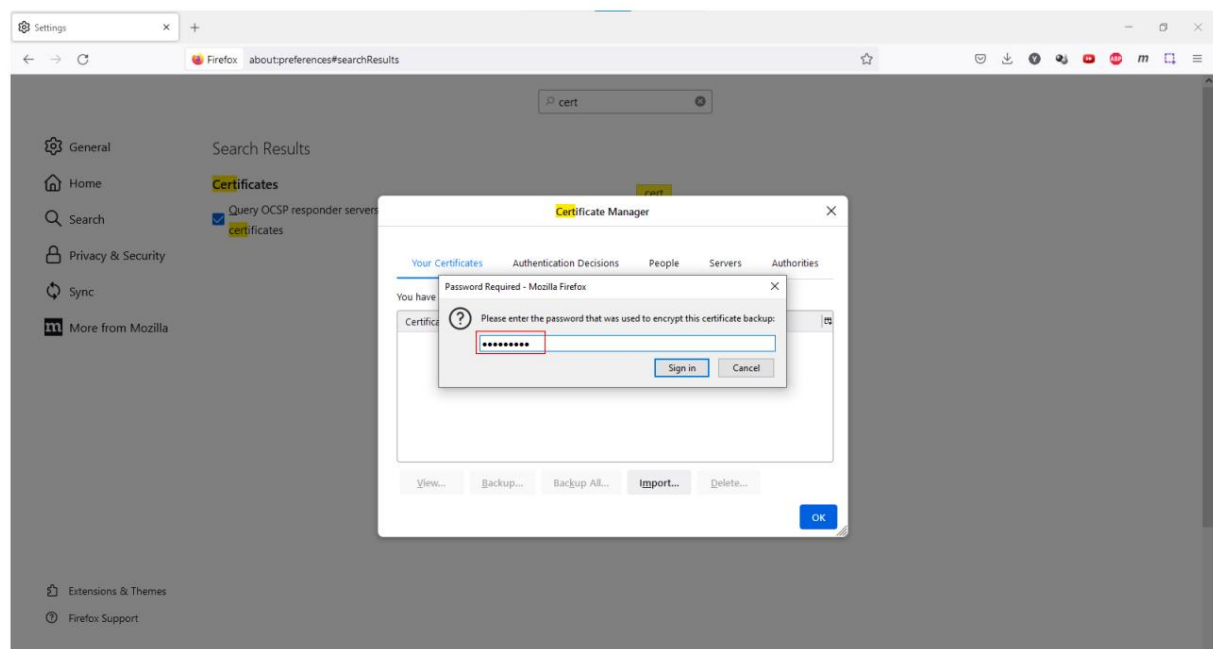


Figure 51 : Importer le fichier pkcs12 (2)

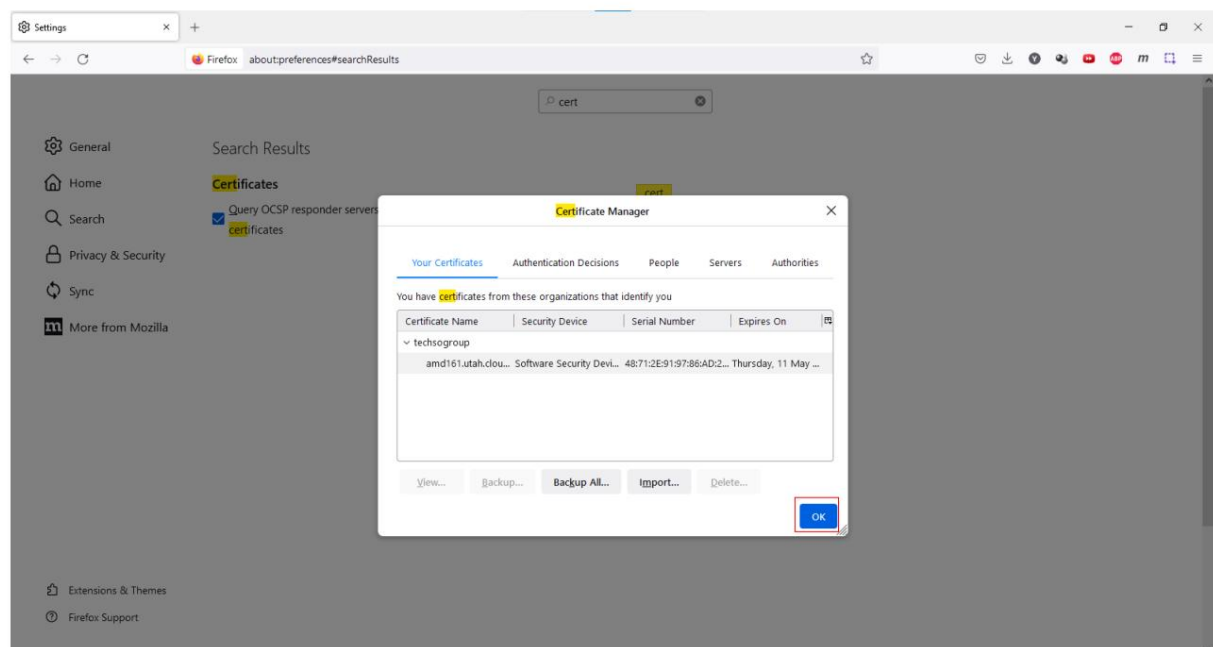


Figure 52 : Importer le fichier pkcs12 (3)

Pour appliquer les modifications, vous devez redémarrer le navigateur. Après cela, vous devriez voir que le certificat est approuvé.

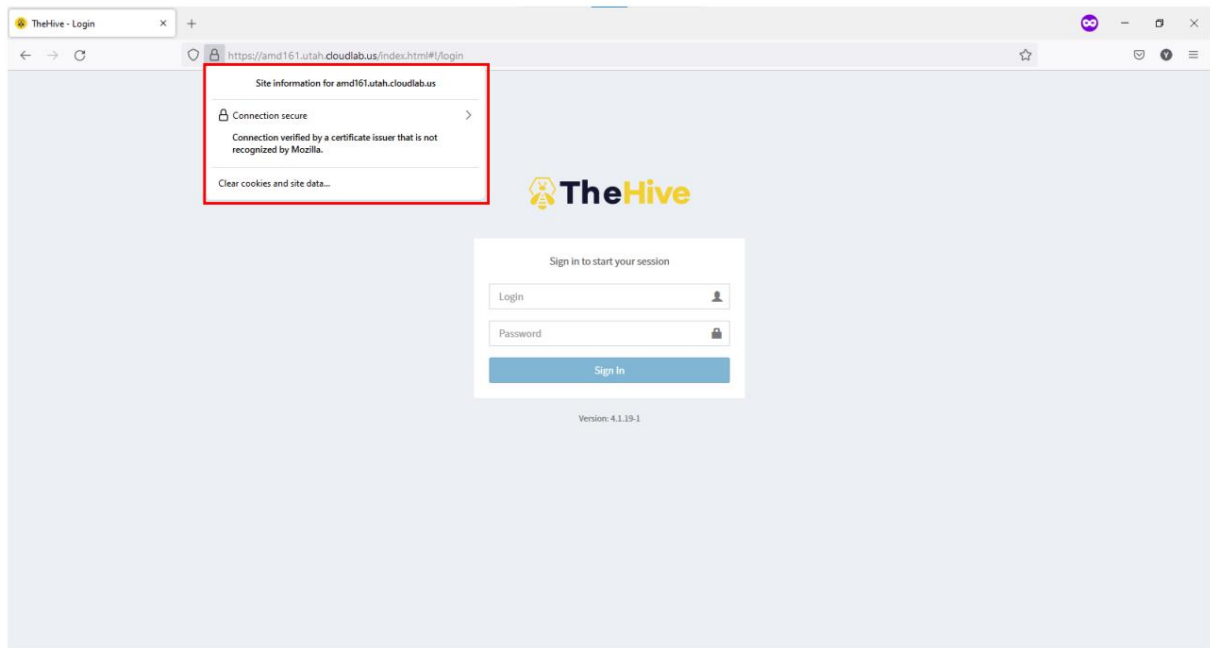


Figure 53 : https vers TheHive

Modifier le mot de passe de l'administrateur

Suivez les instructions ci-dessous :

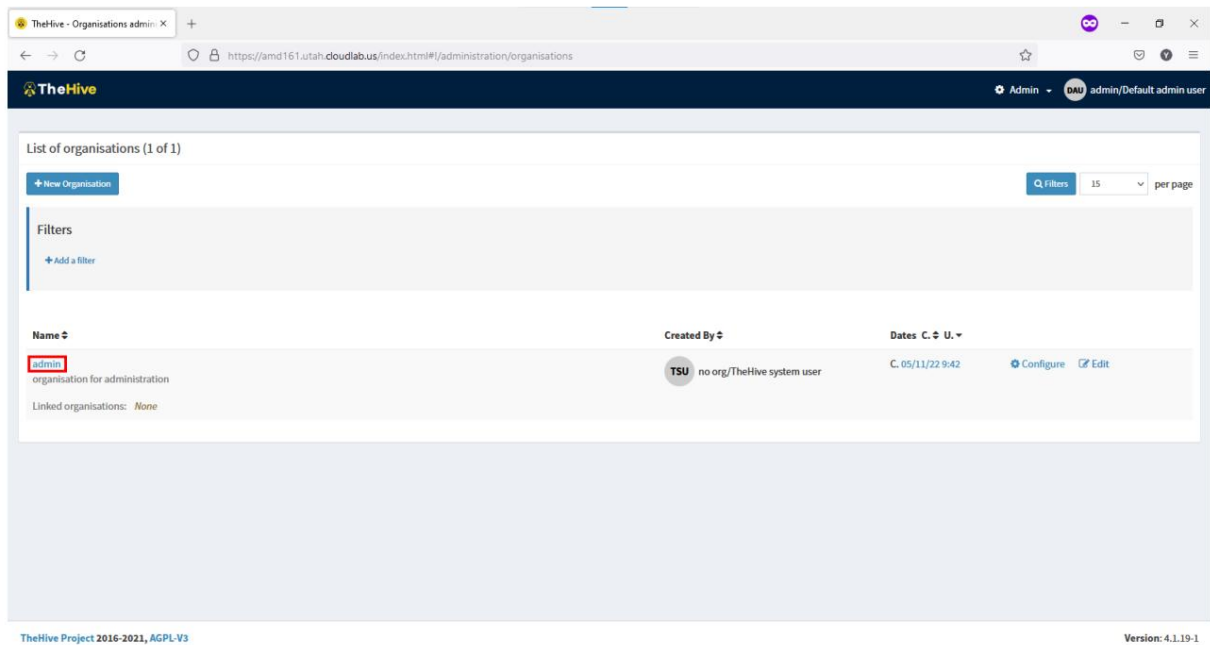


Figure 54 : Modifier le mot de passe administrateur (1)

Orchestration, automatisation et réponse de la sécurité

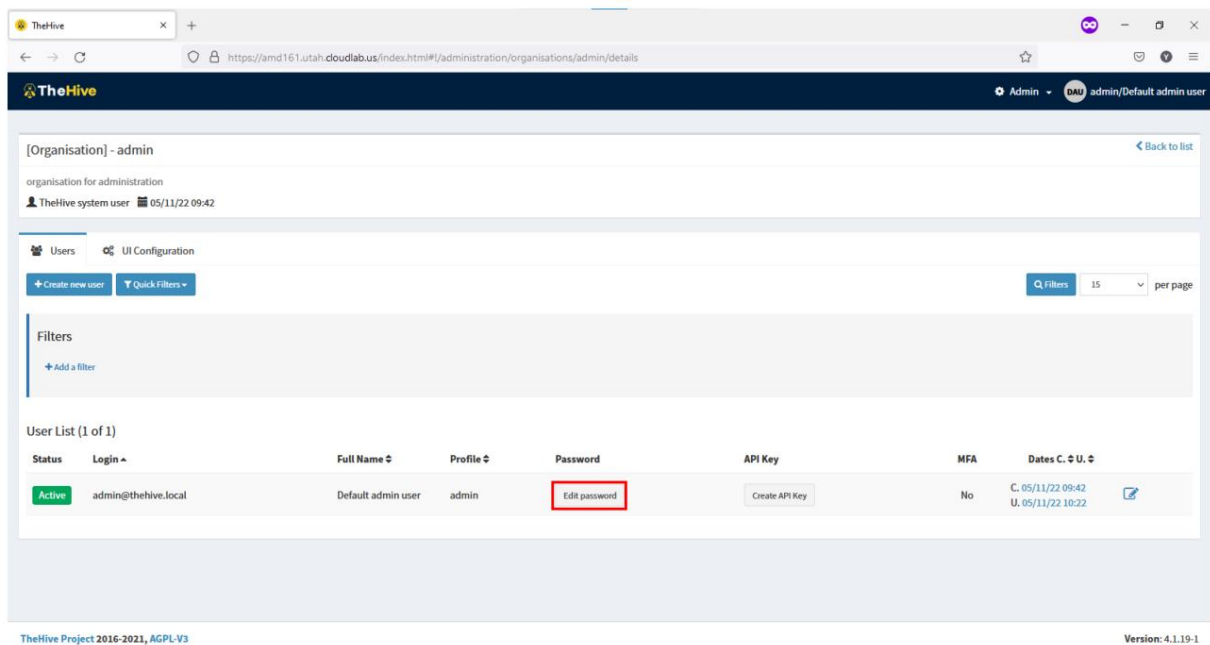


Figure 55 : Modifier le mot de passe administrateur (2)

Entrez votre nouveau mot de passe et cliquez sur vérifier.

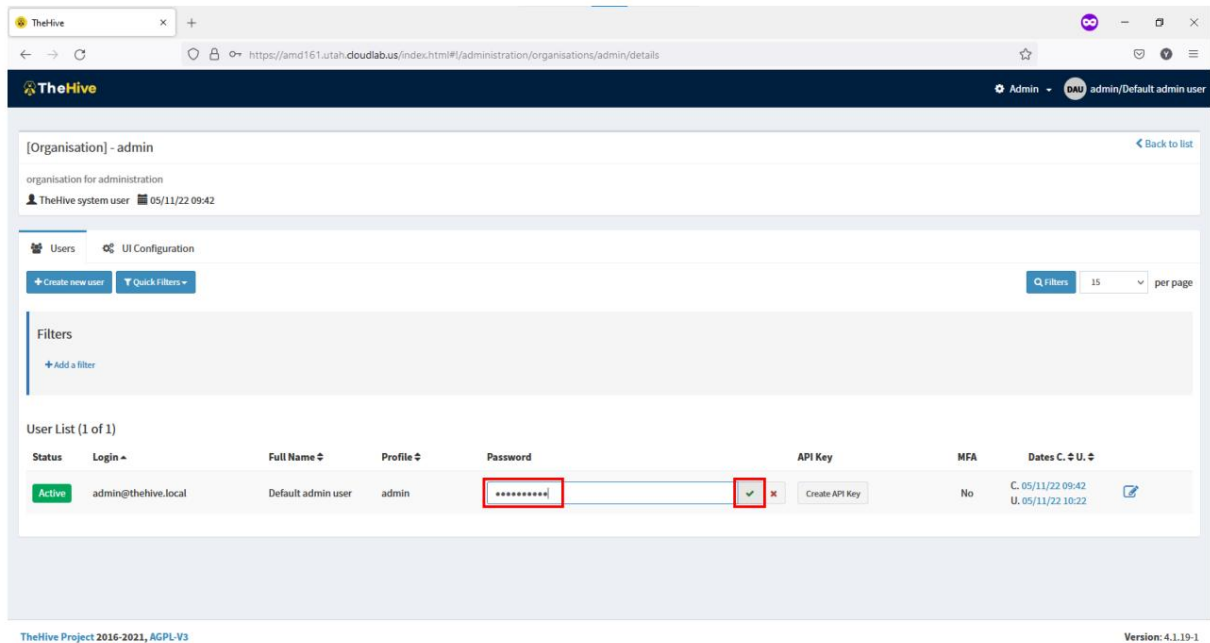


Figure 56 : Modifier le mot de passe administrateur (3)

Créer une nouvelle organisation et y ajouter des utilisateurs

Orchestration, automatisation et réponse de la sécurité

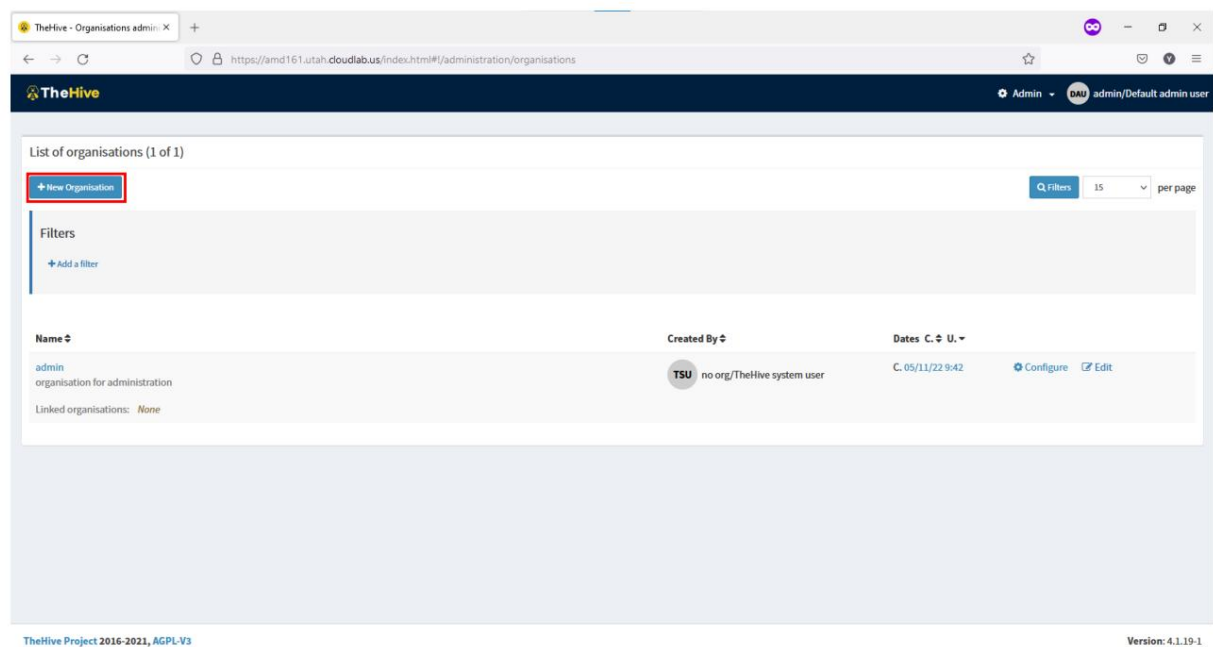


Figure 57 : Créer une organisation (1)

Remplissez les champs requis et enregistrez.

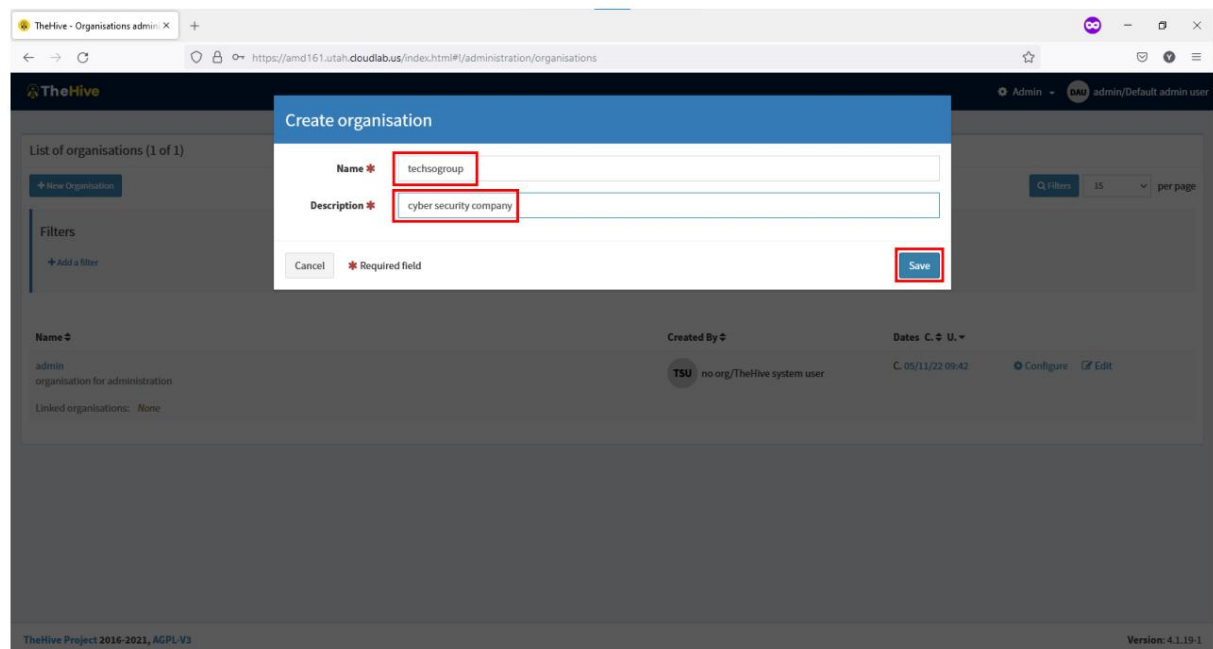


Figure 58 : Créer une organisation (2)

Maintenant que nous avons notre nouvelle organisation, ajoutons un nouvel utilisateur.

Orchestration, automatisation et réponse de la sécurité

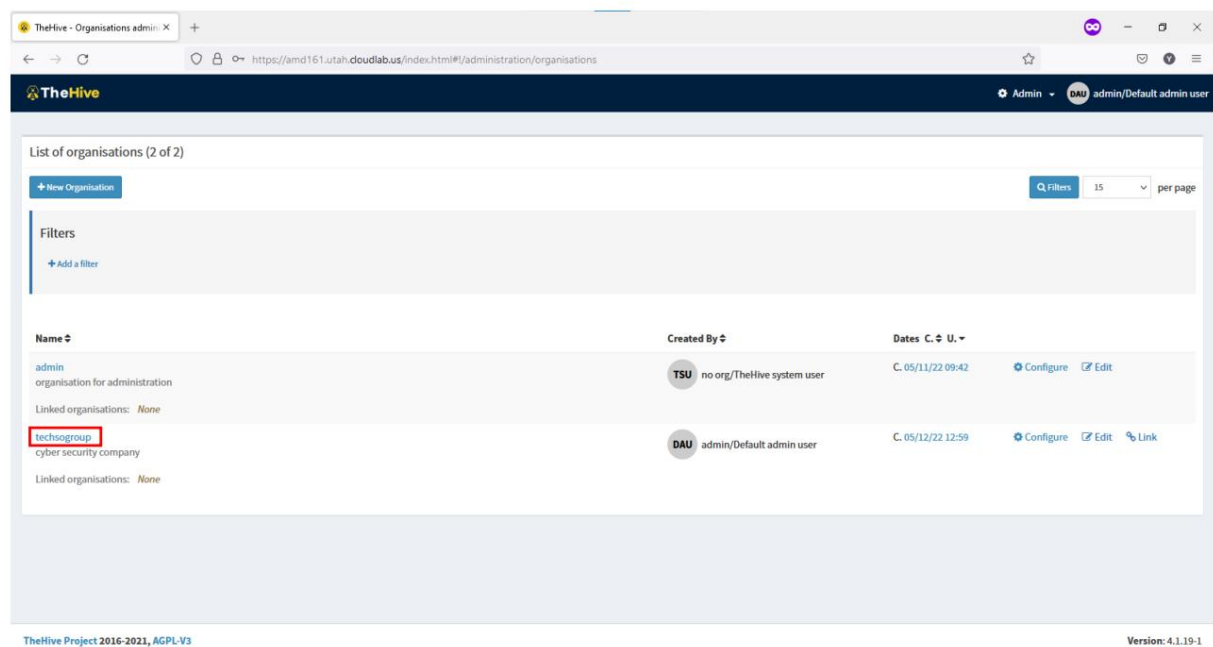


Figure 59 : Créer un utilisateur (1)

Cliquez sur le bouton "Créer un nouvel utilisateur" et remplissez les champs nécessaires.

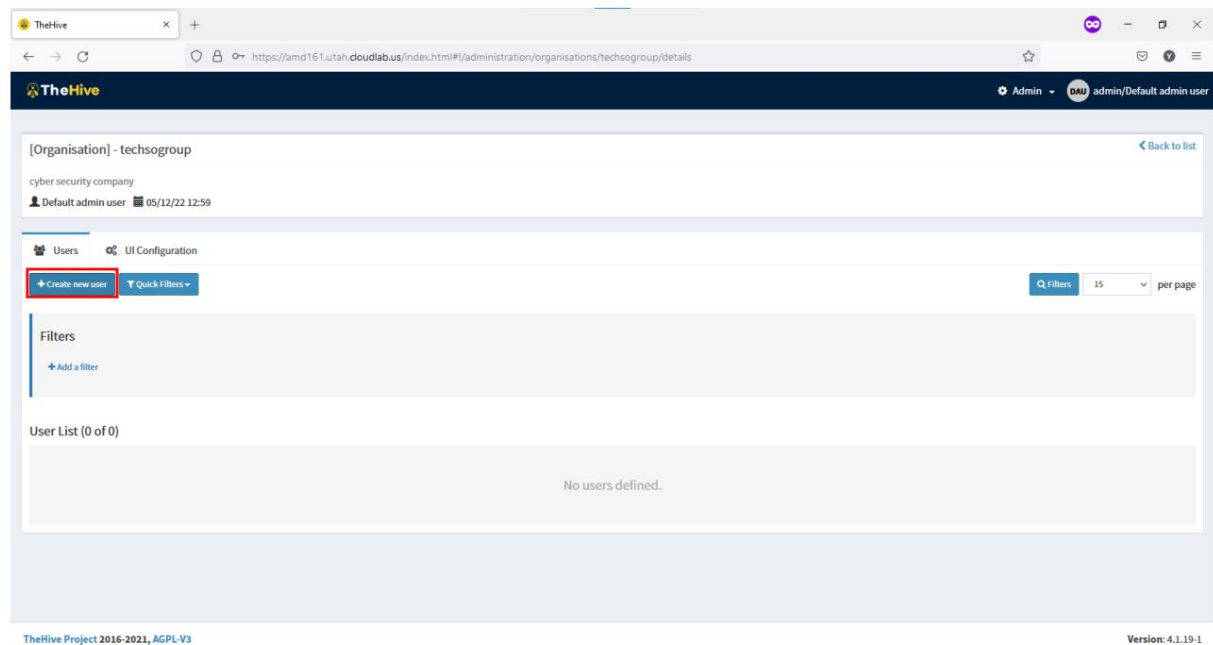
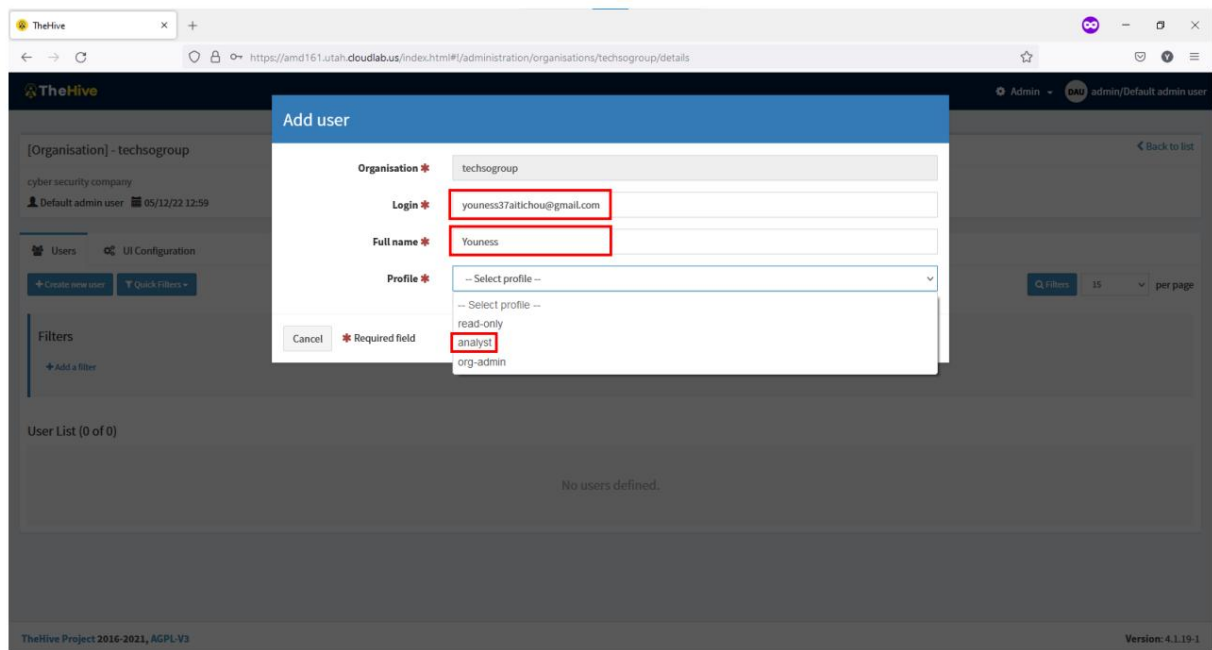


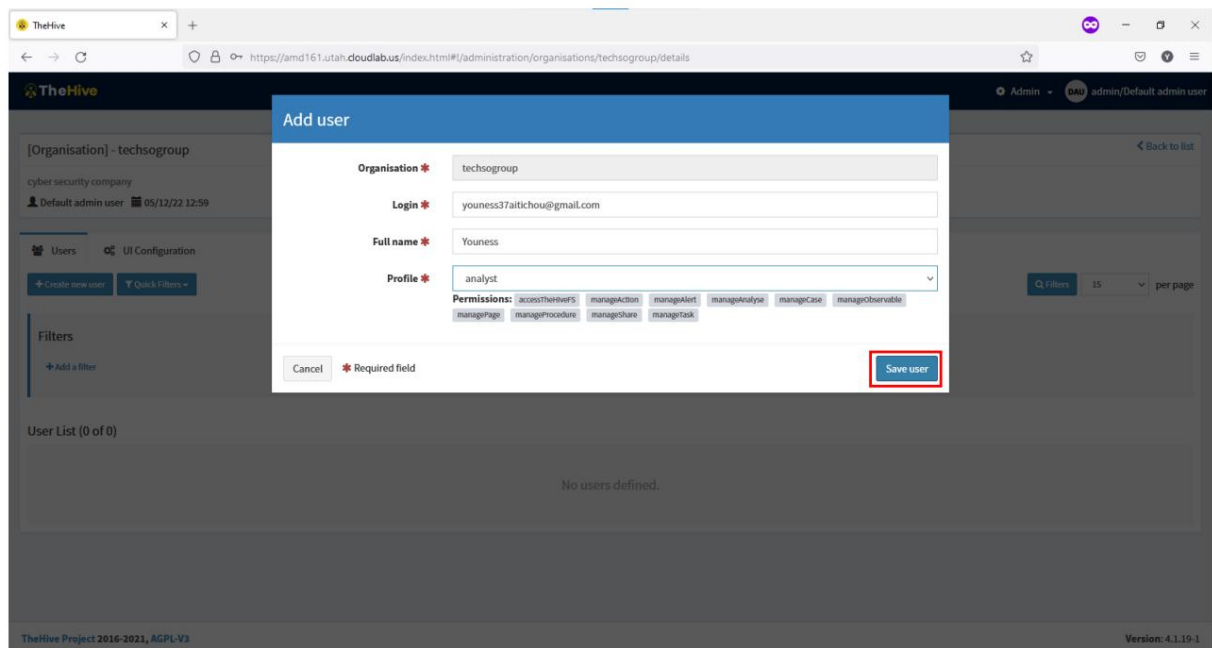
Figure 60 : Créer un utilisateur (2)

Orchestration, automatisation et réponse de la sécurité



The screenshot shows the 'Add user' form in TheHive. The form is titled 'Add user' and is located in the 'Administration' section. The 'Organisation' field is set to 'techsogroup'. The 'Login' field contains 'youness37altichou@gmail.com' and the 'Full name' field contains 'Youness'. The 'Profile' field is set to 'analyst'. The 'Permissions' field is set to 'read-only'. The 'Save user' button is highlighted with a red box.

Figure 61 : Créer un utilisateur (3)



The screenshot shows the 'Add user' form in TheHive. The form is titled 'Add user' and is located in the 'Administration' section. The 'Organisation' field is set to 'techsogroup'. The 'Login' field contains 'youness37altichou@gmail.com' and the 'Full name' field contains 'Youness'. The 'Profile' field is set to 'analyst'. The 'Permissions' field is set to 'read-only'. The 'Save user' button is highlighted with a red box.

Figure 62 : Créer un utilisateur (4)

Définissons un mot de passe pour cet utilisateur.

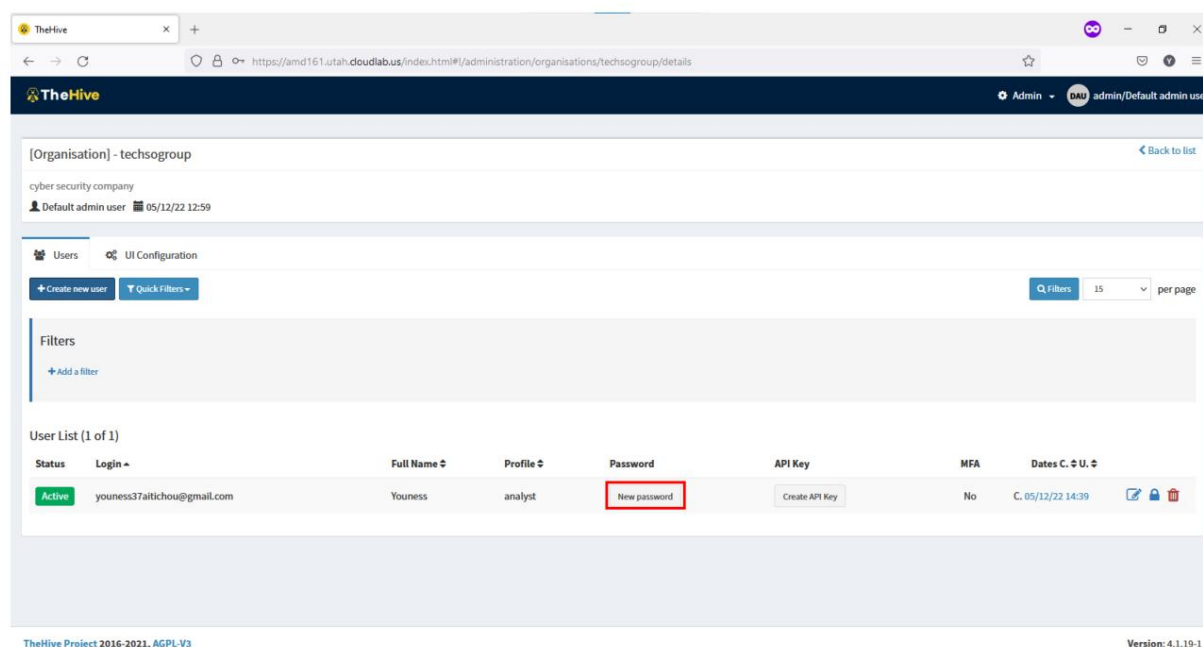


Figure 63 : Créer un utilisateur (5)

Entrez le mot de passe et cliquez sur vérifier.

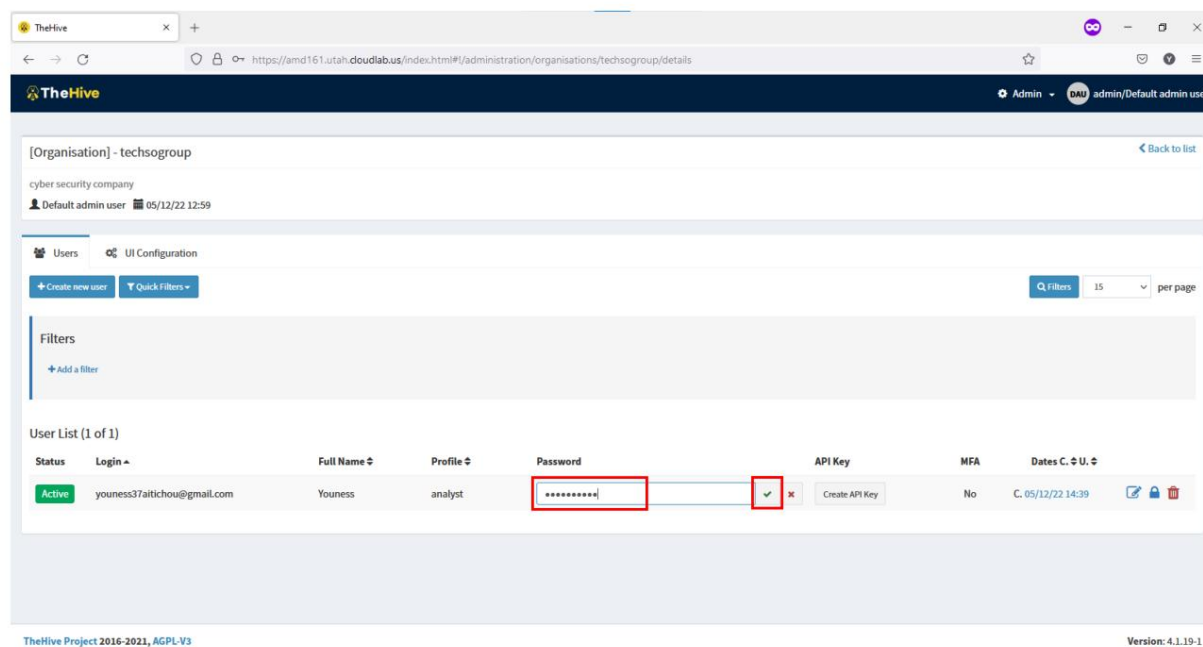


Figure 64 : Créer un utilisateur (6)

Créer un nouveau tableau de bord

Remplissez les champs requis et appuyez sur Créer.

Pour la visibilité, nous l'avons défini sur Partagé pour être accessible à tous les utilisateurs.

Orchestration, automatisation et réponse de la sécurité

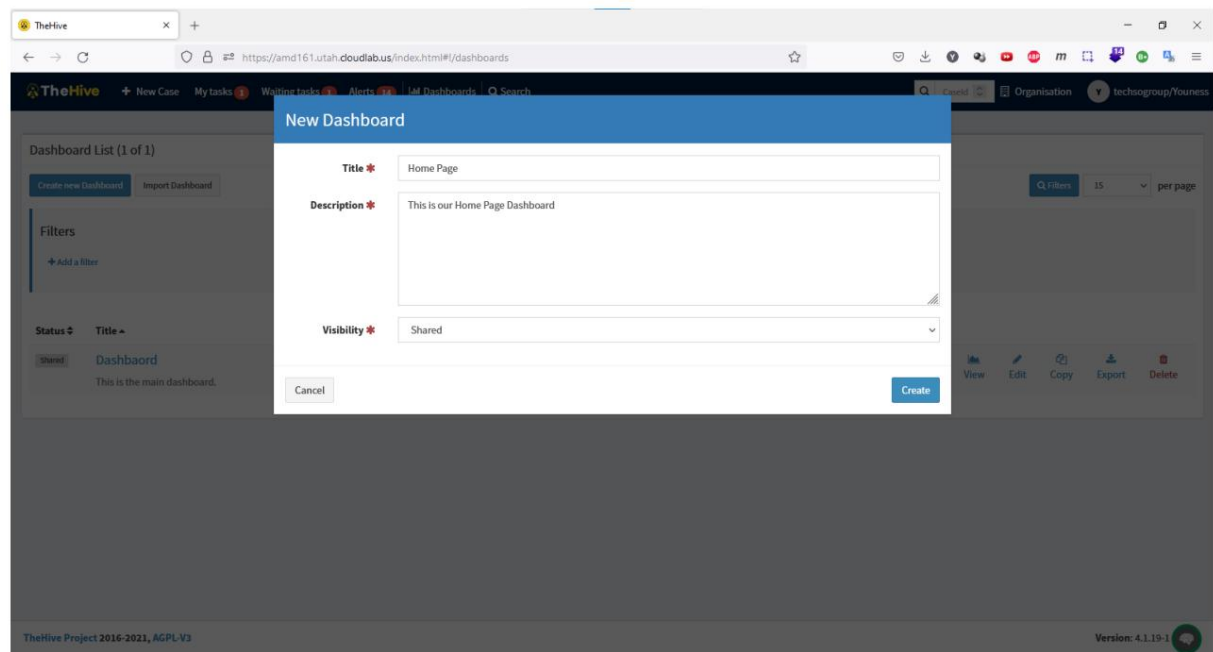


Figure 65 : Créer un nouveau tableau de bord (2)

La première chose à faire est de faire glisser et déposer les widgets de la barre de menu de droite vers notre zone de travail. Pour la première fois, nous avons déjà une ligne existante, il nous suffit donc de faire glisser et de déposer le widget que nous voulons utiliser dans la zone de travail.

Pour l'instant, nous utiliserons un widget "Donut" pour afficher nos alertes existantes en fonction de leurs sources.

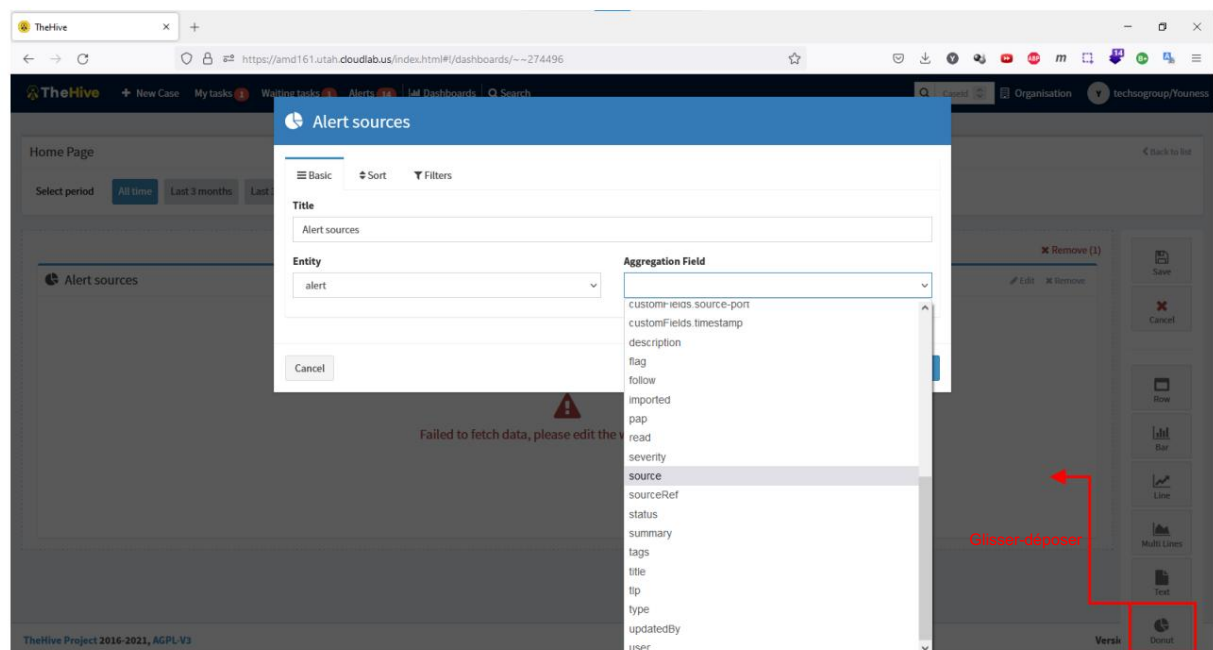


Figure 66 : Créer un nouveau tableau de bord (3)

Remplissez ensuite les champs obligatoires comme toujours.

Figure 67 : Créer un nouveau tableau de bord (4)

Le résultat devrait ressembler à ce qui suit.

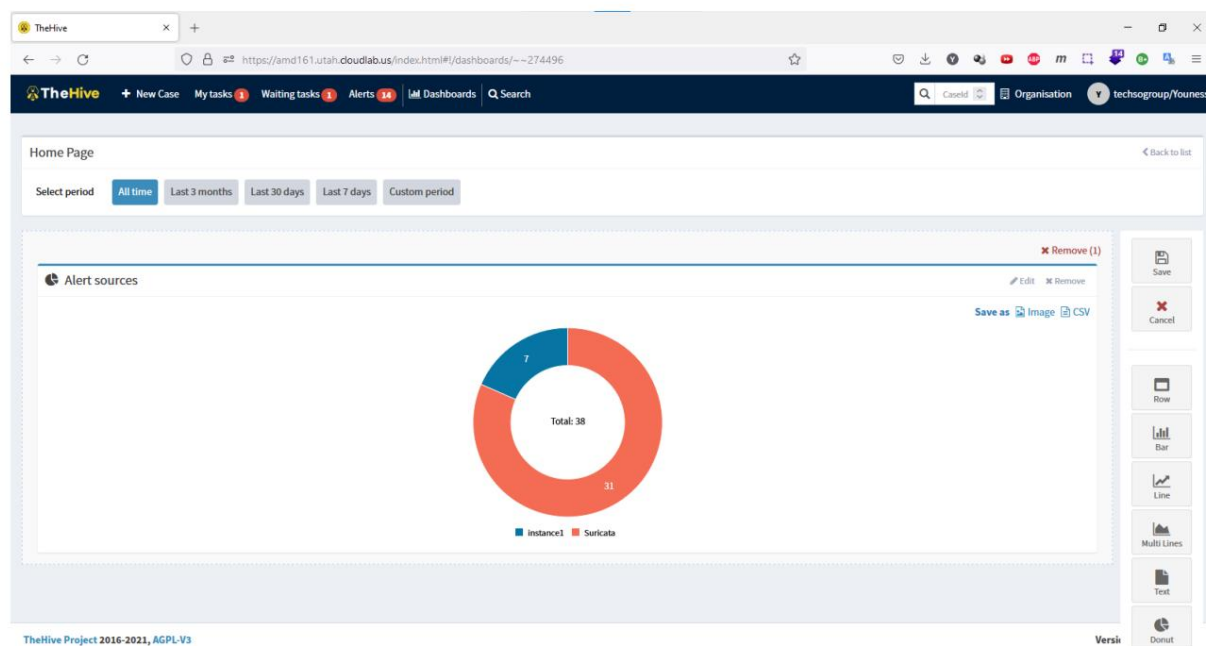


Figure 68 : Créer un nouveau tableau de bord (5)

Ajoutons un autre type de widget "Bar" pour mieux se familiariser avec.

Vous pouvez déposer le widget sur la même ligne ou vous pouvez créer une autre ligne, puis faire glisser et déposer le widget dessus, juste pour mentionner que chaque ligne peut contenir trois widgets au maximum.

Orchestration, automatisation et réponse de la sécurité

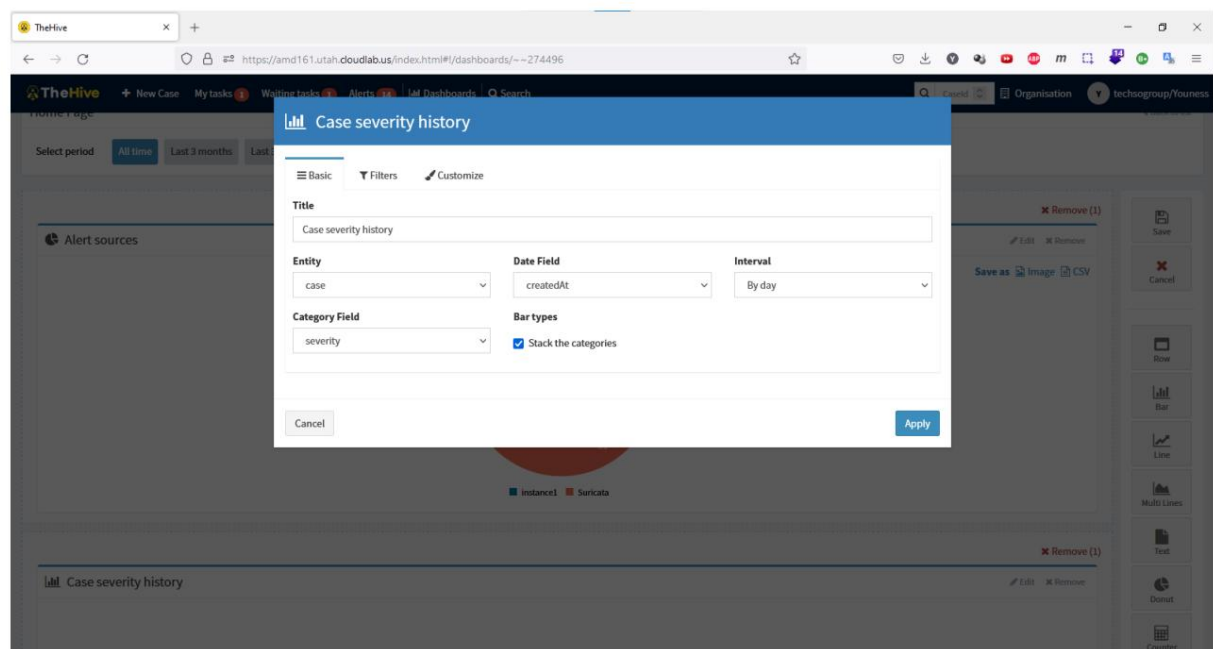


Figure 69 : Créer un nouveau tableau de bord (6)

La personnalisation consiste à définir vos couleurs et étiquettes appropriées pour les niveaux de gravité mentionnés.

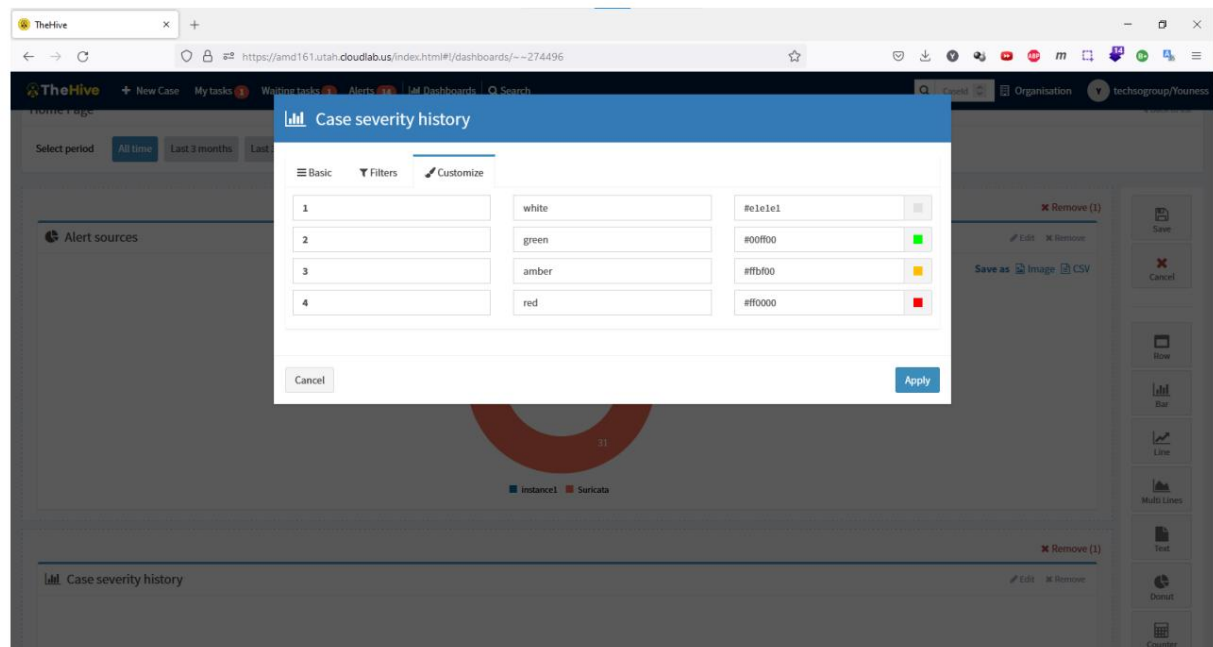


Figure 70 : Créer un nouveau tableau de bord (7)

Après avoir rempli les informations requises et appuyé sur Appliquer, le résultat devrait ressembler à ce qui suit.

Orchestration, automatisation et réponse de la sécurité

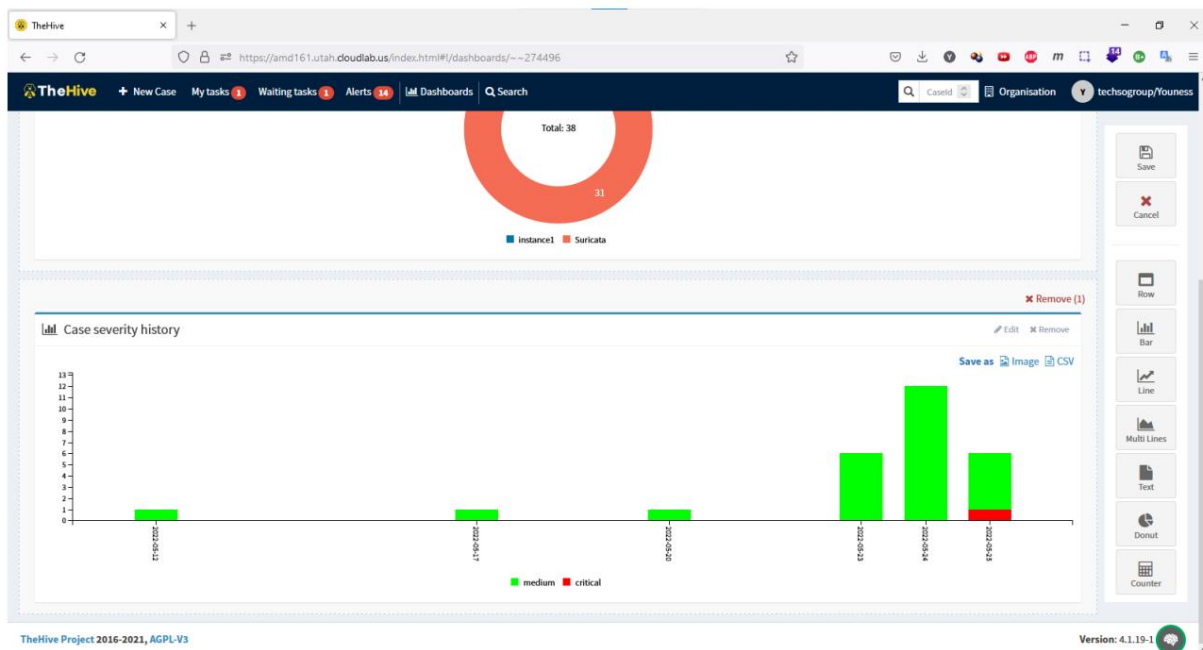


Figure 71 : Créer un nouveau tableau de bord (8)

Maintenant, le même processus doit être suivi jusqu'à ce que vous répondiez à tous vos besoins en matière de tableau de bord. Cela dépend des informations que vous souhaitez visualiser.

N'oubliez pas de sauvegarder vos modifications après chaque étape sinon elles pourraient être perdues.

Définir le proxy inverse pour Cortex

```
fichier_mot_de_passe_ssl /etc/ssl/pass/phrase.pass ; serveur {
    écouter 443 ssl; # le port sur lequel votre instance écoute nom_serveur
    apt032.apt.emulab.net ;

    certificat_ssl /etc/ssl/certs/cortex-cert.pem ; /etc/ssl/private/
    clé_certificat_ssl cortex-privateKey.pem ;

    proxy_connect_timeout 600 ;
    proxy_send_timeout 600 ;
    proxy_read_timeout 600 ; send_timeout 600 ;
    client_max_body_size 20M;

    proxy_buffering désactivé ;
    client_header_buffer_size 8k ;

    location /
    { add_header Strict-Transport-Security "max-age=31536000; includeSubDomains" ; proxy_pass http://
    127.0.0.1:9001/ ; # l'ip de votre instance interne proxy_http_version 1.1 ; proxy_set_header Connexion "" ; }

    }

serveur
{ écouter 80 default_server ; écouter
  [::]:80 default_server ; nom du serveur _ ;
  renvoie 301 https://$host$request_uri ;
}
```

Figure 72 : apt032.apt.emulab.net.conf

Orchestration, automatisation et réponse de la sécurité

```

GNU nano 2.3.1 File: /etc/nginx/conf.d/apt032.apt.emulab.net.conf
ssl_password_file /etc/ssl/passphrase.pass;
server {
    listen 443 ssl; # the port that ur instance listen to
    server_name apt032.apt.emulab.net;

    ssl_certificate /etc/ssl/certs/cortex-cert.pem;
    ssl_certificate_key /etc/ssl/private/cortex-privateKey.pem;

    proxy_connect_timeout 600;
    proxy_send_timeout 600;
    proxy_read_timeout 600;
    send_timeout 600;
    client_max_body_size 20M;
    proxy_buffering off;
    client_header_buffer_size 8k;

    location / {
        add_header Strict-Transport-Security "max-age=31536000; includeSubDomains";
        proxy_pass https://172.0.0.1:9901; # the ip of ur internal instance
        proxy_http_version 1.1;
        proxy_set_header Connection "";
    }
}

server {
    listen 80 default_server;
    listen [::]:80 default_server;
    server_name _;
    return 301 https://$host$request_uri;
}

```

Figure 73 : Fichier de configuration du proxy inverse

1. Le chemin vers la phrase secrète pour ouvrir la clé privée
2. La configuration et le mappage https
3. La redirection forcée de http vers https pour sécuriser toutes les connexions

applications.conf Analyseurs et répondeurs

```

GNU nano 2.3.1 File: /etc/cortex/application.conf Modified
# url can be point to:
# - directory where analyzers are installed
# - json file containing the list of analyzer descriptions
urls = [
    # "https://download.thehive-project.org/analyzers.json"
    "/opt/Cortex-Analyzers/analyzers"
]

# Same defaults. Do not change unless you know what you are doing.
fork-join-executor {
    # Min number of threads available for analysis.
    parallelism-min = 2
    # Parallelism (threads) ... cell(available processors * factor).
    parallelism-factor = 2.0
    # Max number of threads available for analysis.
    parallelism-max = 4
}

# RESPONDERS
#
responder {
    # responder location (same format as analyzer urls)
    urls = [
        # "https://download.thehive-project.org/responders.json"
        "/opt/Cortex-Analyzers/responders"
    ]

    # Same defaults. Do not change unless you know what you are doing.
    fork-join-executor {
        # Min number of threads available for analysis.
        parallelism-min = 2
        # Parallelism (threads) ... cell(available processors * factor).
        parallelism-factor = 2.0
        # Max number of threads available for analysis.
        parallelism-max = 4
    }
}

# Proxy configuration to retrieve catalogs
# play.ws.proxy {
#     host = proxy.example.com
# }

```

Figure 74 : Configuration des analyseurs et des répondeurs

Scénario (Analyse d'une adresse IP)

Activons un analyseur et utilisons-le pour enrichir une observable.

Orchestration, automatisation et réponse de la sécurité

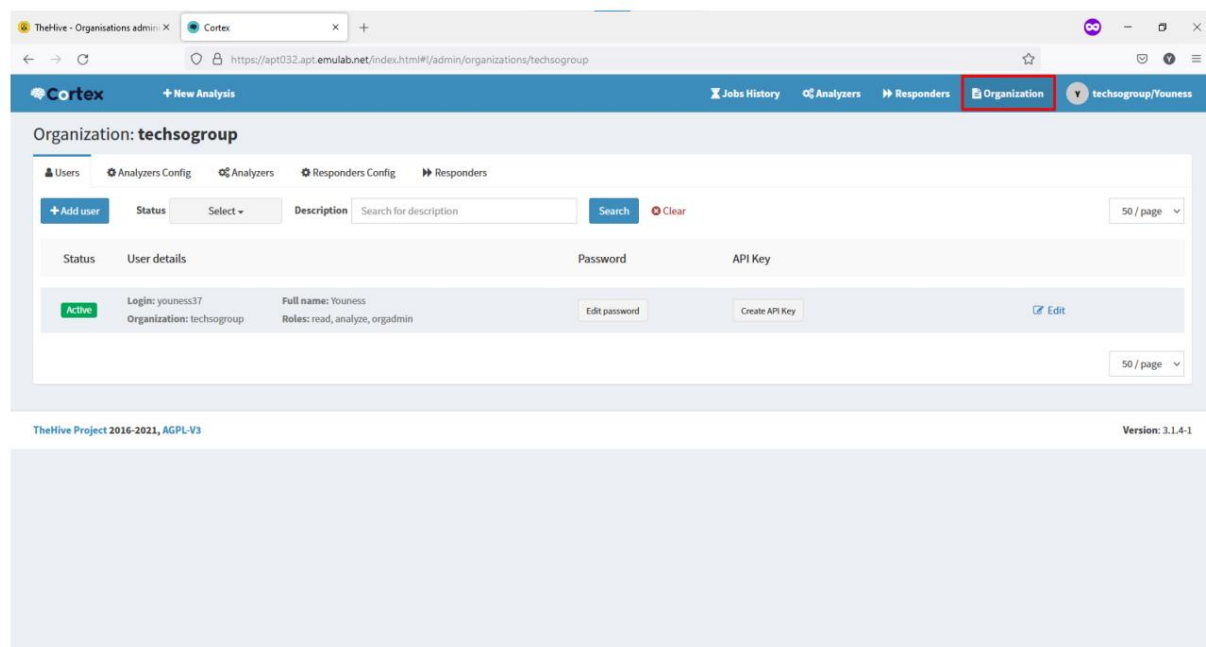


Figure 75 : Activer un analyseur (1)

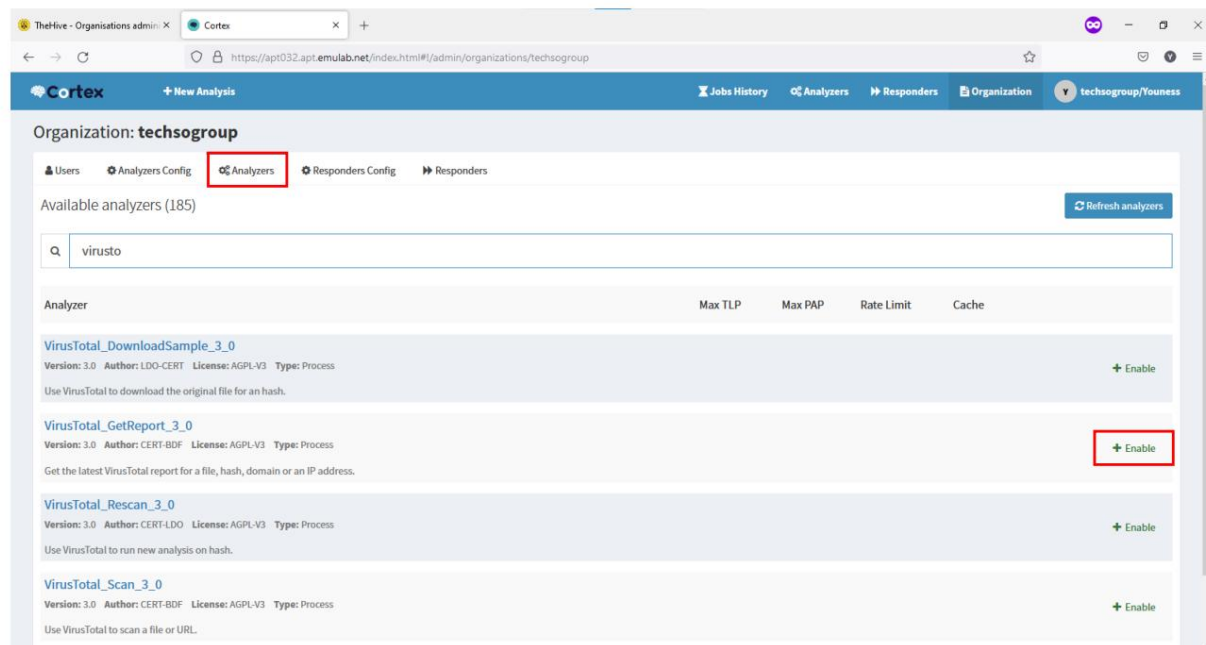


Figure 76 : Activer un analyseur (2)

Nous allons maintenant activer l'analyseur VirusTotal_GetReport_3_0 et après avoir récupéré une clé API d'un compte virustotal existant, nous l'utiliserons pour nous authentifier auprès du service virustotal.

Orchestration, automatisation et réponse de la sécurité

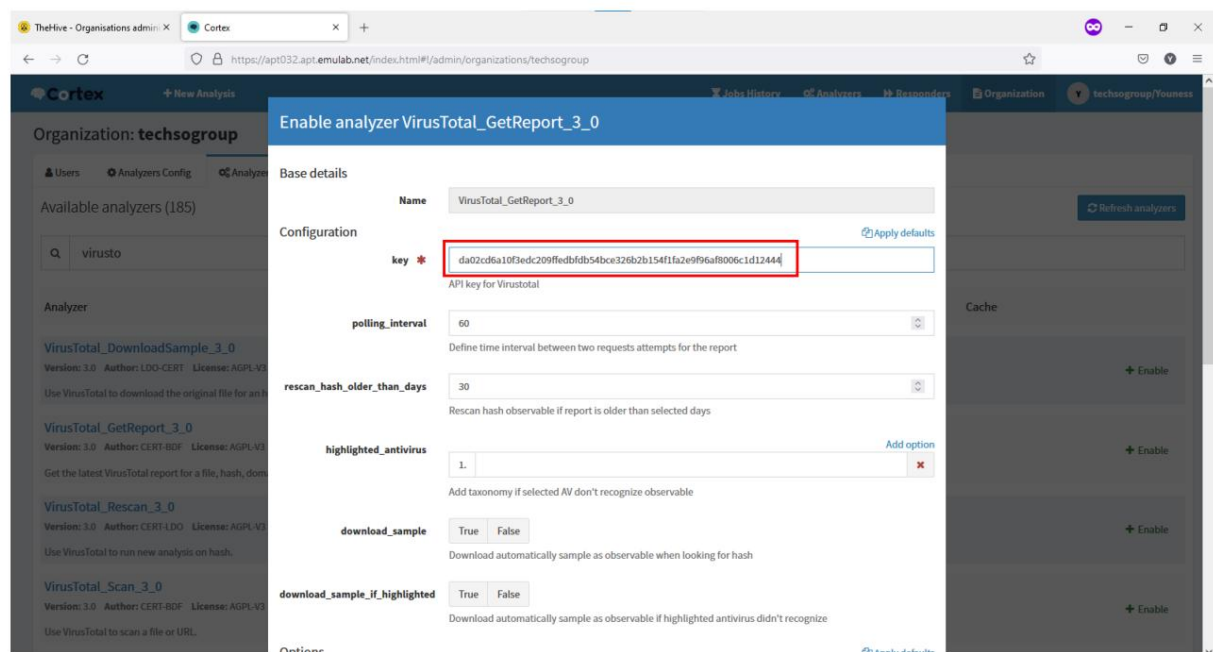


Figure 77 : Activer un analyseur (3)

Vous pouvez définir les autres configurations pour correspondre à vos besoins. Pour l'instant, nous nous en tiendrons aux bases.

Entrez votre clé API, faites défiler vers le bas et appuyez sur Enregistrer.

Créons une nouvelle analyse pour voir si notre analyseur fonctionne correctement.

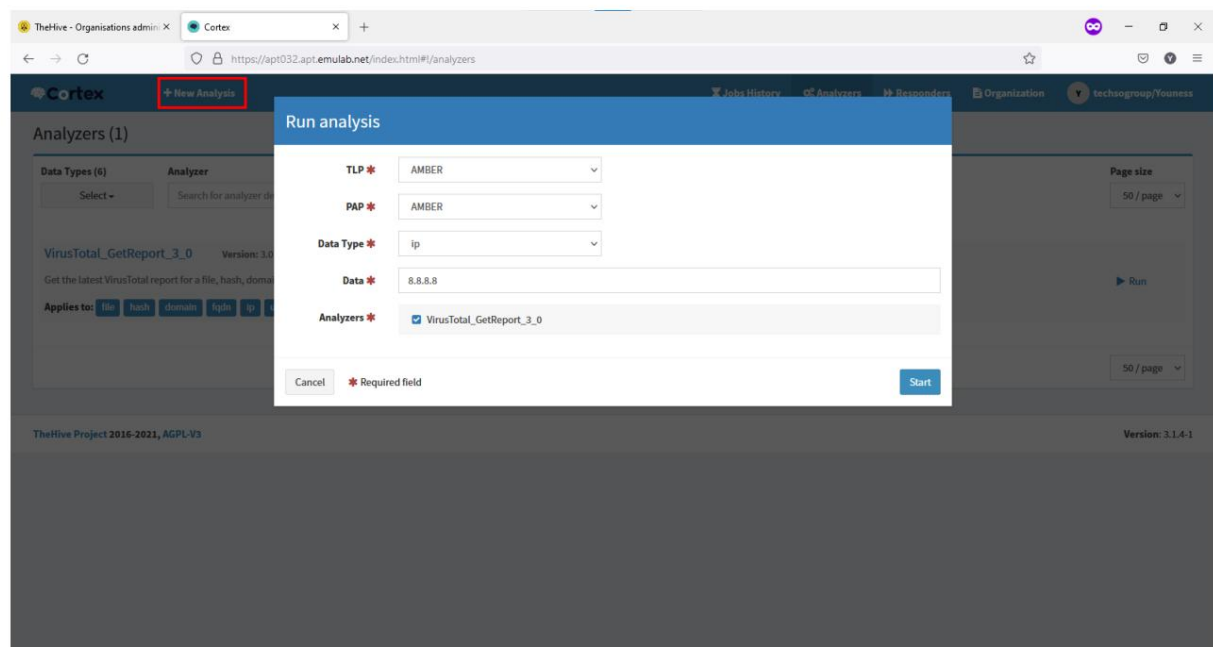


Figure 78 : Analyser une adresse IP (1)

Après avoir rempli les champs requis, appuyez sur Démarrer.

Orchestration, automatisation et réponse de la sécurité

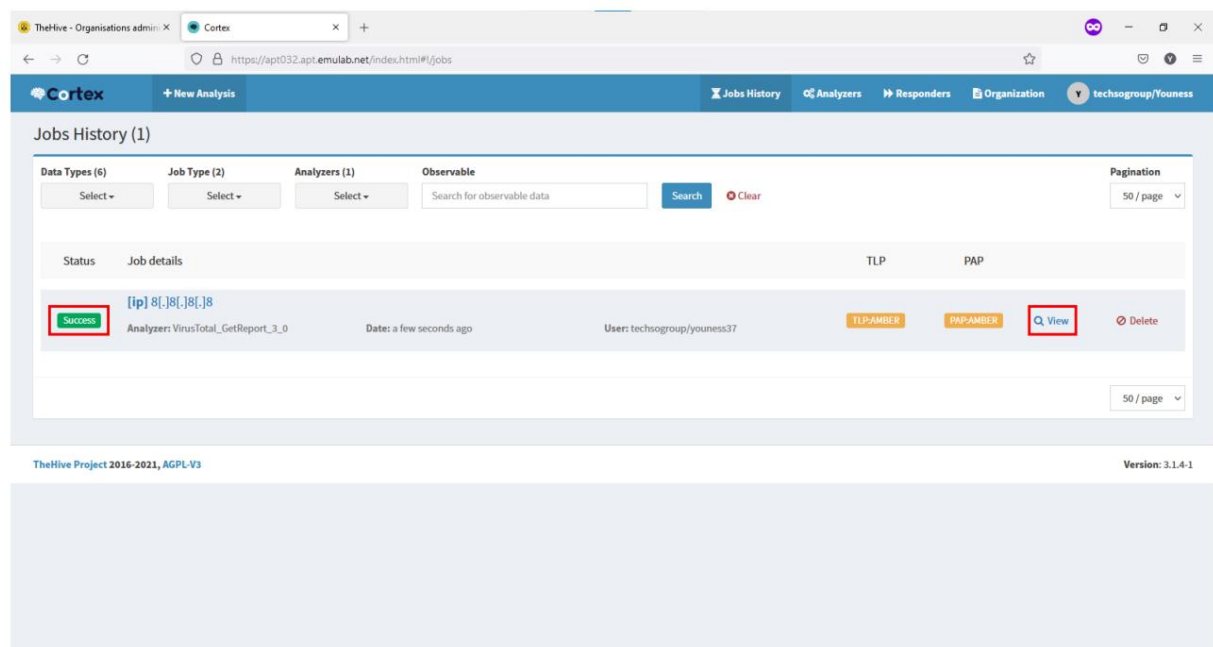


Figure 79 : Analyser une adresse IP (2)

Nous voyons l'état de réussite de notre travail dans la capture d'écran ci-dessus, si nous voulons voir les détails de l'analyse, nous pouvons cliquer sur le bouton Afficher .

3. Intégration de TheHive et Cortex

Créer un utilisateur d'API dans Cortex

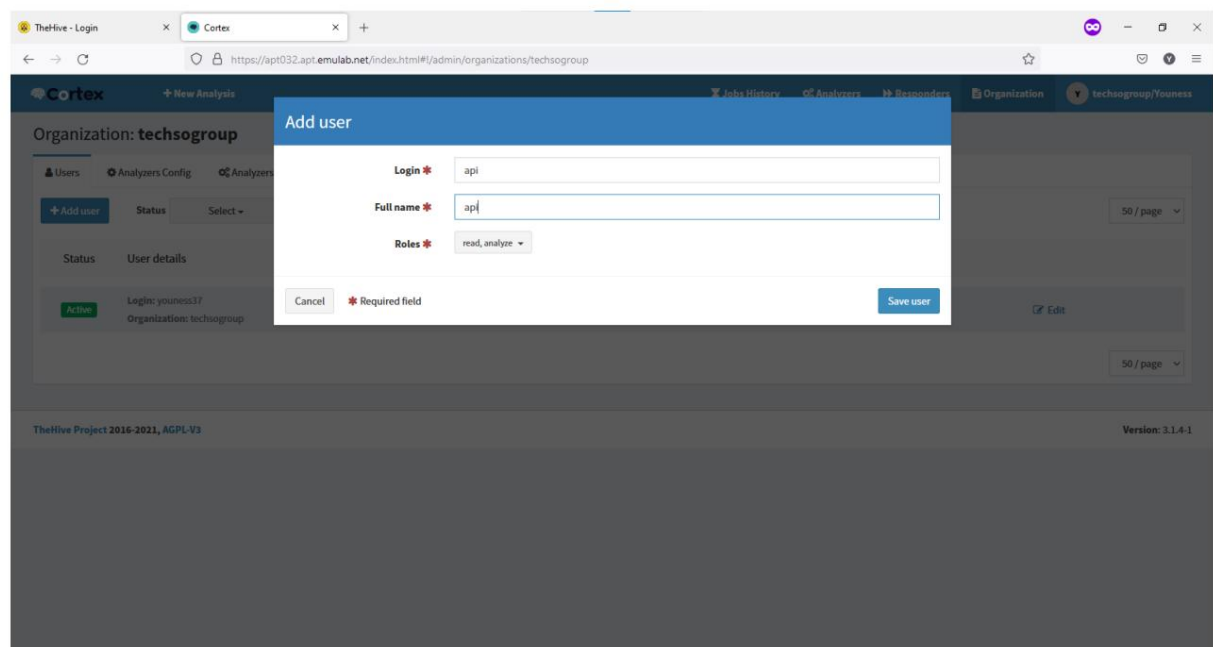


Figure 80 : Créer un utilisateur Cortex à intégrer à TheHive (1)

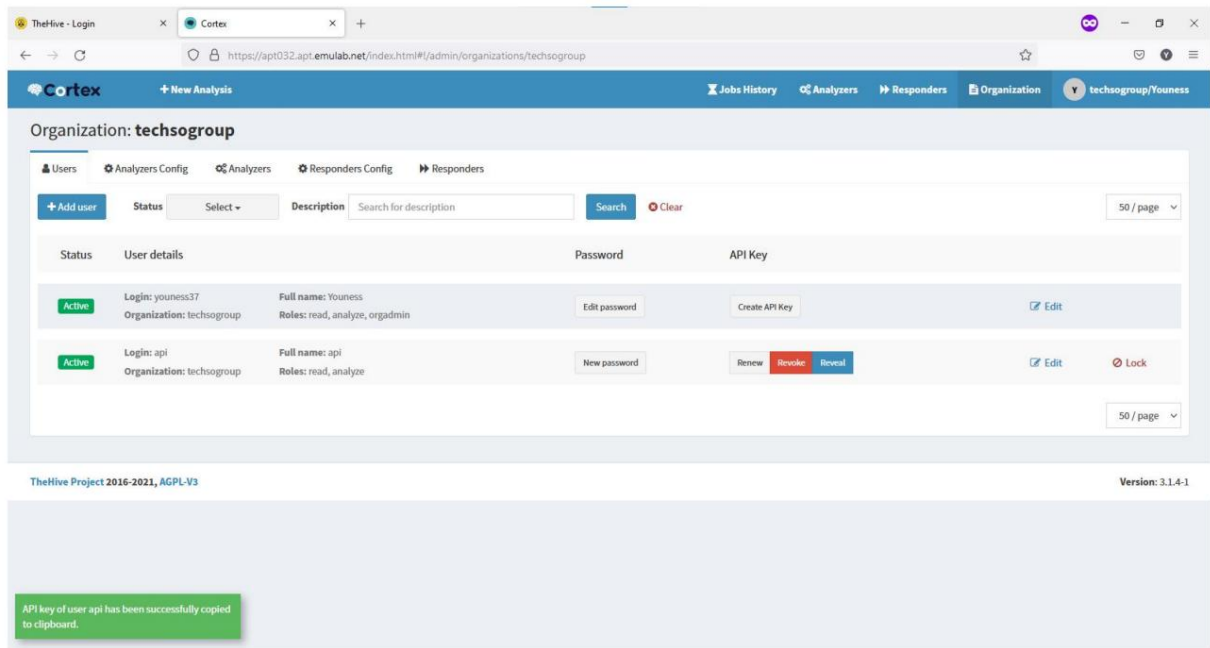


Figure 81 : Créer un utilisateur Cortex à intégrer à TheHive (2)

Créer une paire de clés SSH

Création de clés ssh :

```
ssh-keygen -t rsa -b 4096
```

Et pour le fichier Enter dans lequel enregistrer la clé (/root/.ssh/id_rsa) : remplissez avec cortex.

Vous trouverez les clés dans le chemin ~/.ssh/ .

```
cd ~/.ssh/
```

Remarque :

Pas besoin de la phrase secrète pour faciliter les choses si nous voulons créer un service système pour maintenir la connexion ssh.

Après avoir copié cortex.pub de l'instance hive vers l'instance cortex, effectuez les modifications suivantes :

ajoutons « cortex.pub » au fichier des clés autorisées.

```
cat ~/.ssh/cortex.pub >> ~/.ssh/authorized_keys
```

Nous devons spécifier les autorisations pour le dossier ~/.ssh et ses composants.

```
chmod 700 ~/.ssh
```

```
chmod 600 ~/.ssh/*
```

Maintenant, nous devons nous connecter de l'instance TheHive à l'instance cortex comme suit.

Configuration du tunnel SSH pour Cortex

```

GNU nano 4.8 /etc/thehive/application.conf Modified
// username: thehive # file owner
// }
}

## Authentication configuration
# More information at https://github.com/TheHive-Project/TheHiveDocs/TheHive4/Administration/Authentication.md
//auth {
// providers: [
//   {name: session}
//   {name: basic, realm: thehive} # required !
//   {name: local}
//   {name: key}
// ]
# The format of logins must be valid email address format. If the provided login doesn't contain '@' the following
# domain is automatically appended
// defaultUserDomain: "thehive.local"
//}

## CORTEX configuration
# More information at https://github.com/TheHive-Project/TheHiveDocs/TheHive4/Administration/Connectors.md
# Enable cortex connector
play.modules.enabled += org.thp.thehive.connector.cortex.CortexModule
cortex {
  servers: [
    {
      name: "CORTEX" # Cortex name
      url: "http://127.0.0.1:9001/" # URL of Cortex instance
      auth {
        type: "bearer"
        key: "z5xhper07BSSykr3njg2/dNZ038z5MM" # Cortex API key
      }
      wsConfig {} # HTTP client configuration (SSL and proxy)
    }
  ]
}

## MISP configuration
# More information at https://github.com/TheHive-Project/TheHiveDocs/TheHive4/Administration/Connectors.md
# Enable MISP connector
play.modules.enabled += org.thp.thehive.connector.misp.MispModule
// misp {
// interval: 1 hour
// servers: [

```

Figure 82 : Configuration de l'intégration Cortex et TheHive

4. Installation et configuration du MISP

Options d'installation du MISP

```

-c Installer UNIQUEMENT le noyau MISP
-M Modules MISP
-m Messagerie 2 MISP
-S Corrélations profondes expérimentales
-A Installer tout ce qui précède
-C Effectue uniquement les vérifications de pré-installation et quitte -u
Effectue une installation sans assistance, sans poser de questions
-U Tentative de mise à niveau de l'élément sélectionné
-N Nuke cette instance MISP
-f Forcer l'installation du test sur Ubuntu LTS actuel

Les options peuvent être combinées : /tmp/INSTALL.sh -c -D # Installera Core + Dashboard

```

Image 83 : Options d'installation du MISP

Première connexion MISP et changement de mot de passe

Orchestration, automatisation et réponse de la sécurité

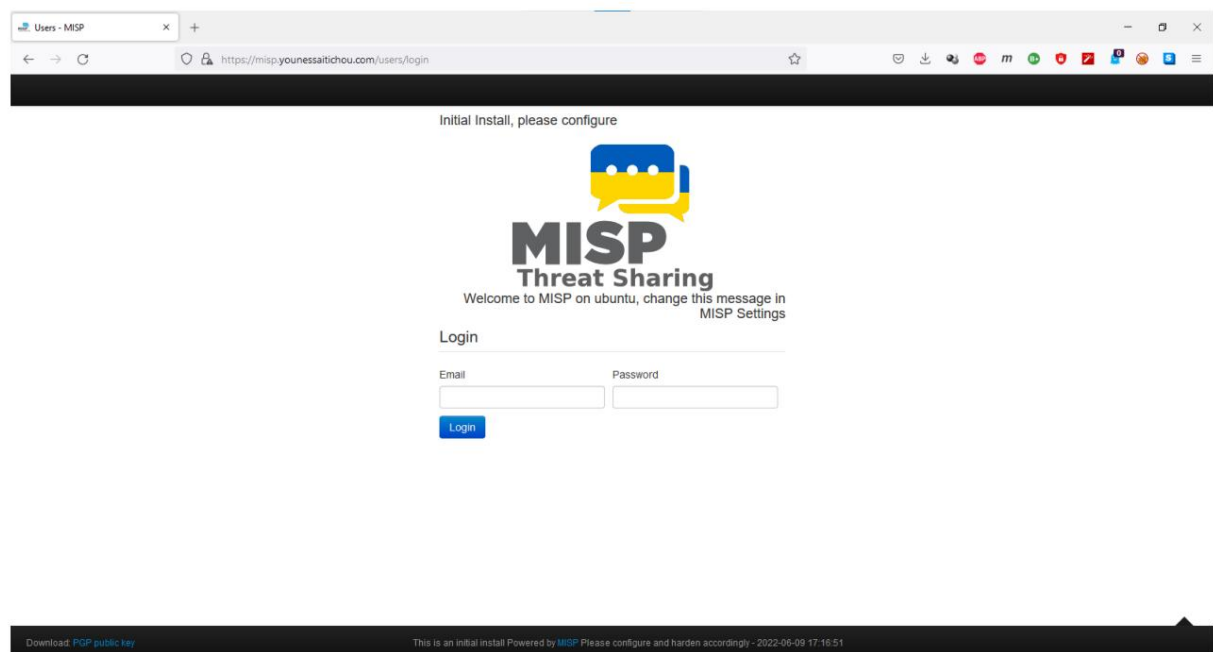


Figure 84 : Page de connexion MISP

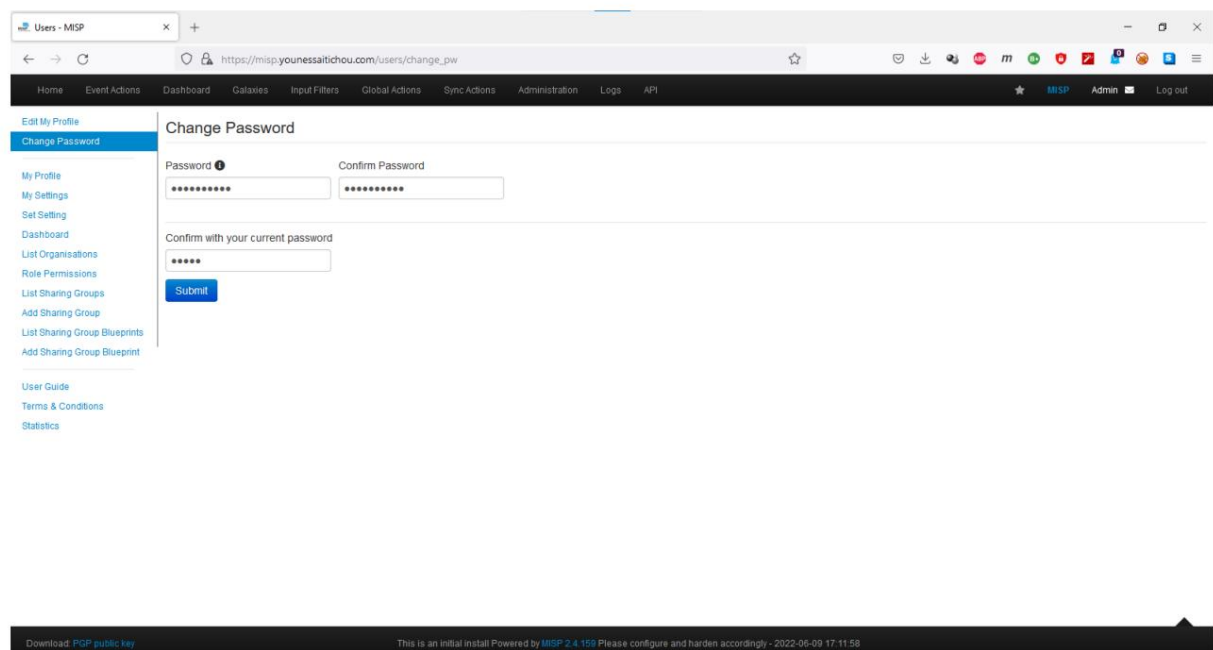


Figure 85 : MISP modifier le mot de passe

MISP ajouter des flux

Orchestration, automatisation et réponse de la sécurité

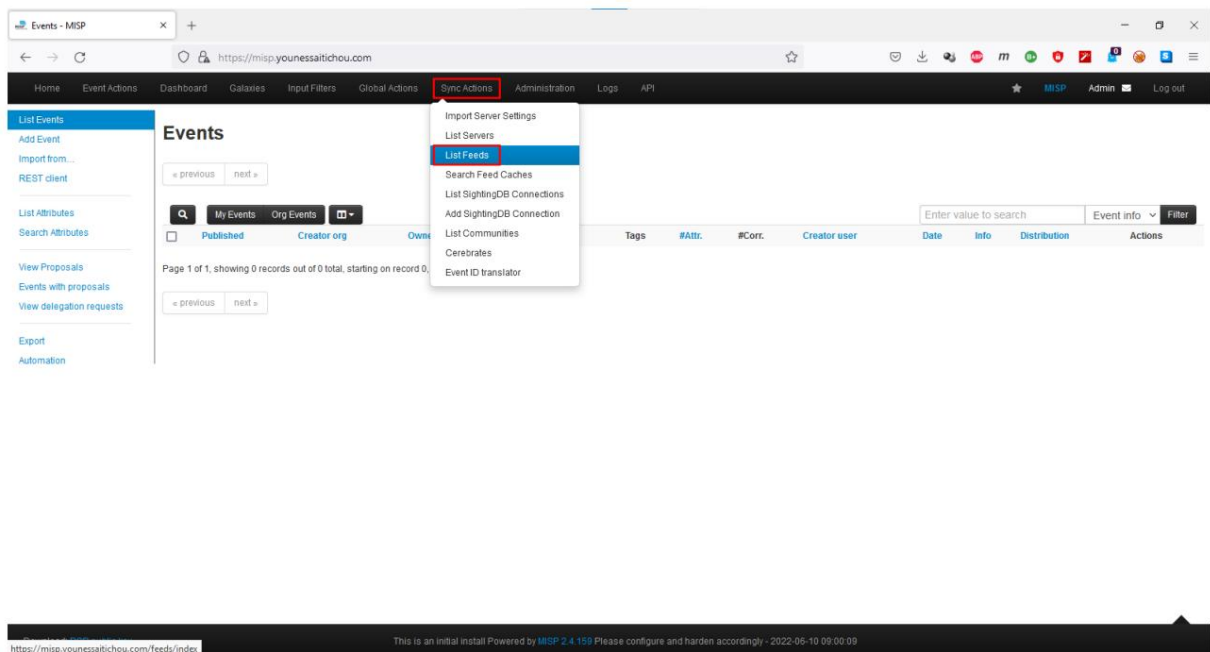


Figure 86 : MISP ajouter des flux (1)

Voici les flux par défaut que nous pouvons activer et synchroniser avec, notez qu'il existe d'autres flux publics que nous pouvons utiliser.

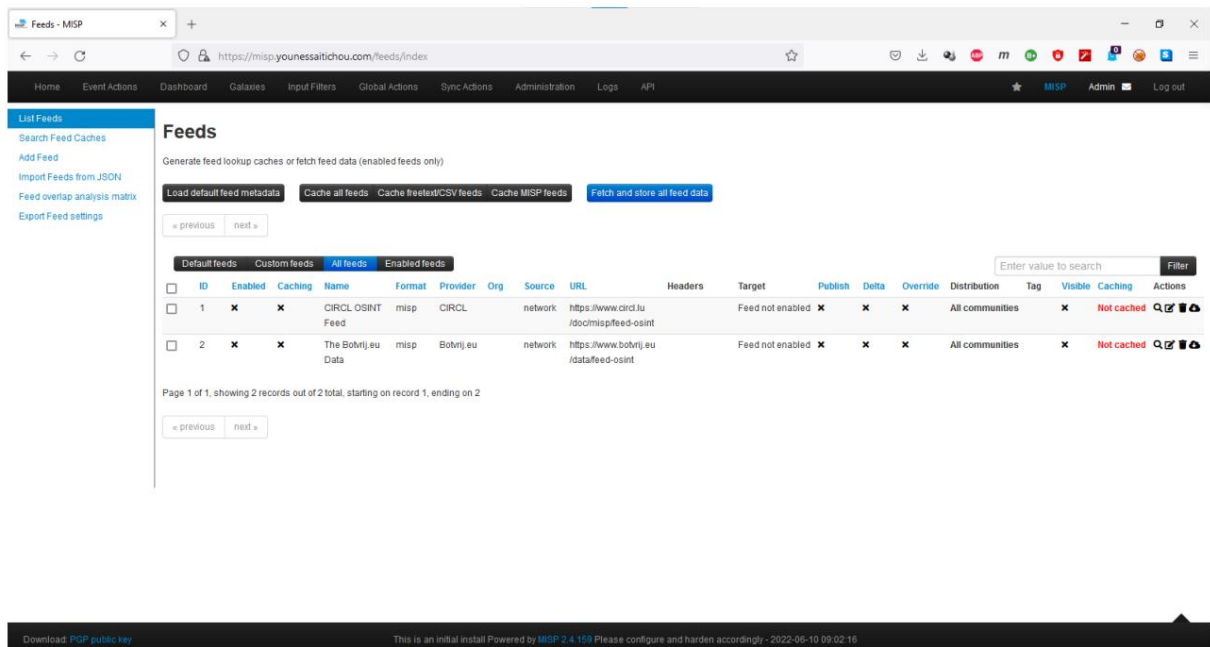


Figure 87 : MISP ajouter des flux (2)

Activons les flux.

Orchestration, automatisation et réponse de la sécurité

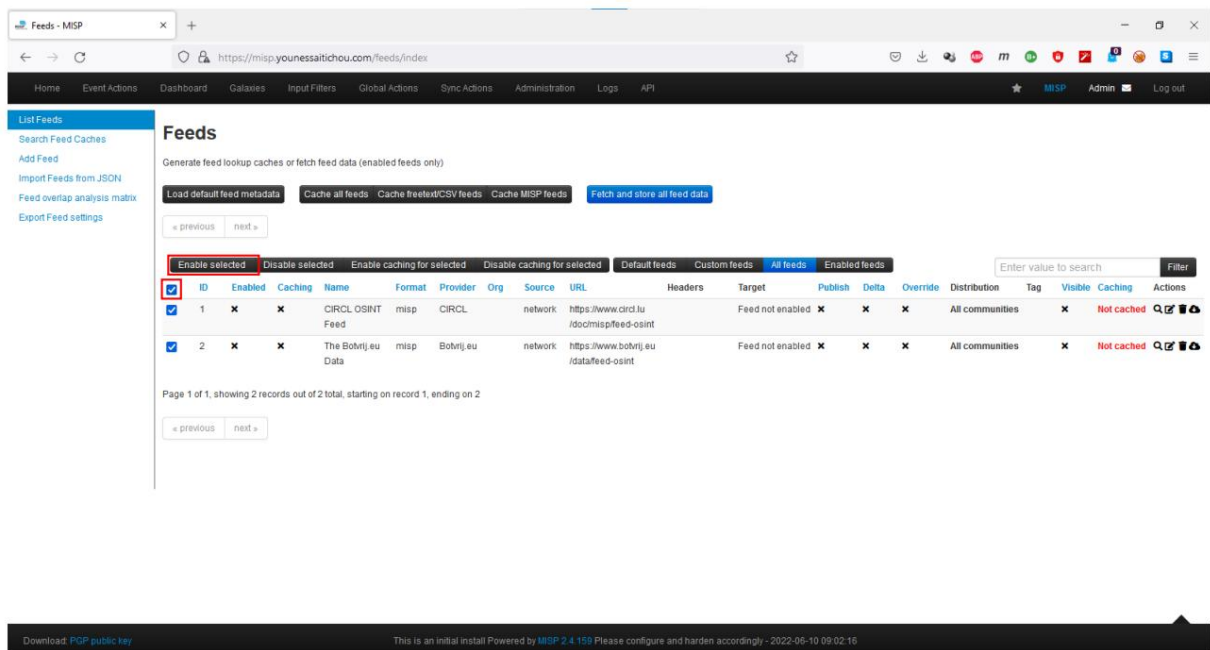


Figure 88 : MISP ajouter des flux (3)

Cliquez sur oui pour continuer.

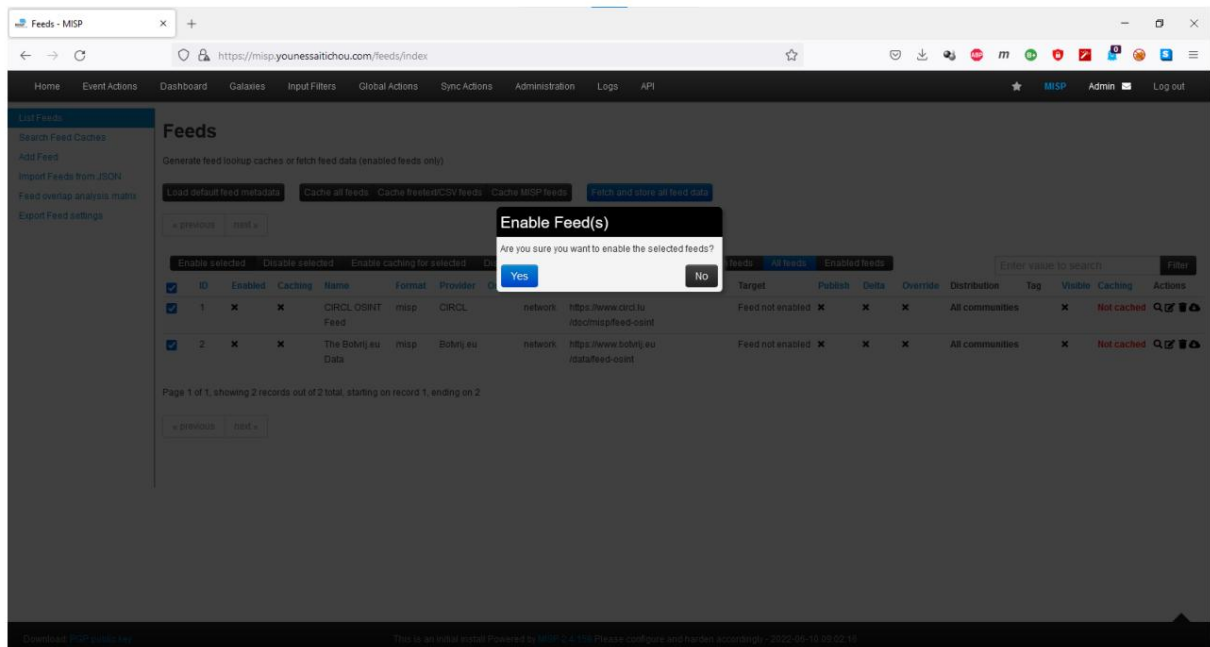


Figure 89 : MISP ajouter des flux (4)

Maintenant, récupérons et stockons toutes les données de flux.

Orchestration, automatisation et réponse de la sécurité

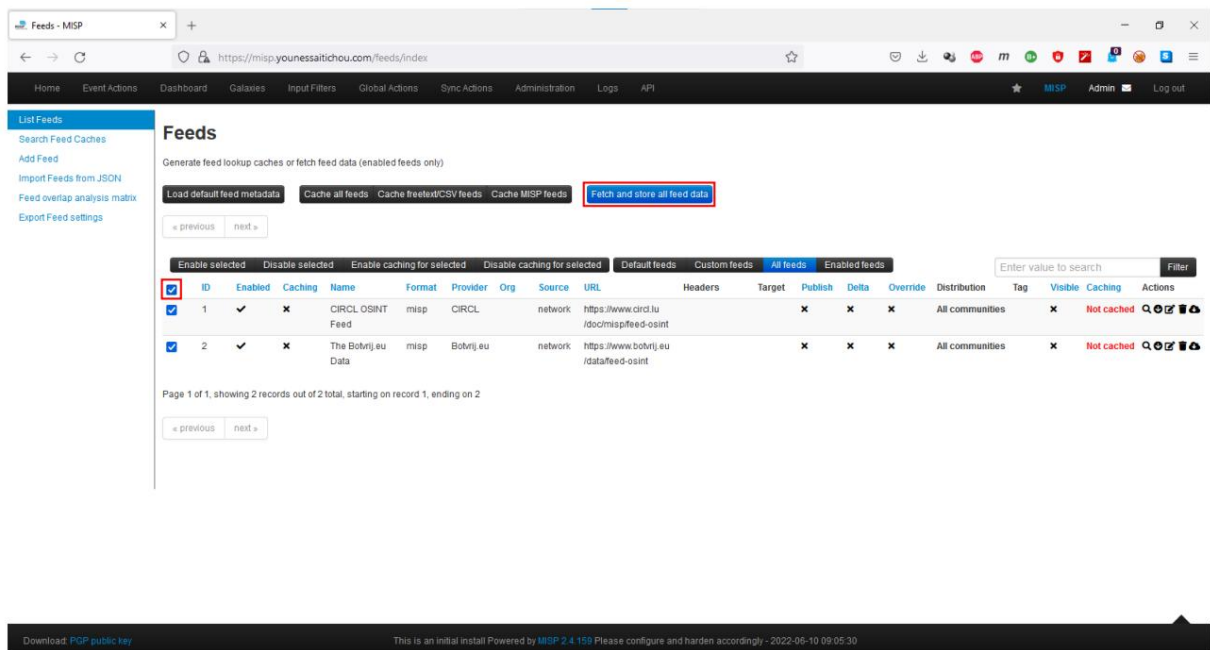


Figure 90 : MISP ajouter des flux (5)

Pour voir l'état de notre flux, nous pouvons accéder à la section emploi.

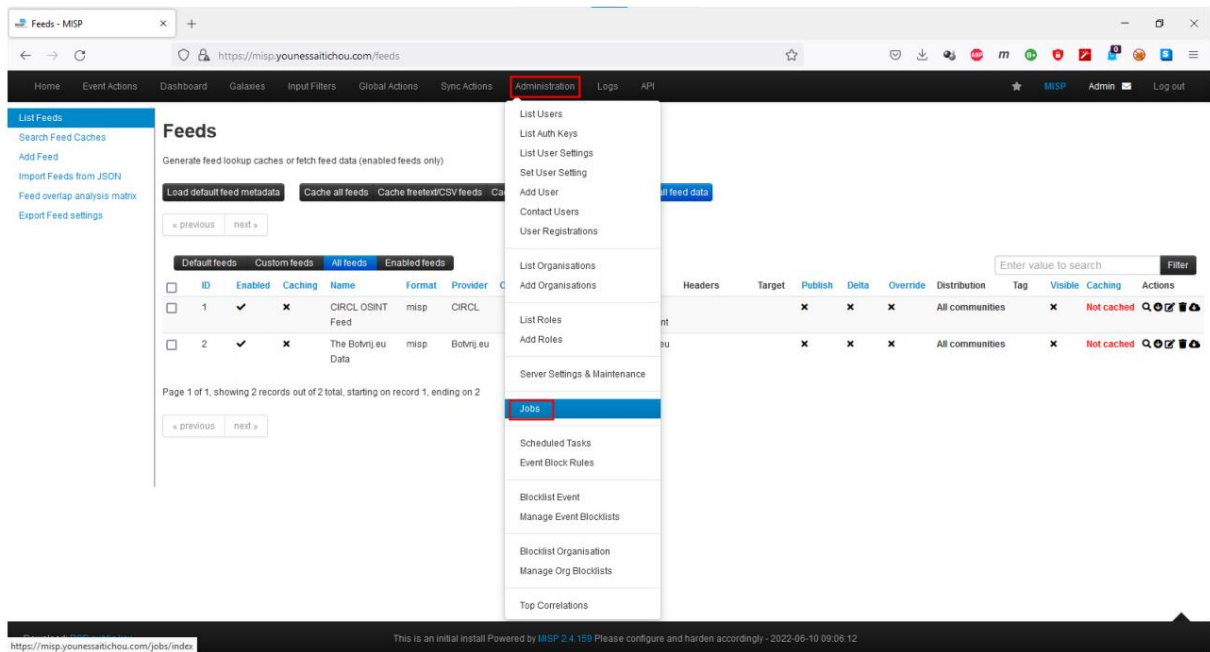


Figure 91 : MISP ajouter des flux (6)

Le téléchargement des flux prendra un certain temps, alors soyez patient.

Après le téléchargement, vous devriez voir les informations ci-dessous.

Orchestration, automatisation et réponse de la sécurité

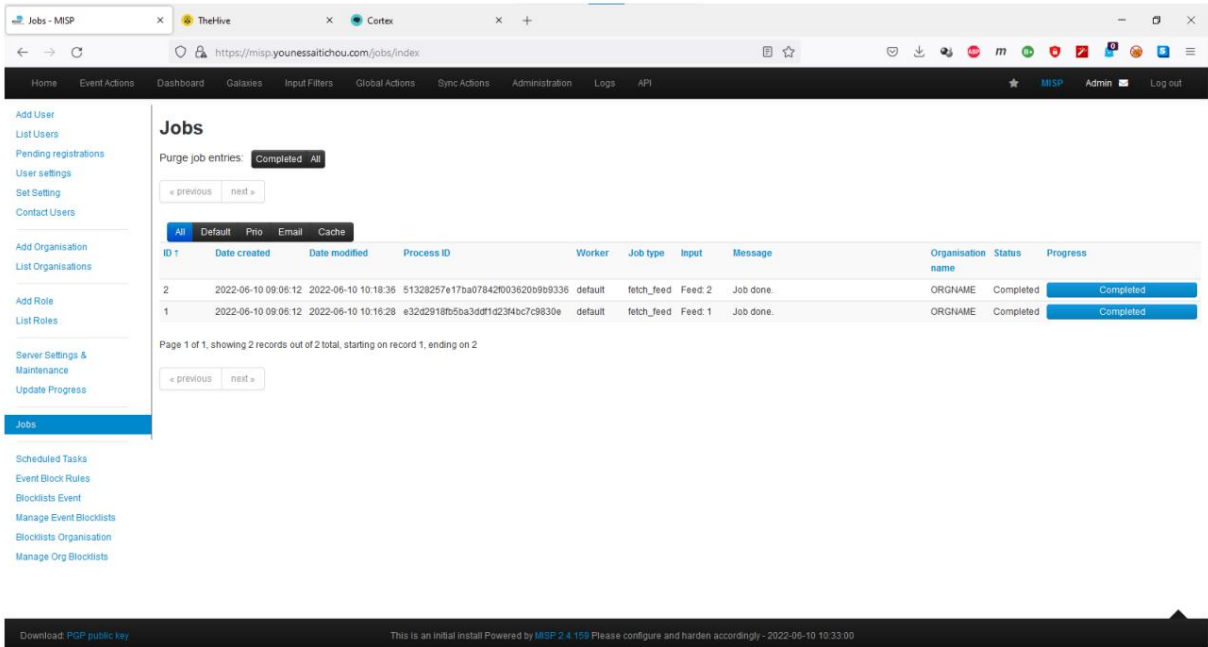


Figure 92 : MISP ajouter des flux (7)

Maintenant, si nous naviguons vers la page d'accueil, nous pouvons trouver nos événements prêts à l'emploi.

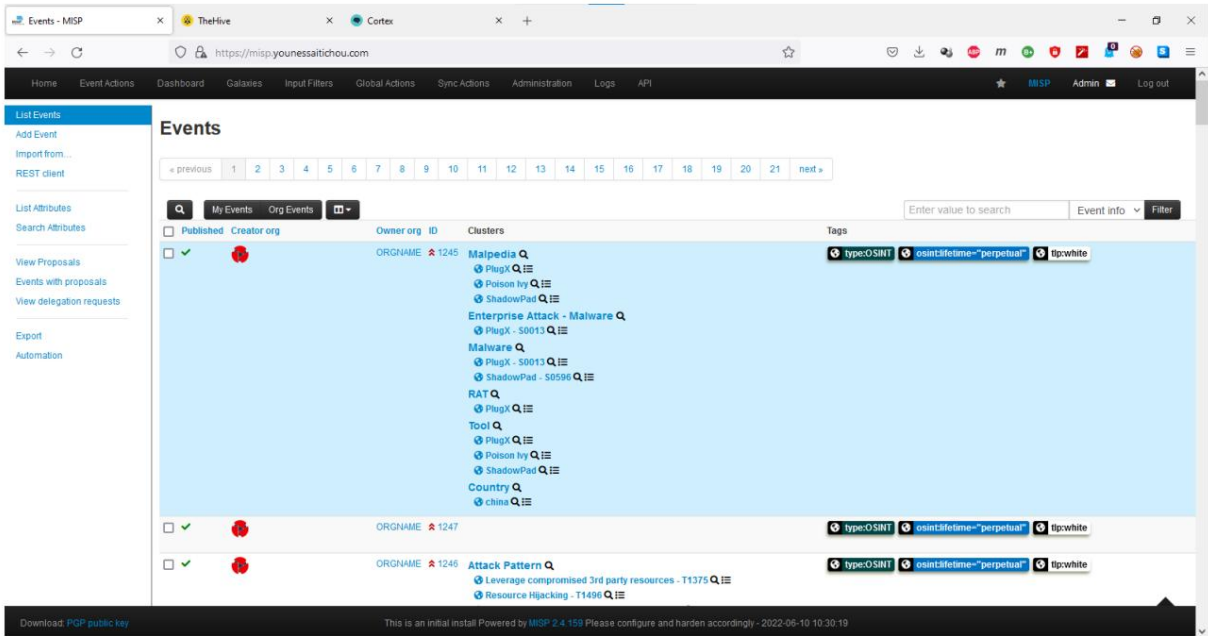


Figure 93 : MISP ajouter des flux (8)

5. Intégration de TheHive et MISP

Créer une clé API MISP

Orchestration, automatisation et réponse de la sécurité

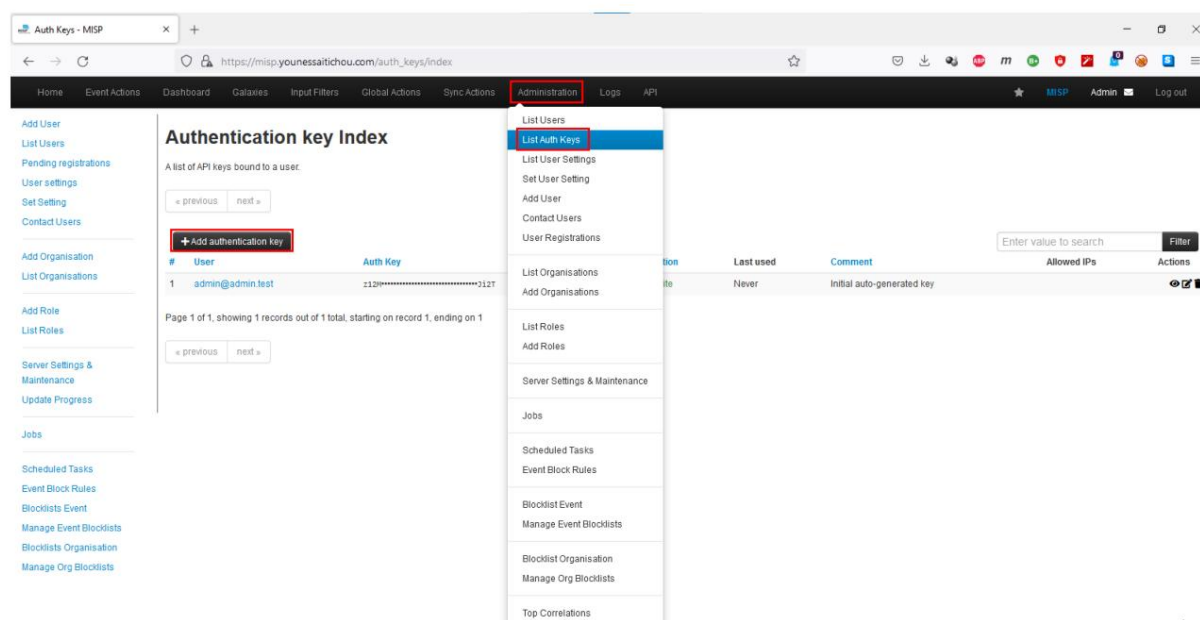


Figure 94 : Clé API MISP (1)

Et ici, vous n'aurez qu'à remplir les blancs :

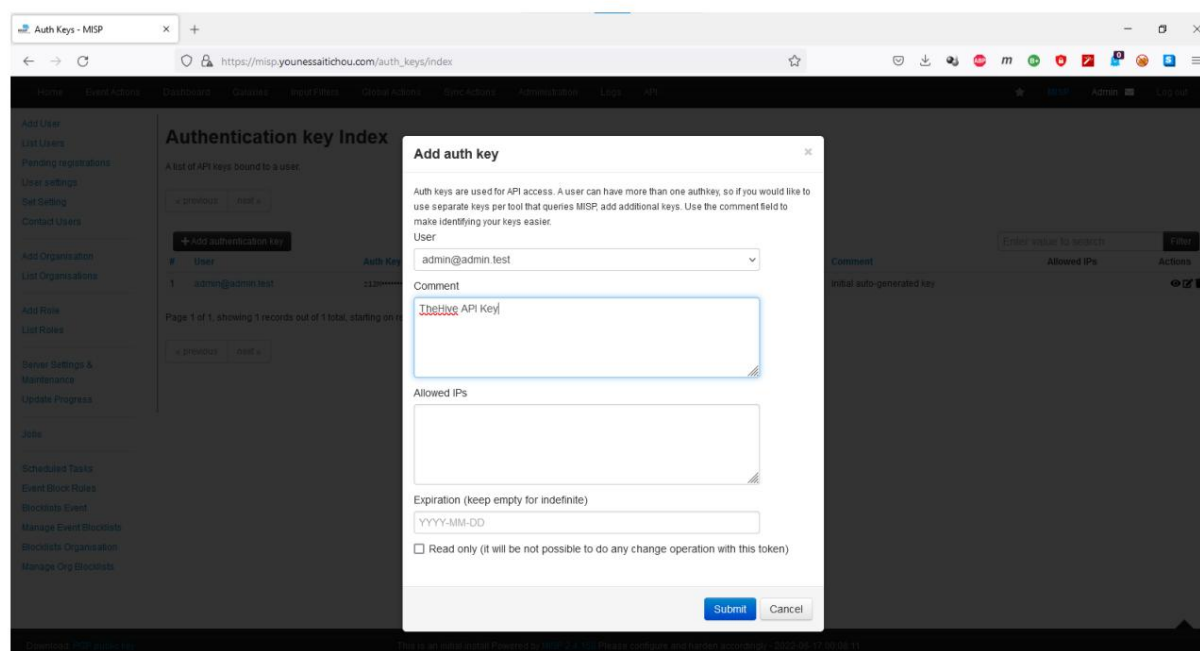


Figure 95 : Clé API MISP (2)

Remarque :

Pour plus de sécurité, vous pouvez spécifier les adresses éligibles pouvant accéder à l'instance MISP dans les adresses IP autorisées, et vous pouvez également spécifier une date d'expiration pour la clé API afin qu'elle ne puisse plus être utilisée après cela.

Ne cochez pas le bouton Radio en lecture seule car nous avons besoin de plus que d'une simple autorisation de lecture dans cette intégration.

Intégration TheHive et MISP

Orchestration, automatisation et réponse de la sécurité

```

play.modules.enabled += org.thp.thehive.connector.misp.MispModule misp { intervalle : 1m

les serveurs: [ {

    nom = "MISP"                                # URL du nom
    MISP = "https://misp.younessaitichou.com/" # URL ou authentification MISP { type = clé clé =
    "QOtwL0v9IHaWys3Gm5sqDQ5UE40edqCkf32iAQ"

                                                    # API MISP

    clé

    } wsConfig {}                                # Configuration du client HTTP (SSL et proxy)
    wsConfig.ssl.loose.acceptAnyCertificate : vrai
    }

}

```

Illustration 96 : configuration MISP application.conf

Nous avons ajouté le nom de l'instance MISP, l'URL de l'instance MISP et la méthode d'authentification qui est la clé API que nous avons générée avec MISP.

En fin de compte, nous avons ajouté AcceptAnyCertificate pour accepter le certificat auto-signé créé par MISP lors du processus d'installation, afin que TheHive ne s'en plaigne pas.

Sinon, nous pouvons générer le certificat comme nous l'avons fait pour le proxy hive par exemple et l'ajouter à l'instance MISP mais toujours pas fiable pour le monde entier. Pour le rendre fiable pour tout le monde sur le Web, nous pouvons utiliser un utilitaire pour créer le certificat comme let's encrypt par exemple et cela fera le travail, mais comme cette architecture sera dans le même réseau et qu'elle est privée, nous considérerons plus le deuxième choix qui consiste à créer un serveur centralisé qui les gère sur l'ensemble du réseau.

Nous devrions maintenant être prêts à partir (après avoir redémarré le service TheHive bien sûr) comme vous pouvez le voir dans l'image ci-dessous.

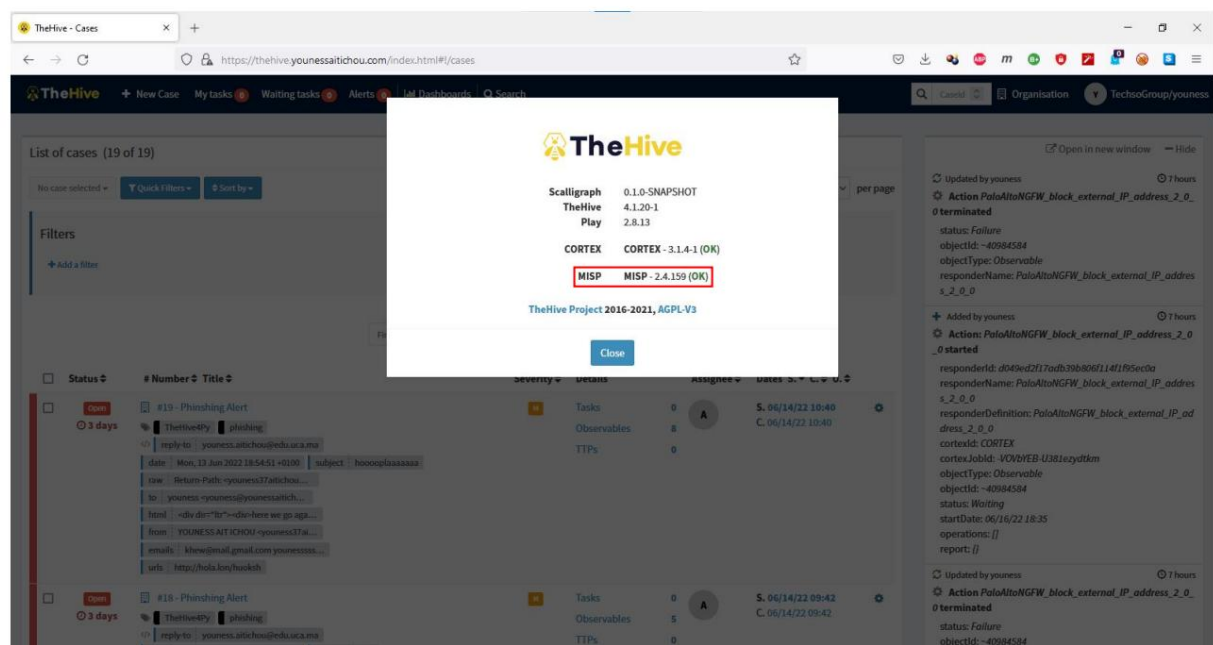


Figure 97 : Intégration TheHive et MISP

Exporter des cas de TheHive vers MISP

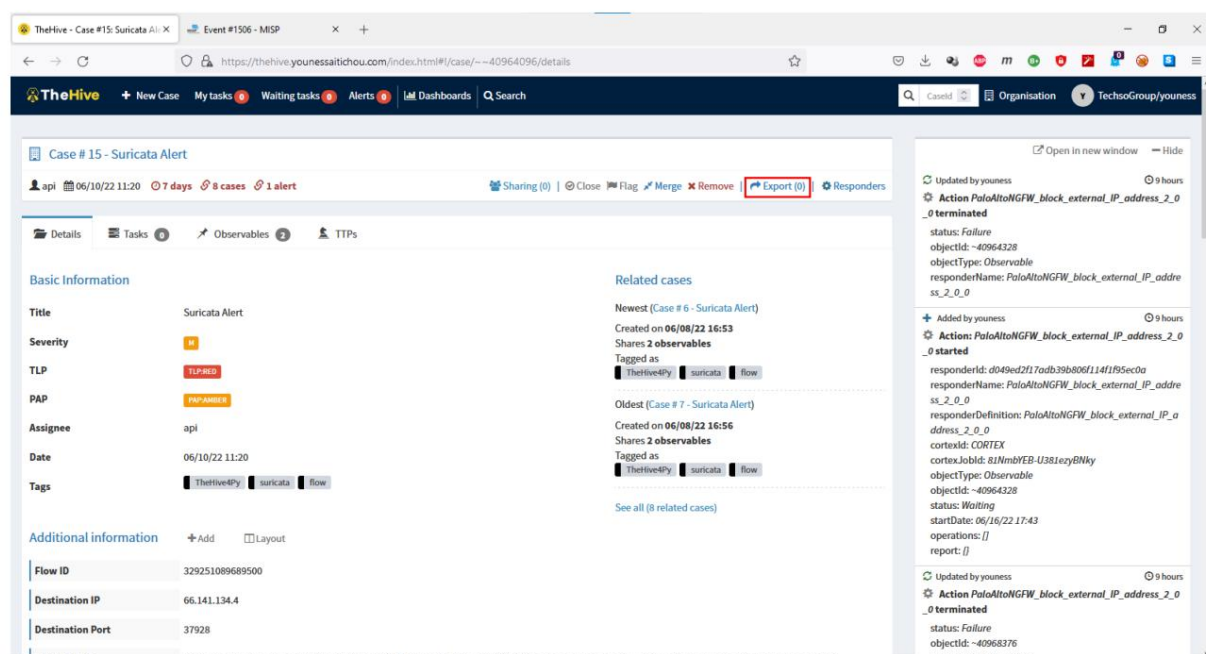


Figure 98 : Exporter le cas de TheHive vers MISP (1)

Et exportez :

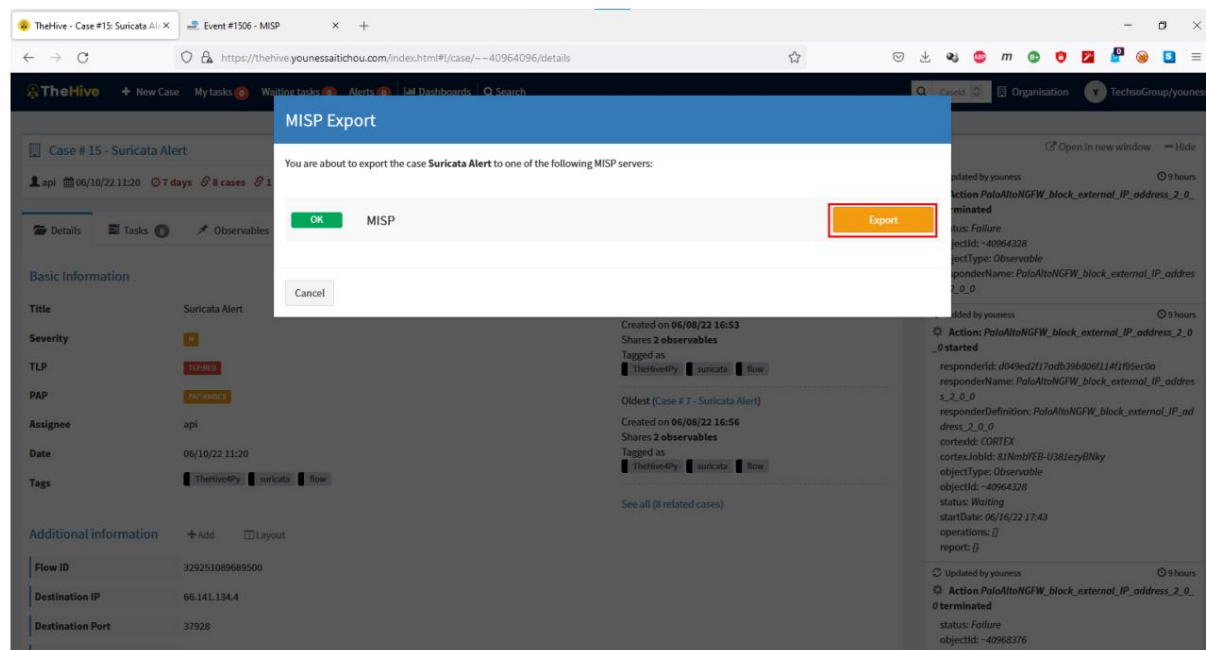


Figure 99 : Exporter le cas de TheHive vers MISP (2)

6. Gravité, TLP et PAP

- Gravité : Cela montre le niveau d'impact de l'incident faisant l'objet d'une enquête sur l'environnement, du niveau faible au niveau critique.

Orchestration, automatisation et réponse de la sécurité

- TLP : le protocole de feux de signalisation est un ensemble de désignations permettant de garantir que les informations sensibles sont partagées avec le public approprié. La gamme de couleurs représente une échelle entre la divulgation complète des informations (blanc) et aucune divulgation/restreinte (rouge).
- PAP : le protocole d'actions autorisées est utilisé pour indiquer ce qu'un analyste peut faire avec les informations, si un attaquant peut détecter l'état actuel de l'analyse ou les actions défensives en place. Il utilise un jeu de couleurs similaire à TLP et fait partie des taxonomies MISP.

7. Scénario : utilisation manuelle

Ajout de modèles MITRE ATT&CK et de taxonomies MISP

Connectez-vous au compte administrateur et importez les modèles MITRE ATT&CK en suivant les instructions suivantes :

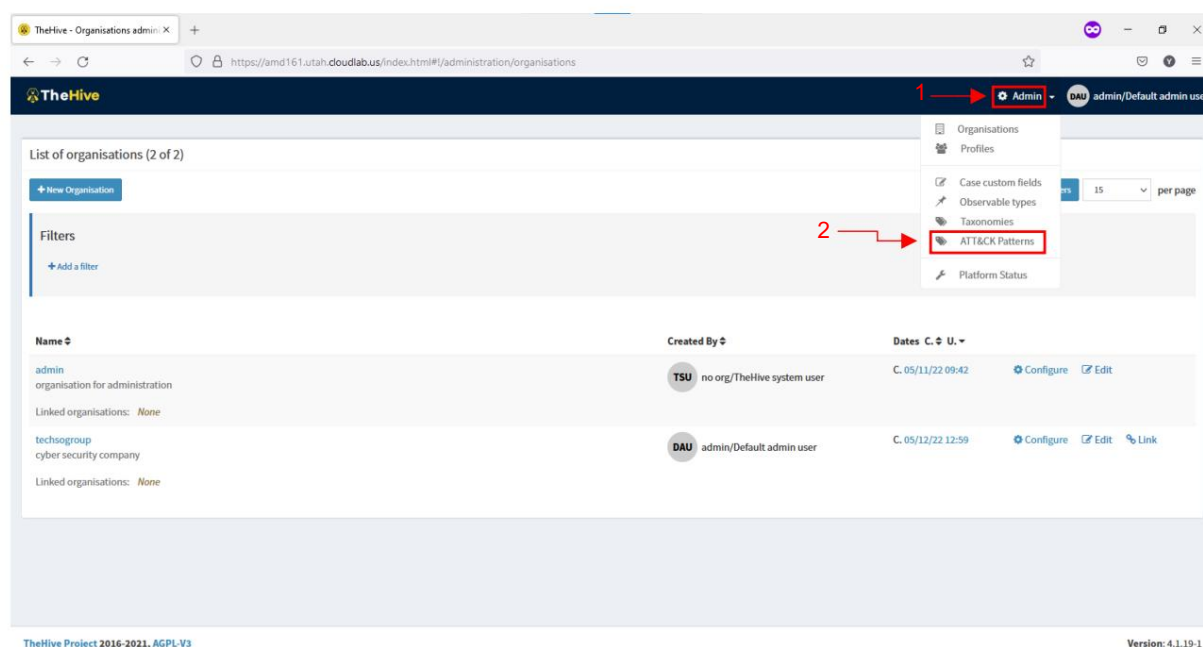


Figure 100 : Ajouter des motifs MITRE ATT&CK (1)

Lorsque vous êtes dans la page attack-patterns <Figure 102>, cliquez sur « Import MITRE ATT&CK Patterns », puis suivez le lien « from here » et téléchargez ou copiez ce fichier json <Figure 101>. Après cela, déposez le fichier et cliquez sur "Oui, importez-le". Le téléchargement va prendre un certain temps, et après cela, vous verrez la page suivante.

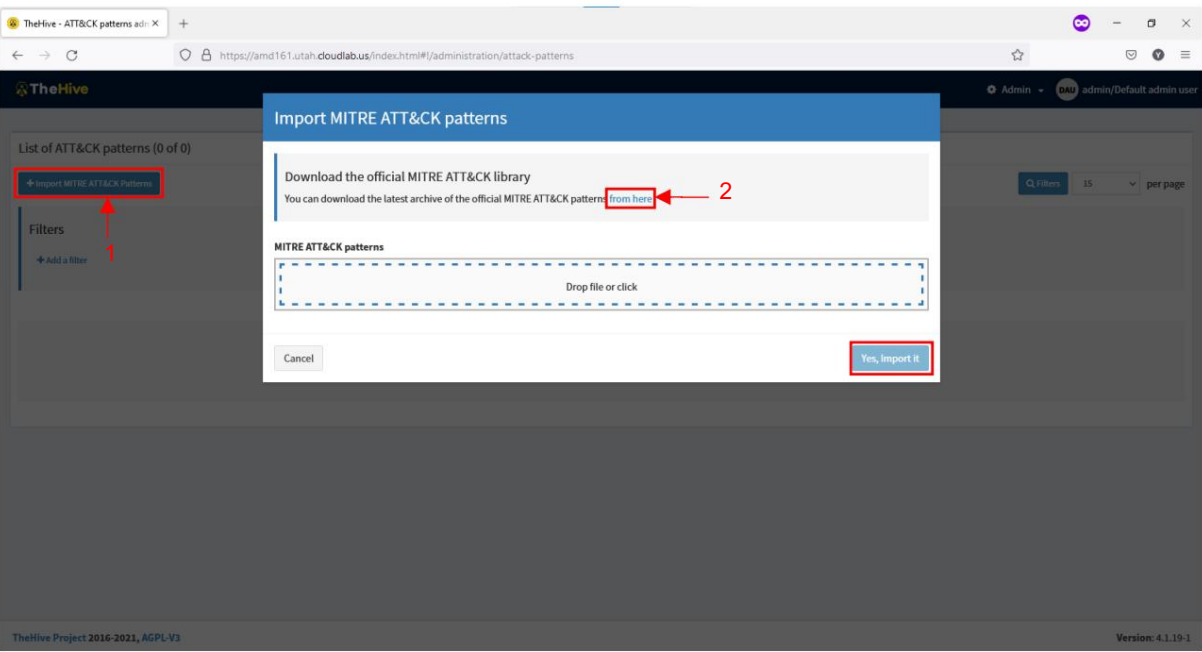


Figure 101 : Ajouter des motifs MITRE ATT&CK (2)

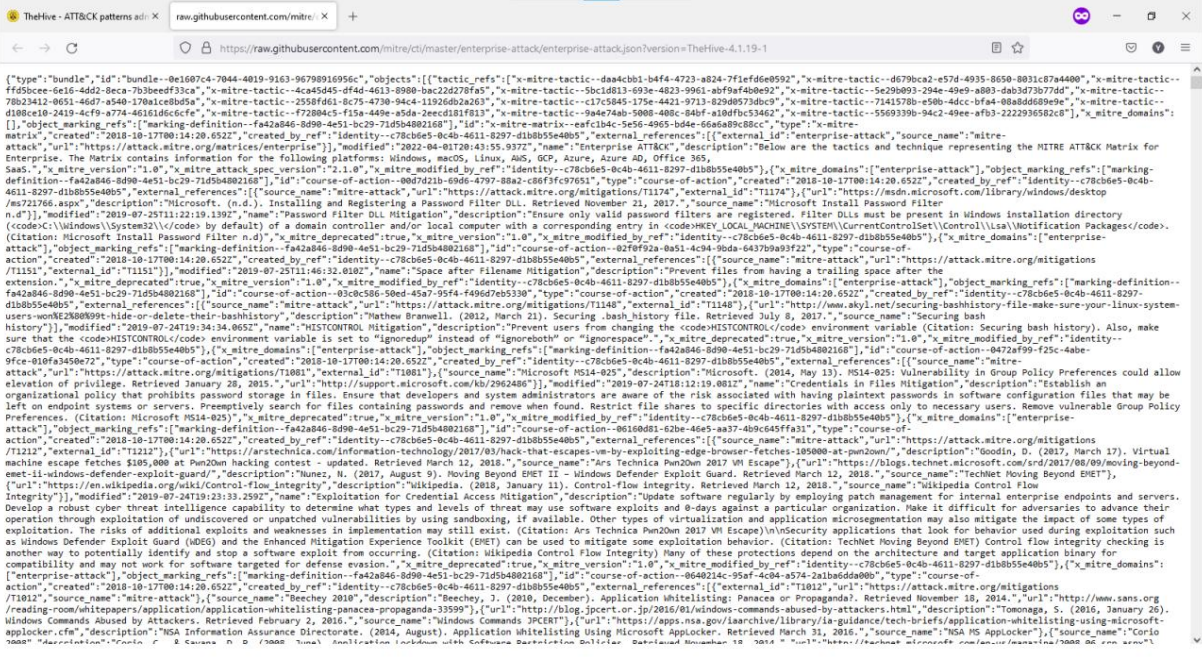


Figure 102 : Données des modèles MITRE ATT&CK

Remarque : (Extra)

Nous pouvons ajouter les taxonomies MISP <Figure 103> qui sont en quelque sorte une autre forme pour formuler le fonctionnement de l'attaque.

Orchestration, automatisation et réponse de la sécurité

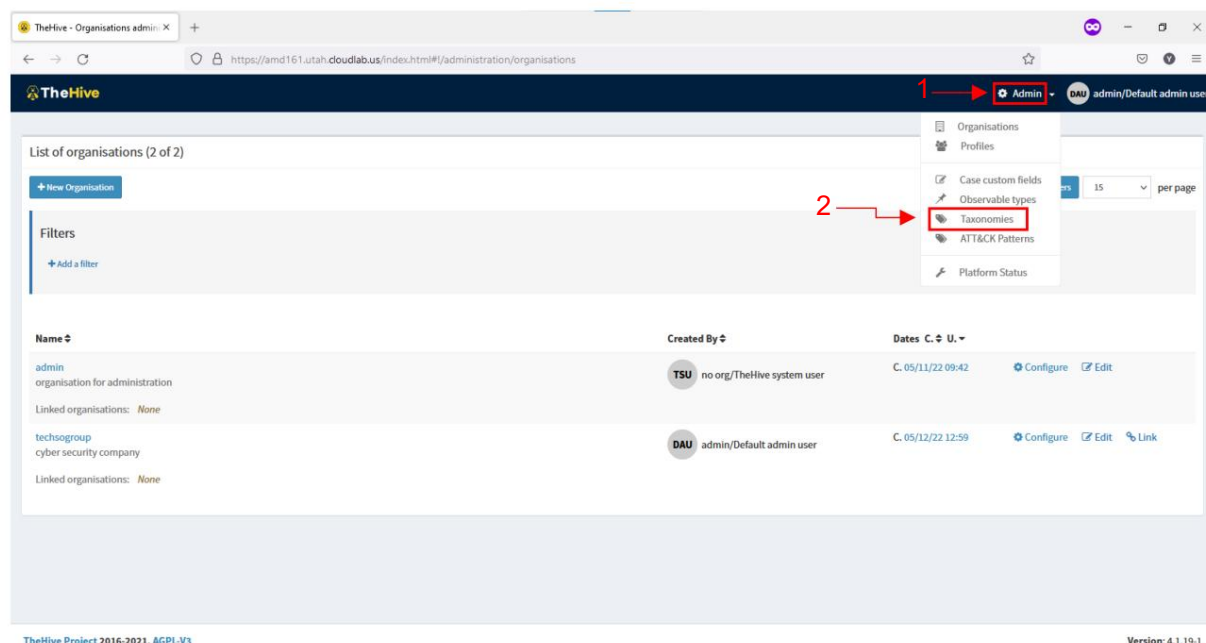


Figure 103 : Ajouter des taxonomies MISP (1)

Il ne nous reste plus qu'à suivre le lien "à partir d'ici", télécharger le fichier zip et le déposer, puis cliquer sur "Oui, l'importer" <Figure 104>.

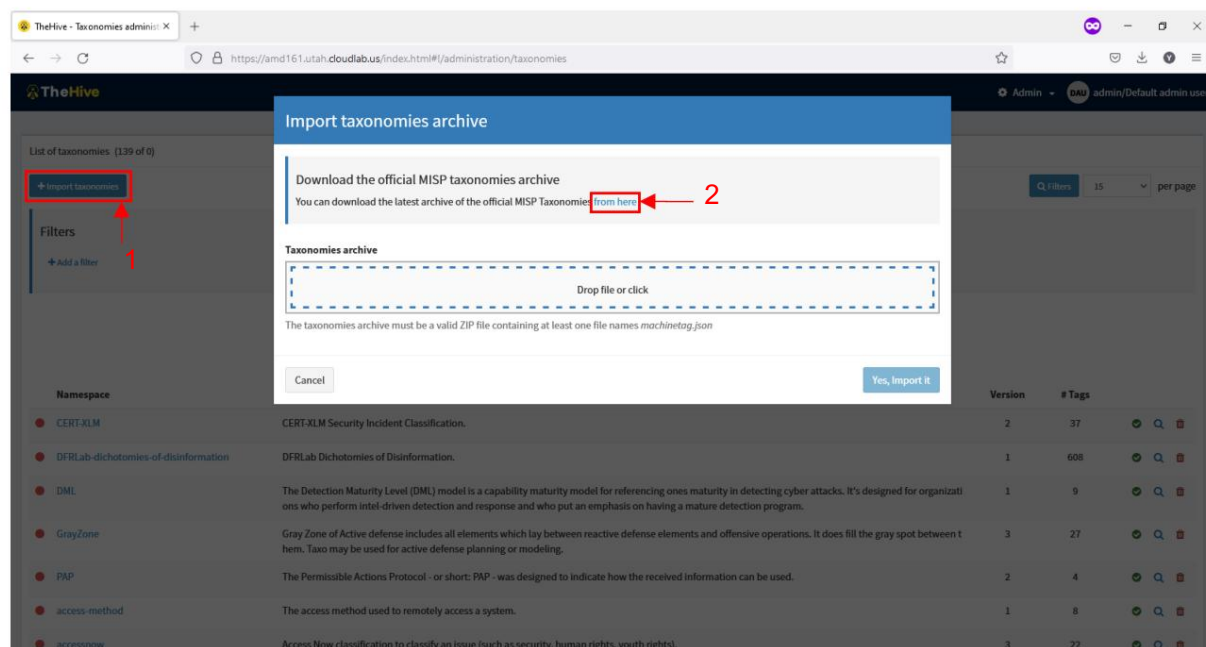


Figure 104 : Ajouter des taxonomies MISP (2)

La page suivante apparaîtra une fois le fichier téléchargé <Figure 105>.

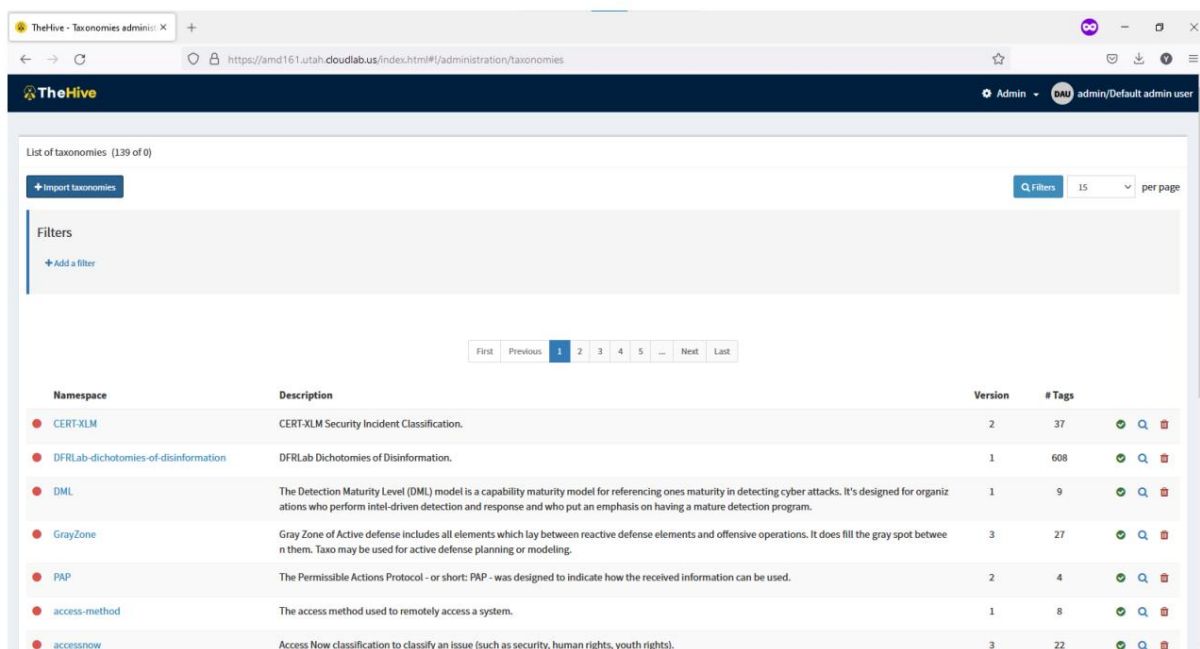


Figure 105 : Ajouter des taxonomies MISP (3)

8. Scénario : manuel de phishing

Code python d'hameçonnage

```
import imaplib
import email
import re
import uuid
from thehive4py.api import TheHiveApi
from thehive4py.models import Alert, AlertArtifact

# TheHive api login api =
TheHiveApi('http://127.0.0.1:9000', 'hE2j3wr2jY5oHZYPikLZNS13ZsiUnPgr', cert=False, organisation="TechsoGroup", version=4)

# Fonction pour extraire les URL et les stocker dans des ensembles d'une liste [(protocol_1, domain_1, path_1), (protocol_2, domain_2, path_2)]
def get_urls(string):
    urls = re.findall(r'([http|https])://([a-zA-Z0-9-_.]+\.[a-zA-Z]{2,})/?(.*)', string)
    return list(set(urls))

# Fonction pour extraire les e-mails et les stocker dans des ensembles avec une liste [(user1, domain_1), (user_2, domain_2)]
def get_emails(string):
    emails = re.findall(r'([a-zA-Z0-9-_.]+\.[a-zA-Z]{2,})@([a-zA-Z0-9-_.]+\.[a-zA-Z]{2,})', string)
    return list(set(emails))

# Fonction pour extraire les IPv4 et les stocker dans une liste [IP_1, IP_2]
def get_IPv4s(string):
    IPs = re.findall(r'([0-9]{1,3}\.[0-9]{1,3}\.[0-9]{1,3}\.[0-9]{1,3})', string)
    return list(set(IPs))

# connexion au compte de messagerie avec le mode ssl
def login_to_email_account():
    # login creds host =
    'imap.email.server' username =
    'user@domain.tld' password = 'Password&123'

    # processus de connexion
    mail = imaplib.IMAP4_SSL(hôte)
    mail.login(nom d'utilisateur, mot de passe)
```

```

    retourner le courrier

# Fonction pour extraire les pièces jointes et les stocker dans un dossier attachment_dir = 'D:/
attachments' list_files = []

# Préparer les artefacts
observables = []

# récupère la boîte de réception et analyse les champs
souhaités def get_inbox(mail):

    # obtenir la boîte de réception et filtrer les informations nécessaires mail.select("inbox") _
    search_data = mail.search(None, 'UNSEEN') my_messages = [] for num in
    search_data[0].split() : email_data = { } data = mail.fetch(num, '(RFC822)') b = data[0]
    email_message = email.message_from_bytes(b) email_data['raw'] = str(email_message)
    string = str(email_message)

    _
    _

    # obtenir les champs personnalisés de l'e-mail pour l'en-
    tête dans ['date','from','to','reply-to', 'subject'] : email_data[header] = email_message[header]

    # obtenir le corps html de l'e-mail pour la partie
    dans email_message.walk() : if part.get_content_type()
    == "text/html": body = part.get_payload(decode=True)
    email_data['html'] = body.decode ()

    email_data['urls'] = get_urls(string) email_data['emails'] =
    get_emails(string) email_data['IPs'] = get_IPv4s(string)
    my_messages.append(email_data) return my_messages

def create_Analysis(email):

    # ajout d'artefacts IP pour l'IP
    dans l'e-mail["IPs"] :
        artefacts.append(AlertArtifact(dataType='ip', data=IP))

    domaines = [] urls
    = e-mails = ""

    # recherche de domaines dans les urls pour url in
    email['urls'] :
        domaines.append(url[1]) urls = urls
        + str(url[0]) + '://' + str(url[1]) + str(url[2]) + "\n"

    # recherche de domaines dans les e-mails pour le
    courrier dans email['emails'] : domaines.append(mail[1])
        emails = emails + str(mail[0]) + '@' + str(mail[1])
        + '\n'

    # supprimer les domaines en double
    list_domains = list(set(domains))

    # ajout d'artefacts de domaine pour le
    domaine dans list_domains :
        artefacts.append(AlertArtifact(dataType='domain', data=domain))

    # ajout d'artefacts de fichier pour le
    fichier dans list_files :
        artefacts.append(AlertArtifact(dataType='file', data=str(attachment_dir) + '/' + str(file)))

    # Préparez l'exemple Alert sourceRef =
    str(uuid.uuid4())[0:6]

```

```

alert =
    Alert( title='Phishing Alert', tlp=3,
          tags=['TheHive4Py', 'phishing'],
          description='Un e-mail de phishing', type='external',
          source='Email', sourceRef=sourceRef ,
          artefacts=artefacts, caseTemplate='hameçonnage',
          customFields={ "raw": str(email['raw']), "date":
            str(email['date']), "from": str(email['from']), "to":
            str(email['to']), "reply-to": str(email['reply-to']), "subject":
            str(email['subject']) , "html": str(email['html']), "urls":
            str(urls), "emails": str(emails)

    }

)

# Créer l'alerte try :

réponse = api.create_alert(alert) alert_id = response.json()
['id'] réponse = api.promote_alert_to_case(alert_id)
case_id = response.json()['id'] réponse = api.get_case_observables(case_id)
ids = response.json() pour les obs dans les identifiants :

réponse = api.run_analyzer('CORTEX', obs['id'], 'VirusTotal_GetReport_3_0')
print('Alerte créée avec succès')

sauf:
    print("Erreur de création d'alerte")

si __nom__ == '__main__':

    mail = login_to_email_account()

    tandis que (vrai):
        inbox = get_inbox(mail) pour le courrier
        électronique dans la boîte de réception :
            print("Analyser l'email ...")
            create_Analysis(email) print("Analyse
            effectuée")

```

Figure 106 : code python d'hameçonnage

9. Scénario : Playbook de Suricata

Code python Suricata

```

# Ceci est un playbook pour les alertes suricata

from flask import Flask, demande, abandon import uuid from
thehive4py.api import TheHiveApi from thehive4py.models import
Alert, AlertArtifact

app = flask (__nom__)

api = TheHiveApi('http://127.0.0.1:9000', 'hE2j3wr2jY5oHZYPikLZNS13ZsgnPg', cert=False, organisation="TechsoGroup", version=4)

@app.route('/webhook-7ad3e94b-4704-4df0-963d-d1b78c4020f1', method=['POST']) def webhook(): if request.method ==
'POST' and request.json['event_type'] != 'Aucun': createAlert(request.json) return 'success', 200 elif request.json['event_type'] ==
'Aucun': print('Ceci n'est pas une alerte connue')

```

```

    autre:
        abandonner(400)

def createAlert(obj):

    # Préparer les artefacts
    observables = [
        AlertArtifact(dataType='ip', data=obj['src_ip']),
        AlertArtifact(dataType='ip', data=obj['dest_ip'])
    ]

    # Préparez l'exemple Alert sourceRef =
    str(uuid.uuid4())[0:6] alert = Alert( title='Suricata
Alert', tlp=3, tags=['TheHive4Py', 'suricata', 'flow'],
description=str(obj['proto'])+'
'+str(obj['event_type'])+' de

'+str(obj['src_ip'])+':'+str(obj['src_port'])+ ' à '+str(obj['dest_ip'])
+':'+str(obj['dest_port']) ' ), type='interne', source='Suricata',
sourceRef=sourceRef, artefacts=artefacts, caseTemplate='suricata',
customFields={

    "timestamp": str(obj['timestamp']), "flow-id":
    str(obj['flow_id']), "ingress-interface": str(obj['in_iface']),
    "event-type " : str(obj['event_type']), "source-ip": str(obj['src_ip']),
    "source-port": int(obj['src_port']), "destination-ip": str(obj['dest_ip']),
    "destination-port": int(obj['dest_port']), "protocol": str(obj['proto']),
    "json-details": str(obj)

    }

)

# Créez l'alerte essayez :
response =
    api.create_alert(alert) alert_id = response.json()['id']
    response = api.promote_alert_to_case(alert_id)
    case_id = response.json()['id'] response = api.
    get_case_observables(case_id) ids = response.json() print(ids) for obs
    in ids :

        réponse = api.run_analyzer('CORTEX', obs[id], 'VirusTotal_GetReport_3_0')
        print('Alerte créée avec succès')
sauf :
    print("Erreur de création d'alerte")

si __name__ == '__main__':
    app.run(host='127.0.0.1', port=5001)

```

Image 107 : code python Suricata

10. Scénario : Playbook de Kaspersky

Code python de Kaspersky

```

# Ceci est un playbook pour les alertes kaspersky

from flask import Flask, requête, abandon import uuid from
thehive4py.api import TheHiveApi from thehive4py.models
import Alert, AlertArtifact import xml.etree.ElementTree as
ET

app = flask(__nom__)

```

```

api = TheHiveApi('http://127.0.0.1:9000', 'hE2j3wr2jY5oHZYPikLZNSfdZsiUnPgr', cert=False, organisation="TechsoGroup", version=4)

@app.route('/webhook-a852a219-5a67-453b-9756-0efd3fcd477a', method=['POST']) def webhook() : strdata = request.data.decode()
tree = ET.fromstring(strdata)

    si request.method == 'POST' et tree[3].text == 'Kaspersky' :
        createAlert(strdata) renvoie
        'succès', 200
    autre:
        print('Ceci n'est pas une alerte connue') abort(400)

def createAlert(strdata):

    racine = ET.fromstring(strdata)
    # Préparer les artefacts observables
    = [
        AlertArtifact(dataType='hash', data=root[6][0][1].text)
    ]

    # Préparez l'exemple Alert sourceRef =
    str(uuid.uuid4())[0:6] alert = Alert( title='Kaspersky Alert',
    tlp=3, tags=['TheHive4Py', 'Kaspersky'], description=root
    [1].text, type='interne', source='Kaspersky',
    sourceRef=sourceRef, artefacts=artefacts,
    caseTemplate='kaspersky', customFields={ "short-
    description": str(root[0].text) , "description": str(root[1].text),
    "authored-by": str(root[3].text), "authored-date":
    str(root[4].text), "indicator- type": str(root[6][0][0]
    [1].get('type')), "indicateur-contenu": str(root[6][0][0]
    [1].text )

    }
)

# Créez l'alerte essayez :
response = api.create_alert(alert)
    alert_id = response.json()[0]['id'] response =
    api.promote_alert_to_case(alert_id) case_id =
    response.json()[0]['id'] response = api.get_case_observables(case_id) ids =
    response.json() pour les obs dans les ids : réponse = api.run_analyzer('CORTEX',
    obs[id], 'VirusTotal_GetReport_3_0')

    print('Alerte créée avec succès')

    sauf:
        print("Erreur de création d'alerte")

si __name__ == '__main__':
    app.run(host='127.0.0.1', port=5002)

```

Figure 108 : Code python de Kaspersky

Définir le transfert pour les playbooks

Nous devons spécifier le port sur lequel nous voulons que notre proxy écoute, pour nos données entrantes de suricata et Kaspersky et mapper ces ports au webhook défini pour eux.

Nous devons ajouter les lignes suivantes au fichier reverse-proxy.conf sur l'instance TheHive :

Orchestration, automatisation et réponse de la sécurité

```

serveur {
    écouter 4431 ssl; # le port sur lequel votre instance écoute nom_serveur
    thehive.younessaitichou.com ;

    certificat_ssl /etc/ssl/certs/thehive-cert.pem ; /etc/ssl/private/thehive
    clé_certificat_ssl cléprivée.pem;

    proxy_connect_timeout 600 ; proxy_send_timeout
    600 ; proxy_read_timeout 600 ; send_timeout 600 ;
    client_max_body_size
    20M;

    proxy_buffering désactivé ;
    client_header_buffer_size 8k ;

    emplacement / {
        add_header
        Strict-Transport-Security "max-age=31536000 ; includeSubDomains" ;
        proxy_pass http://127.0.0.1:5001/ ;
        # webhook suricata
        proxy_http_version 1.1 ; proxy_set_header Connexion
        "" ;
    }
}

```

Figure 109 : Cartographie proxy Suricata

Après cela, nous devons ajouter les lignes suivantes au fichier reverse-proxy.conf sur l'instance TheHive :

```

serveur {
    écouter 4432 ssl; # le port sur lequel votre instance écoute nom_serveur
    thehive.younessaitichou.com ;

    certificat_ssl /etc/ssl/certs/thehive-cert.pem ; /etc/ssl/private/thehive
    clé_certificat_ssl cléprivée.pem;

    proxy_connect_timeout 600 ; proxy_send_timeout
    600 ; proxy_read_timeout 600 ; send_timeout 600 ;
    client_max_body_size
    20M;

    proxy_buffering désactivé ;
    client_header_buffer_size 8k ;

    emplacement / {
        add_header
        Strict-Transport-Security "max-age=31536000 ; includeSubDomains" ; proxy_pass
        http://127.0.0.1:5002/ ;
        # kaspersky webhook
        proxy_http_version 1.1 ; proxy_set_header Connexion
        "" ;
    }
}

```

Figure 110 : Mappage du proxy Kaspersky